ETHICAL HACKERLIK SAN’ATI

PROFESSIONAL 12 OY / 48 HAFTA / 50% NAZARIYA + 50% AMALIYOT

ETHICAL HACKERLIK SAN’ATI

Linux · TCP/IP · Web · Windows · Cloud

Malware · Ransomware · Forensics · XDR

NASHR MAQSADI

12 oy davomida nazariy asoslar, ruxsatli tajribalar, texnik hisobot va mustaqil ish portfeli yaratish. Ushbu kitob “hacking buyruqlari to‘plami” emas: xavfsizlik tizimlarini tushunish, nazoratni baholash va natijani tekshirish uchun professionallikka yo‘naltirilgan o‘quv qo‘llanma.

Nashr: 2026-yil noyabr. 320 bet: 48 haftaning 144 nazariya + 144 amaliyot sahifasi, 32 sahifalik kirish va ilovalar. Mualliflik matni original; tashqi manbalar bibliografiyada ko‘rsatiladi.

TUZATILGAN NASHR 1.1 | 2026

48 hafta nazariya, buyruqlar va amaliy sinovlar qayta tahrir qilindi. Ruxsatli mashg‘ulotlar; noto‘g‘ri original misollar o‘rniga aniq dalil mezonlari.

12 oy oxirida nimalarni bilasan?

O‘QISH NATIJALARI / PROFESSIONALLIK MEZONI

Bilimga emas, tasdiqlanadigan kompetensiyaga yo‘naltirilgan maqsadlar

• Linuxda foydalanuvchi, ruxsat, process va tarmoq holatini dalil bilan sharhlay olish.

• TCP/IP, DNS, HTTP, TLS va NATdagi paket yo‘lini to‘g‘ri tushuntira olish.

• O‘z yoki yozma ruxsatli assetlarda inventarizatsiya va minimal ta’sirli zaiflik tekshiruvi o‘tkazish.

• AuthN, AuthZ, session management, API, SQL va output encoding nazoratlarini tushunish.

• Windows/Active Directory, cloud IAM va Wi-Fi uchun xavf modelini qurish.

• Malware, ransomware, worm va virus xatti-harakatini tahlikasiz tahlil qilish; YARA/Sigma detection ishlab chiqish.

• SOC/DFIR qarorlarini NIST uslubida izohlash, xatolarni oldini olish va recovery rejasini sinash.

• Professional pentest finding va xavfsizlik arxitekturasi hisobotini yozish.

Darajalar: 3, 6, 9 va 12-oy

3-oy: network/RoE/asset inventory. 6-oy: secure web/auth va Windows loglar. 9-oy: malware/ransomware tahlili va recovery. 12-oy: 6 artefaktli professional portfel, detection va remediatsiya ko‘rsatkichlari.

Sertifikat, ish o‘rni yoki professional maqom 12 oy oxirida kafolatlanmaydi. Natija mashqlarni mustaqil bajarish, xatoni qayta tekshirish va tanqidiy fikrlashga bog‘liq.

Mundarija va sahifalar xaritasi

HAR OY 24 BET / 12 BET NAZARIYA + 12 BET AMALIYOT

Oy	Mavzu	Bet
01	Linux va tarmoq poydevori	9–32
02	Nmap, Wireshark va paketlar	33–56
03	Pentest metodologiyasi va OSINT	57–80
04	HTTP, autentifikatsiya va web sinovlari	81–104
05	Secure coding, API va web tahdidlar	105–128
06	Windows, Active Directory va identifikatsiya	129–152
07	Linux hardening, konteyner va cloud	153–176
08	Malware anatomiyasi va reverse engineering	177–200
09	Ransomware, worm, virus va tiklash	201–224
10	SOC, SIEM, XDR va detection engineering	225–248
11	Digital forensics, threat intelligence va history	249–272
12	Professional faoliyat va yakuniy portfel	273–296

Ilovalar

Sahifa	Bo‘lim
297–308	Tarixiy hujumlar, malware oilalari, OWASP/NIST/MITRE va manbalar
309–320	Professional RoE, pentest report, recovery, Sigma/IR mashqlar va portfel

Haftalik format: 1-bet — asos; 2-bet — texnik mexanizm; 3-bet — risk/himoya; 4-bet — o‘quv tajribasi; 5-bet — chuqur amaliyot; 6-bet — natija, troubleshooting va report.

Ethical Hacking: fan va mas’uliyat

RUXSAT VA TA’SIRNI BOSHQARISH

Etika texnik qobiliyatning cheklovi emas, faoliyat standartidir

Xavfsizlik tekshiruvchisi hujumchi foydalanishi mumkin bo‘lgan kamchiliklarni tushunadi va tekshiradi. Ammo shaxsiy akkauntga egalik qilish sizga Telegram, Google yoki bank serverlariga istalgan ekspluatatsiya yoki trafik yuklamasini yuborish vakolatini bermaydi. Aktiv egasidan aniq scope, vaqt oralig‘i va to‘xtatish qoidalari bo‘lishi kerak.

• No-go: uchinchi tomon akkauntlari, ruxsatsiz serverlar, kamera va Wi-Fi tarmoqlari; haqiqiy ma’lumotni o‘g‘irlash; DoS/DDoS; malware tarqatish.

• Yaxshi tajriba: 127.0.0.1 local serveri, maxsus o‘quv VMlari, sintetik login jurnallari, o‘z infratuzilmangizning read-only auditi.

• Kuchli hisobot: topilma, aktiv va kontekst, minimal qaytariladigan isbot, ta’sir, fix, retest, noaniqlik.

• Qandaydir amal xizmatni to‘xtatishi yoki shaxsiy ma’lumotga tegishi mumkin bo‘lsa, stop conditionni ishga tushiring.

Yuqori xavfli mavzularni qanday o‘rganamiz?

Ransomware: arxitektura, real tarixiy oqibatlar, signallar, zaxira nusxa va tiklash. Worm: graf simulyatsiyasi va segmentatsiya. Credential attacks: offline synthetic eventlar va MFA himoyasi. Exploit: faqat izolyatsiyalangan o‘quv target. Operational malware yoki ruxsatsiz ekspluatatsiya yo‘riqnomalari kitobga kiritilmagan.

Boshlanish cheklisti — qurilma va xavfsiz muhit

HAFTA 0 / LAB SETUP

Minimal uskuna

• VirtualBox/VMware va Kali Linux; 2 vCPU, 4+ GB RAM, yetarli disk va snapshot (resursga mos).

• VM NIC: NAT — yangilanishlar, Host-Only/Internal Network — izolyatsiyalangan test target.

• Har bir o‘quv darsida alohida `~/ehs/weekXX` papkasi; hech qachon shaxsiy token yoki parollarni repo’ga joylashtirma.

• Masofadan aniqlanmagan GitHub skriptlarini `curl | bash` orqali ijro qilma; manba, commit, checksum va scope tekshirilsin.

Kali Linux / Python

```
uname -a
ip -br addr
ip -4 route
python3 --version
nmap --version
ss -ltnp
```

Pass shartlari

• Kali interfeysining qaysi biri NAT/Host-Only ekanini bilasan.

• `ip route`da default gateway qayerdan kelishini tushuntirasan.

• Nmap faqat aniq ruxsatli IPga yuborilishi yozilgan.

• VM snapshot va tozalash rejasi mavjud.

Ish daftari: dalil va xulosa uchun joy

RoE yozishni amalda boshlash

KELISHUVNI BOSHQARISH / SECURITY MANAGEMENT

Namuna: loopback pentest uchun scope

RoE (namunaviy YAML)

```
scope_id: EHS-2026-001
asset_owner: self
allowed: [127.0.0.1, local-training-vm]
out_of_scope: [third-party, personal-accounts]
traffic_policy: low, no-DoS
stop_condition: unexpected impact or data exposure
report_retention: 30 days, redacted
approval: owner / date / signature
```

- Ruxsat scope/IP/vaqt aniqlanmaguncha aktiv tekshiruv yo‘q.
- Uchinchi tomon SaaS/Internet servislari alohida ruxsat talab qiladi.
- Skanerlash xavfsizlik tadqiqi maqsadidan chiqsa stop condition bilan tugatiladi.

Mustaqil vazifa

O‘zingning VM muhiting uchun to‘rtta bandni yoz: ruxsatli host, ruxsatli port, ma’lumot yig‘ish chegarasi va emergency stop. Yozma hujjatga sana va muhit versiyasini qo‘sh.

Dalil yig‘ish va qayta tekshirish standarti

REPORTING / PROVENANCE

Kali Linux / Python

```
mkdir -p ~/ehs/evidence/{raw,notes,images}
date -u +%FT%TZ | tee ~/ehs/evidence/notes/utc.txt
printf 'safe-lab-output\n' > ~/ehs/evidence/raw/example.txt
sha256sum ~/ehs/evidence/raw/example.txt \
  > ~/ehs/evidence/notes/manifest.sha256
sha256sum -c ~/ehs/evidence/notes/manifest.sha256
```

Professional dalil sahifasi uchun 7 savol

- Qaysi aktiv va qaysi berilgan vakolat asosida sinovdan o‘tdi?
- Aniq buyruq, tool versiyasi, vaqt zonasi, kutilgan xulq nima edi?
- Haqiqiy kuzatuv qaysi fayl, screenshot yoki packet captureda bor?
- Holatni qayta ko‘rishda credential va shaxsiy ma’lumot redakt qilinganmi?
- Bu xulosa uchun muqobil izoh bormi?
- Tuzatish rejasining biznes narxi va rollbacki qanday?
- Takror tekshirish (retest) PASS/FAIL/UNVERIFIED sifatida ajratildimi?

Ish daftari: dalil va xulosa uchun joy

12 oylik ish rejasi va baholash

O‘QISH RITMI / MAHORAT SERTIFIKATI EMAS

Haftalik odat

Ish turi	Soat/hafta	Evidence
Nazariy o‘rganish	4–6	Konspekt, concept map, nazorat savollari
Amaliy mashq	4–6	Command, output, expected/actual, cleanup
Report va review	1–2	Finding, remediation, retest

Oylik 100 ballik baholash

- Nazariya 25: termin, protokol, threat model va asoslar.
- Amaliyot 35: xavfsiz bajarish, buyruqlar, xatolarni topish, takrorlash.
- Dalil 20: vaqt, tool, hash va tekshiriladigan output.
- Defensive ta’sir 20: fix, detection, restore, report.

Ketma-ketlik

1–4 hafta: Linux/tarmoq; 5–8: paketlar; 9–12: RoE/inventarizatsiya; 13–20: web; 21–24: Windows; 25–28: Wi-Fi/cloud; 29–36: malware/ransomware; 37–44: detection/IR/purple; 45–48: capstone.

01-hafta / Linux muhiti, shell va ruxsatlar

1-OY • Linux va tarmoq poydevori | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Bash, stdin/stdout/stderr, exit code, pipe, PATH, sudo, fayl egasi va POSIX ruxsatlari.

Asosiy tushuncha

Shell buyruqni qabul qiladi, tizim esa uni foydalanuvchining UID/GID huquqlari bilan bajaradi. Faylga kirish huquqi egasi, guruhi va boshqa foydalanuvchilar uchun alohida belgilanadi.

Tayanch atamalarni ajratamiz

1. stdin/stdout/stderr	stdin=kirish (0); stdout=oddiy natija (1); stderr=xatolik oqimi (2). Yo‘naltirishlarni adashtirmang.
2. exit code	0 odatda muvaffaqiyat; 0 dan farqli kod xatolik yoki maxsus holatni bildiradi.
3. POSIX ruxsatlari	r=o‘qish, w=yozish, x=ijro/katalogga kirish; owner/group/other alohida.
4. shell / sudo	Bash buyruqni tahlil qiladi; sudo ayrim buyruqlarni boshqa foydalanuvchi, ko‘pincha root sifatida bajaradi.

Keng tarqalgan chalkashlik

Aniqlik: Terminal va shell bir xil emas.

Chuqurroq konseptual tahlil

Linux permission uchliklari owner/group/other uchun read-write-execute bitlaridan iborat. Directory uchun x (execute) ko‘pincha traversal huquqini anglatadi, file uchun esa ijroga ruxsat. `chmod 600` oddiy fayl egasiga read/write beradi; `umask` yangi obyektlar uchun default permission’ni cheklaydi.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

01-hafta / Texnik mexanizm

1-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Shell buyruqni qabul qiladi, tizim esa uni foydalanuvchining UID/GID huquqlari bilan bajaradi. Faylga kirish huquqi egasi, guruhi va boshqa foydalanuvchilar uchun alohida belgilanadi.

stdin/stdout/stderr	exit code	POSIX ruxsatlari	shell / sudo

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
pwd	Joriy ish katalogining absolyut yo‘lini chiqaradi; diskda hech narsa o‘zgartirmaydi.
id	UID, GID va guruhlar ro‘yxatini chiqaradi; privilege kontekstini tekshirish uchun.
ls -la	Barcha, shu jumladan yashirin fayllarni huquq/egasi bilan ro‘yxatlaydi.
stat	Fayl metama’lumoti, permission va vaqtlarni chiqaradi; argument kerak.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: POSIX shell — komandalar child process bilan tugaydi; `PATH` qanday executable tanlanishini belgilaydi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Terminal va shell bir xil emas: terminal interfeys, shell buyruq talqin qiluvchi dastur. Natija: oldingi va keyingi stat natijasi; UID/GID va 600 ma’nosi.

01-hafta / Xavf va himoya

1-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Ruxsatni o‘zgartirishdan oldin qaysi fayl egasi va guruhi amalni bajarishini tushuntir.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Linux permissions mini-cheatsheet. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

systemd service unitda User, Group, WorkingDirectory, Environment, ProtectSystem, NoNewPrivileges va Restart parametrlari ishlash va xavfsizlikka ta’sir qiladi. `systemctl status` xizmat ishga tushganini ko‘rsatadi, lekin u to‘g‘ri ishlayotganini yoki autentik natija chiqarayotganini yakka o‘zi isbotlamaydi.

Manba yo‘nalishi: [S01][S03][S15][S19]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: chmod faqat o‘z sinov faylingda ishlasin; root yoki umumiy katalogga ruxsatlarni o‘zgartirma.

01-hafta / Amaliy mashg‘ulot A

1-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: oldingi va keyingi stat natijasi; UID/GID va 600 ma’nosi.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 01 | Mavzuga mos amaliyot

```
mkdir -p ~/ehs/week01
printf 'lab\n' > ~/ehs/week01/test.txt
stat -c '%a %U %G %n' ~/ehs/week01/test.txt
chmod 600 ~/ehs/week01/test.txt
stat -c '%a %U %G %n' ~/ehs/week01/test.txt
```

KUTILGAN NATIJA: Oxirgi stat qiymati 600; fayl egasida o‘qish va yozish huquqi qoladi.
XAVFSIZLIK: chmod faqat o‘z sinov faylingda ishlasin; root yoki umumiy katalogga ruxsatlarni o‘zgartirma.

TUSHUNTIRISH: Shell buyruqni qabul qiladi, tizim esa uni foydalanuvchining UID/GID huquqlari bilan bajaradi. Faylga kirish huquqi egasi, guruhi va boshqa foydalanuvchilar uchun alohida belgilanadi.
EHTIYOT: Terminal va shell bir xil emas: terminal interfeys, shell buyruq talqin qiluvchi dastur.

01-hafta / Amaliy mashg‘ulot B

1-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #1, Linux muhiti, shell va ruxsatlar.
Command / tool	Linux terminal / ruxsatli lokal sinov
Expected	Oxirgi stat qiymati 600; fayl egasida o‘qish va yozish huquqi qoladi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Terminal va shell bir xil emas: terminal interfeys, shell buyruq talqin qiluvchi dastur.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: oldingi va keyingi stat natijasi; UID/GID va 600 ma’nosi. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Tarmoq auditida manzilning o‘zi emas, asset owner va ruxsat scope asos. Natijalar jadvalida interface,

Texnik izoh: Terminal va shell bir xil emas: terminal interfeys, shell buyruq talqin qiluvchi dastur. Shell buyruqni qabul qiladi, tizim esa uni foydalanuvchining UID/GID huquqlari bilan bajaradi. Faylga kirish huquqi egasi, guruhi va boshqa foydalanuvchilar uchun alohida belgilanadi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

01-hafta / Hisobot va challenge

1-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Linux permissions mini-cheatsheet

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Linux muhiti, shell va ruxsatlar” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Linux muhiti, shell va ruxsatlar. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: oldingi va keyingi stat natijasi; UID/GID va 600 ma’nosi.
Xavfsizlik chegarasi: chmod faqat o‘z sinov faylingda ishlasin; root yoki umumiy katalogga ruxsatlarni o‘zgartirma.

02-hafta / IP, subnet, NAT va routing

1-OY • Linux va tarmoq poydevori | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

IPv4/CIDR, private IP, ARP/NDP, gateway, DNS, DHCP, NAT, port tushunchalari.

Asosiy tushuncha

IP paket qayerga borishini routing jadvali hal qiladi. CIDR prefiks tarmoq chegarasini, default gateway esa maxsus marshrut bo‘lmaganda keyingi tugunni bildiradi. VirtualBox NAT fizik Wi-Fi segmenti emas.

Tayanch atamalarni ajratamiz

1. IPv4/CIDR	IPv4 — 32 bitli manzil; /24 kabi prefiks tarmoq bitlari sonini bildiradi.
2. private IP	10/8, 172.16/12 va 192.168/16 ichki manzil diapazonlari; internetda to‘g‘ridan-to‘g‘ri marshrutlanmaydi.
3. ARP/NDP	ARP IPv4 uchun, NDP IPv6 uchun mahalliy qo‘shni manziliga yo‘llashni ta’minlaydi.
4. gateway	Mahalliy segmentdan tashqaridagi manzilga paket yuboriladigan keyingi yo‘riqnoma.

Keng tarqalgan chalkashlik

Aniqlik: 10.0.2.x VM manzilini kompyutering ulangan haqiqiy Wi-Fi subneti bilan tenglas.

Chuqurroq konseptual tahlil

Routing jadvalida “default via” odatda boshqa ko‘proq xos marshrutga mos kelmagan paketlarning next hopini ko‘rsatadi. Masalan, `10.0.2.0/24 dev eth0` lokal kanalga kiradi, `default via 10.0.2.2` esa tashqi manzilga gateway. VirtualBox NAT IP manzilini LAN-dagi fizik Wi-Fi qurilmalar bilan bir xil deb qabul qilish katta diagnostika xatosidir.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

02-hafta / Texnik mexanizm

1-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

IP paket qayerga borishini routing jadvali hal qiladi. CIDR prefiks tarmoq chegarasini, default gateway esa maxsus marshrut bo‘lmaganda keyingi tugunni bildiradi. VirtualBox NAT fizik Wi-Fi segmenti emas.

IPv4/CIDR	private IP	ARP/NDP	gateway

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
ip -br addr	Interfeys va IP/CIDR manzillarini qisqa ko‘rinishda o‘qiydi.
ip route	Mahalliy routing jadvali; aktiv skan emas.
ip neigh	Qo‘shni MAC/IP cache holatini ko‘rsatadi.
resolvectl status	systemd-resolved DNS konfiguratsiyasini ko‘rsatadi; mavjud bo‘lmasligi mumkin.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Owner/group/other ruxsatlari ACL yoki MAC nazoratining barcha imkoniyatlarini ifodalamaydi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: 10.0.2.x VM manzilini kompyutering ulangan haqiqiy Wi-Fi subneti bilan tenglashtirma. Natija: VM va Windows host uchun alohida IP/gateway xaritasi.

02-hafta / Xavf va himoya

1-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

eth0 da 10.0.2.x ko‘rish fizik Wi-Fi scan huquqini bermaydi.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik kompрometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Kali network topology PDF. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Tarmoq auditida manzilning o‘zi emas, asset owner va ruxsat scope asos. Natijalar jadvalida interface, IPv4/IPv6, mask, route, source of evidence, confidence va timestamp bo‘lishi kerak. Screenshot bir lahzalik kuzatuv; DHCP lease yoki VPN ulanishi bilan IP o‘zgarishi mumkin.

Manba yo‘nalishi: [S01][S03][S15][S19]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Bu buyruqlar o‘z kompyuteringdagi marshrutni o‘qiydi; boshqa tarmoqni skanerlamaydi.

02-hafta / Amaliy mashg‘ulot A

1-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: VM va Windows host uchun alohida IP/gateway xaritasi.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 02 | Mavzuga mos amaliyot

```
ip -br addr
ip -4 route
ip route get 1.1.1.1
ip neigh show
```

KUTILGAN NATIJA: Interfeys nomi, CIDR, default via va next-hop ajratiladi; faqat routing jadvali o‘qiladi.
XAVFSIZLIK: Bu buyruqlar o‘z kompyuteringdagi marshrutni o‘qiydi; boshqa tarmoqni skanerlamaydi.

TUSHUNTIRISH: IP paket qayerga borishini routing jadvali hal qiladi. CIDR prefiks tarmoq chegarasini, default gateway esa maxsus marshrut bo‘lmaganda keyingi tugunni bildiradi. VirtualBox NAT fizik Wi-Fi segmenti emas.
EHTIYOT: 10.0.2.x VM manzilini kompyutering ulangan haqiqiy Wi-Fi subneti bilan tenglashtirma.

02-hafta / Amaliy mashg‘ulot B

1-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #2, IP, subnet, NAT va routing.
Command / tool	i Linux terminal / ruxsatli lokal sinov
Expected	Interfeys nomi, CIDR, default via va next-hop ajratiladi; faqat routing jadvali o‘qiladi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	10.0.2.x VM manzilini kompyutering ulangan haqiqiy Wi-Fi subneti bilan tenglashtirma.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: VM va Windows host uchun alohida IP/gateway xaritasi. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Linux permission uchliklari owner/group/other uchun read-write-execute bitlaridan iborat. Directory

Texnik izoh: 10.0.2.x VM manzilini kompyutering ulangan haqiqiy Wi-Fi subneti bilan tenglashtirma. IP paket qayerga borishini routing jadvali hal qiladi. CIDR prefiks tarmoq chegarasini, default gateway esa maxsus marshrut bo‘lmaganda keyingi tugunni bildiradi. VirtualBox NAT fizik Wi-Fi segmenti emas.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

02-hafta / Hisobot va challenge

1-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Kali network topology PDF

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “IP, subnet, NAT va routing” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: IP, subnet, NAT va routing. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: VM va Windows host uchun alohida IP/gateway xaritasi.
Xavfsizlik chegarasi: Bu buyruqlar o‘z kompyuteringdagi marshrutni o‘qiydi; boshqa tarmoqni skanerlamaydi.

© 2026 • Xavfsiz, ruxsatli tadqiqot • Nazariya + amaliyot

03-hafta / TCP/UDP va mahalliy servis

1-OY • Linux va tarmoq poydevori | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

3-way handshake, listen/bind, ephemeral port, TCP state, UDPning connectionless modeli.

Asosiy tushuncha

TCP ulanishni SYN, SYN-ACK, ACK orqali o‘rnatadi; UDP ulanish holatini saqlamaydi. Port — bitta xostdagi xizmatga mantiqiy manzil. Bind manzili kim ulanishingiz mumkinligini belgilaydi.

Tayanch atamalarni ajratamiz

1. 3-way handshake	TCP ulanishi boshlanishidagi SYN, SYN-ACK va ACK xabarlar ketma-ketligi.
2. listen/bind	Bind lokal IP:portni tanlaydi; listen TCP ulanish so‘rovlarini kutish holati.
3. ephemeral port	Mijoz ulanishi uchun operatsion tizim odatda vaqtinchalik tanlaydigan port.
4. TCP state	LISTEN, ESTABLISHED, TIME_WAIT kabi transport aloqa holatlari.

Keng tarqalgan chalkashlik

Aniqlik: Port ochiq bo‘lsa ham, bu zaiflik borligi isboti emas..

Chuqurroq konseptual tahlil

systemd service unitda User, Group, WorkingDirectory, Environment, ProtectSystem, NoNewPrivileges va Restart parametrlari ishlash va xavfsizlikka ta’sir qiladi. `systemctl status` xizmat ishga tushganini ko‘rsatadi, lekin u to‘g‘ri ishlayotganini yoki autentik natija chiqarayotganini yakka o‘zi isbotlamaydi.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

03-hafta / Texnik mexanizm

1-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

TCP ulanishni SYN, SYN-ACK, ACK orqali o‘rnatadi; UDP ulanish holatini saqlamaydi. Port — bitta xostdagi xizmatga mantiqiy manzil. Bind manzili kim ulanishingiz mumkinligini belgilaydi.

3-way handshake	listen/bind	ephemeral port	TCP state

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
ss -ltnp	Tinglayotgan TCP soketlar va ko‘rinadigan jarayonlarni chiqaradi.
ss -lunp	Tinglayotgan UDP soketlarni ko‘rsatadi; UDP TCP kabi sessiya o‘rnatmaydi.
curl -I	URLga HEAD so‘rov yuborib javob headerini ko‘rsatadi; tashqi hostga trafik ketishi mumkin.
python3 -m http.server	Lokal HTTP server ishga tushiradi; --bind 127.0.0.1 bilan cheklash kerak.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: `10.0.2.16` VirtualBox NAT bo‘lishi mumkin; fizik Wi-Fi `wlan0` VM ichida ko‘rinmasligi normal. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Port ochiq bo‘lsa ham, bu zaiflik borligi isboti emas. Natija: LISTEN holati, curl status va serverning to‘xtatilgani.

03-hafta / Xavf va himoya

1-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

0.0.0.0 va 127.0.0.1 o‘rtasidagi attack-surface farqini ko‘rsat.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Loopback service inventory. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Linux permission uchliklari owner/group/other uchun read-write-execute bitlaridan iborat. Directory uchun x (execute) ko‘pincha traversal huquqini anglatadi, file uchun esa ijroga ruxsat. `chmod 600` oddiy fayl egasiga read/write beradi; `umask` yangi obyektlar uchun default permission’ni cheklaydi.

Manba yo‘nalishi: [S01][S03][S15][S19]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: 0.0.0.0 ga bind qilish lokal serverni tarmoqqa ochishi mumkin; loopbackni tanla.

03-hafta / Amaliy mashg‘ulot A

1-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: LISTEN holati, curl status va serverning to‘xtatilgani.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 03 | Mavzuga mos amaliyot

```
# Terminal A (faqat o‘z papkangizda)
cd ~/ehs && python3 -m http.server 8000 --bind 127.0.0.1
# Terminal B
ss -ltn | grep ':8000'
curl -I http://127.0.0.1:8000/
# Terminal A: Ctrl+C bilan yop
```

KUTILGAN NATIJA: 127.0.0.1:8000 da LISTEN va lokal HTTP javobi ko‘rinadi; tashqi interfeysda server yo‘q.
XAVFSIZLIK: 0.0.0.0 ga bind qilish lokal serverni tarmoqqa ochishi mumkin; loopbackni tanla.

TUSHUNTIRISH: TCP ulanishni SYN, SYN-ACK, ACK orqali o‘rnatadi; UDP ulanish holatini saqlamaydi. Port — bitta xostdagi xizmatga mantiqiy manzil. Bind manzili kim ulanishingiz mumkinligini belgilaydi.
EHTIYOT: Port ochiq bo‘lsa ham, bu zaiflik borligi isboti emas.

03-hafta / Amaliy mashg‘ulot B

1-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #3, TCP/UDP va mahalliy servis.
Command / tool	Python3 (sintetik sinov)
Expected	127.0.0.1:8000 da LISTEN va lokal HTTP javobi ko‘rinadi; tashqi interfeysda server yo‘q.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Port ochiq bo‘lsa ham, bu zaiflik borligi isboti emas.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: LISTEN holati, curl status va serverning to‘xtatilgani. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Routing jadvalida “default via” odatda boshqa ko‘proq xos marshrutga mos kelmagan paketlarning next

Texnik izoh: Port ochiq bo‘lsa ham, bu zaiflik borligi isboti emas. TCP ulanishni SYN, SYN-ACK, ACK orqali o‘rnatadi; UDP ulanish holatini saqlamaydi. Port — bitta xostdagi xizmatga mantiqiy manzil. Bind manzili kim ulanishingiz mumkinligini belgilaydi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

03-hafta / Hisobot va challenge

1-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Loopback service inventory

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “TCP/UDP va mahalliy servis” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: TCP/UDP va mahalliy servis. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: LISTEN holati, curl status va serverning to‘xtatilgani.
Xavfsizlik chegarasi: 0.0.0.0 ga bind qilish lokal serverni tarmoqqa ochishi mumkin; loopbackni tanla.

© 2026 • Xavfsiz, ruxsatli tadqiqot • Nazariya + amaliyot

04-hafta / Bash automatizatsiya va journaling

1-OY • Linux va tarmoq poydevori | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Shell quote, redirection, grep, awk, sed, shellcheck, reproducible outputs, vaqt va timezone.

Asosiy tushuncha

Shell skriptini ishonchli qilish uchun yo‘llarni qo‘shtirnoq bilan o‘rash, qaytish kodlarini tekshirish va stdout/stderrni ajratish kerak. Log dalilini va hash manifestini saqlang.

Tayanch atamalarni ajratamiz

1. quoting	"$variable" bo‘sh joy va glob kengayishidan keladigan ko‘p xatoni oldini oladi.
2. redirection	> stdoutni faylga yozadi; 2> xatolar oqimini yozadi; >> oxiriga qo‘shadi.
3. grep / awk	grep satr qidiradi; awk maydonlar bo‘yicha tahlil qiladi.
4. sha256sum	Fayl kontentining SHA-256 nazorat yig‘indisini hisoblaydi.

Keng tarqalgan chalkashlik

Aniqlik: grep topgan satr avtomatik xavfsizlik hodisasi emas.

Chuqurroq konseptual tahlil

Tarmoq auditida manzilning o‘zi emas, asset owner va ruxsat scope asos. Natijalar jadvalida interface, IPv4/IPv6, mask, route, source of evidence, confidence va timestamp bo‘lishi kerak. Screenshot bir lahzalik kuzatuv; DHCP lease yoki VPN ulanishi bilan IP o‘zgarishi mumkin.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

04-hafta / Texnik mexanizm

1-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Shell skriptini ishonchli qilish uchun yo‘llarni qo‘shtirnoq bilan o‘rash, qaytish kodlarini tekshirish va stdout/stderrni ajratish kerak. Log dalilini va hash manifestini saqlang.

quoting	redirection	grep / awk	sha256sum

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
grep -n	Mos satrlarni qator raqami bilan chiqaradi.
awk	Matnni qator va ustunlar bo‘yicha ajratib tahlil qiladi.
sed -n	Matn oqimini tahrir qoidasi bo‘yicha chiqaradi; -n default printni o‘chiradi.
journalctl	systemd jurnalini o‘qiydi; ayrim yozuvlar uchun guruh/ruxsat kerak.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Hash o‘zgargani fayl o‘zgarganini bildiradi, kim o‘zgartirganini emas. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: grep topgan satr avtomatik xavfsizlik hodisasi emas; kontekstni tekshir. Natija: filtr natijasi, hash fayli, kutilgan satrlar soni.

04-hafta / Xavf va himoya

1-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Scriptni `set -euo pipefail` bilan tekshir; destructive buyruqlarni ishlatma.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: 1-oy imtihoni: shell/network. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Routing jadvalida “default via” odatda boshqa ko‘proq xos marshrutga mos kelmagan paketlarning next hopini ko‘rsatadi. Masalan, `10.0.2.0/24 dev eth0` lokal kanalga kiradi, `default via 10.0.2.2` esa tashqi manzilga gateway. VirtualBox NAT IP manzilini LAN-dagi fizik Wi-Fi qurilmalar bilan bir xil deb qabul qilish katta diagnostika xatosidir.

Manba yo‘nalishi: [S01][S03][S15][S19]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Loglarga haqiqiy parol, token yoki shaxsiy ma’lumot yozma.

04-hafta / Amaliy mashg‘ulot A

1-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: filtr natijasi, hash fayli, kutilgan satrlar soni.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 04 | Mavzuga mos amaliyot

```
mkdir -p ~/ehs/week04
printf 'OK\nERROR disk\nERROR auth\n' > ~/ehs/week04/log.txt
grep -n 'ERROR' ~/ehs/week04/log.txt
sha256sum ~/ehs/week04/log.txt > ~/ehs/week04/hash.sha256
sha256sum -c ~/ehs/week04/hash.sha256
```

KUTILGAN NATIJA: Ikki ERROR satri va hash tekshiruviga OK chiqadi.
XAVFSIZLIK: Loglarga haqiqiy parol, token yoki shaxsiy ma’lumot yozma.

TUSHUNTIRISH: Shell skriptini ishonchli qilish uchun yo‘llarni qo‘shtirnoq bilan o‘rash, qaytish kodlarini tekshirish va stdout/stderrni ajratish kerak. Log dalilini va hash manifestini saqlang.
EHTIYOT: grep topgan satr avtomatik xavfsizlik hodisasi emas; kontekstni tekshir.

04-hafta / Amaliy mashg‘ulot B

1-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #4, Bash automatizatsiya va journaling.
Command / tool	Linux terminal / ruxsatli lokal sinov
Expected	Ikki ERROR satri va hash tekshiruviga OK chiqadi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	grep topgan satr avtomatik xavfsizlik hodisasi emas; kontekstni tekshir.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: filtr natijasi, hash fayli, kutilgan satrlar soni. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: systemd service unitda User, Group, WorkingDirectory, Environment, ProtectSystem, NoNewPrivileges va

Texnik izoh: grep topgan satr avtomatik xavfsizlik hodisasi emas; kontekstni tekshir. Shell skriptini ishonchli qilish uchun yo‘llarni qo‘shtirnoq bilan o‘rash, qaytish kodlarini tekshirish va stdout/stderrni ajratish kerak. Log dalilini va hash manifestini saqlang.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

04-hafta / Hisobot va challenge

1-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

1-oy imtihoni: shell/network

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Bash automatizatsiya va journaling” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Bash automatizatsiya va journaling. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: filtr natijasi, hash fayli, kutilgan satrlar soni.
Xavfsizlik chegarasi: Loglarga haqiqiy parol, token yoki shaxsiy ma’lumot yozma.

05-hafta / Host discovery va port status

2-OY • Nmap, Wireshark va paketlar | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Nmap -sn, -sT, -sV, -p, -oN; host discovery va version detection farqi.

Asosiy tushuncha

Nmap ochiq yoki filtrlangan port holatini kuzatadi; xizmat mavjudligi uning zaifligini isbotlamaydi. Discovery javobi firewalldan ta’sirlanishi mumkin. --version faqat mahalliy Nmap versiyasini chiqaradi.

Tayanch atamalarni ajratamiz

1. nmap -sn	Port skanerlashsiz host topish usullarini ishga tushiradi; natija firewallga bog‘liq.
2. host discovery	Xostning javob berish ehtimolini tekshirish; javob bo‘lmasa xost yo‘q degani emas.
3. version detection	-sV servis protokoli/banneriga asoslanib dastur turini taxmin qiladi.
4. TCP -sT	TCP connect orqali portning ulanish qabul qilishini tekshiradi.

Keng tarqalgan chalkashlik

Aniqlik: -sV natijasidagi dastur versiyasi har doim aniq emas.

Chuqurroq konseptual tahlil

TCP uch bosqichli handshake SYN→SYN-ACK→ACK orqali sequence numberlarni kelishtiradi. Bu aloqa avvaldan mavjud bo‘lmagan joyda kuzatiladi. Retransmission paketning yo‘qolishi yoki kechikishini anglatsa ham, ko‘pincha tarmoq jitter yoki capture loss sabab bo‘lishi mumkin; uni hujum bilan birlashtirish uchun boshqa kontekst kerak.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

05-hafta / Texnik mexanizm

2-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Nmap ochiq yoki filtrlangan port holatini kuzatadi; xizmat mavjudligi uning zaifligini isbotlamaydi. Discovery javobi firewalldan ta’sirlanishi mumkin. --version faqat mahalliy Nmap versiyasini chiqaradi.

nmap -sn	host discovery	version detection	TCP -sT

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
nmap --version	FAQAT o‘rnatilgan Nmap dasturining versiyasini chiqaradi; tarmoq skani EMAS.
nmap -sT -p 8000 127.0.0.1	127.0.0.1:8000 ga TCP connect sinovi yuboradi; open/closed natija.
nmap -sV -p 8000 127.0.0.1	Lokal 8000 portdagi servisni probe orqali taxmin qiladi; natija ehtimoliy.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Host discovery response bo‘lmasa, host ishlamayapti degani emas; filtering sabab bo‘lishi mumkin. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: -sV natijasidagi dastur versiyasi har doim aniq emas; serverdagi konfiguratsiya bilan solishtir. Natija: server oldin/keyin port natijalari va `nmap --version` izohi.

05-hafta / Xavf va himoya

2-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

open/closed/filtered qiymatlarini paket javoblari bilan bog‘la.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Port inventory + izoh. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Mutaxassis `curl -Iv https://example.com` va `openssl s_client -connect example.com:443` kabi passiv diagnostikadan boshlashi mumkin. Chiqqan chain, SAN, notBefore/notAfter va negotiated protocol qayd etiladi. Bu namuna domen bilan emas, o‘z serveri bilan bosqichma-bosqich amalda to‘liqroq tekshiriladi.

Manba yo‘nalishi: [S16][S17][S03]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Nmap faqat 127.0.0.1 yoki yozma ruxsat berilgan IP doirasida.

05-hafta / Amaliy mashg‘ulot A

2-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: server oldin/keyin port natijalari va `nmap --version` izohi.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 05 | Mavzuga mos amaliyot

```
# Terminal A
python3 -m http.server 8000 --bind 127.0.0.1
# Terminal B
nmap --version
nmap -sT -p 8000 127.0.0.1
nmap -sV -p 8000 127.0.0.1
# Serverni Ctrl+C bilan yoping
```

KUTILGAN NATIJA: --version lokal versiyani ko‘rsatadi; 8000 port server ishlaganda open, yopilgach closed bo‘lishi mumkin.
XAVFSIZLIK: Nmap faqat 127.0.0.1 yoki yozma ruxsat berilgan IP doirasida.

TUSHUNTIRISH: Nmap ochiq yoki filtrlangan port holatini kuzatadi; xizmat mavjudligi uning zaifligini isbotlamaydi. Discovery javobi firewalldan ta’sirlanishi mumkin. --version faqat mahalliy Nmap versiyasini chiqaradi.
EHTIYOT: -sV natijasidagi dastur versiyasi har doim aniq emas; serverdagi konfiguratsiya bilan solishtir.

05-hafta / Amaliy mashg‘ulot B

2-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #5, Host discovery va port status.
Command / tool	Python3 (sintetik sinov)
Expected	
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	-sV natijasidagi dastur versiyasi har doim aniq emas; serverdagi konfiguratsiya bilan solishtir.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: server oldin/keyin port natijalari va `nmap --version` izohi. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Packet capture orqali har bir xulosaga dalil qidir: port openmi — SYN-ACK bormi? Xizmat haqiqatan

Texnik izoh: -sV natijasidagi dastur versiyasi har doim aniq emas; serverdagi konfiguratsiya bilan solishtir. Nmap ochiq yoki filtrlangan port holatini kuzatadi; xizmat mavjudligi uning zaifligini isbotlamaydi. Discovery javobi firewalldan ta’sirlanishi mumkin. --version faqat mahalliy Nmap versiyasini chiqaradi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

05-hafta / Hisobot va challenge

2-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Port inventory + izoh

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Host discovery va port status” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Host discovery va port status. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: server oldin/keyin port natijalari va `nmap --version` izohi.
Xavfsizlik chegarasi: Nmap faqat 127.0.0.1 yoki yozma ruxsat berilgan IP doirasida.

06-hafta / Packet capture va TCP handshake

2-OY • Nmap, Wireshark va paketlar | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Wireshark capture/display filters, TCP SYN/SYN-ACK/ACK, retransmission va reset.

Asosiy tushuncha

Paket yozish va paketni ko‘rsatish filtrlari farqli: capture filter yozib olinadigan trafikni, display filter ko‘rinadigan yozuvlarni belgilaydi. TCP SYN-ACK aloqa boshlanishiga doir dalildir.

Tayanch atamalarni ajratamiz

1. capture filter	tcpdump/libpcap yozib olishdan oldingi filtrlash qoidasi.
2. display filter	Wireshark ichida yozib olingan paketlarning ekran ko‘rinishini cheklaydi.
3. SYN/SYN-ACK/ACK	TCP aloqaning uch bosqichli kelishuv flaglari.
4. retransmission	Paket yo‘qolishi yoki kechikishi sababli qayta uzatilishi; har doim hujum emas.

Keng tarqalgan chalkashlik

Aniqlik: Retransmission sonidan birgina o‘zi hujum haqida xulosa chiqarmang..

Chuqurroq konseptual tahlil

Routing jadvalida “default via” odatda boshqa ko‘proq xos marshrutga mos kelmagan paketlarning next hopini ko‘rsatadi. Masalan, `10.0.2.0/24 dev eth0` lokal kanalga kiradi, `default via 10.0.2.2` esa tashqi manzilga gateway. VirtualBox NAT IP manzilini LAN-dagi fizik Wi-Fi qurilmalar bilan bir xil deb qabul qilish katta diagnostika xatosidir.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

06-hafta / Texnik mexanizm

2-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Paket yozish va paketni ko‘rsatish filtrlari farqli: capture filter yozib olinadigan trafikni, display filter ko‘rinadigan yozuvlarni belgilaydi. TCP SYN-ACK aloqa boshlanishiga doir dalildir.

capture filter	display filter	SYN/SYN-ACK/ACK	retransmission

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
tcpdump -i lo -nn	Loopback paketlarini yozadi/ko‘rsatadi; ko‘rish uchun sudo kerak bo‘lishi mumkin.
curl -v http://127.0.0.1:8000/	Lokal HTTP request/response va connection tafsilotlarini chiqaradi.
tshark -r	Mavjud PCAP faylini diskdan o‘qiydi; kiruvchi fayl kerak.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: SYN-ACK xizmatning transport darajasida tayyorligini, ilovaning xavfsizligini emas, ko‘rsatadi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Retransmission sonidan birgina o‘zi hujum haqida xulosa chiqarmang. Natija: SYN/ACK dalillari va capture qamrovining cheklovi.

06-hafta / Xavf va himoya

2-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Nmap va curl trafiklari orasidagi farqni aniqlab, screenshot + pcap metadata ber.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik kompрometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: TCP handshake laboratoriya hisobot. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Packet capture orqali har bir xulosaga dalil qidir: port openmi — SYN-ACK bormi? Xizmat haqiqatan HTTPmi — Content-Type, status va server protsessi bormi? Kuzatuv lokalmi — `lo`da bo‘lgan voqeani tarmoqdagi boshqa hostga umumlashtirish mumkin emas.

Manba yo‘nalishi: [S16][S17][S03]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Packet capture parol/cookie tutishi mumkin: faqat lo, hech qanday haqiqiy akkaunt ishlatma.

06-hafta / Amaliy mashg‘ulot A

2-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: SYN/ACK dalillari va capture qamrovining cheklovi.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 06 | Mavzuga mos amaliyot

```
# Terminal A
python3 -m http.server 8000 --bind 127.0.0.1
# Terminal B (agar tcpdump va ruxsat bo‘lsa)
sudo tcpdump -i lo -c 12 'tcp port 8000'
# Terminal C
curl -I http://127.0.0.1:8000/
# Barcha jarayonlarni tugating
```

KUTILGAN NATIJA: Loopbackdagi TCP flaglarni ko‘rasiz; trafik faqat o‘z mashinangizda hosil bo‘ladi.
XAVFSIZLIK: Packet capture parol/cookie tutishi mumkin: faqat lo, hech qanday haqiqiy akkaunt ishlatma.

TUSHUNTIRISH: Paket yozish va paketni ko‘rsatish filtrlari farqli: capture filter yozib olinadigan trafikni, display filter ko‘rinadigan yozuvlarni belgilaydi. TCP SYN-ACK aloqa boshlanishiga doir dalildir.
EHTIYOT: Retransmission sonidan birgina o‘zi hujum haqida xulosa chiqarmang.

06-hafta / Amaliy mashg‘ulot B

2-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #6, Packet capture va TCP handshake.
Command / tool	t Python3 (sintetik sinov)
Expected	Loopbackdagi TCP flaglarni ko‘rasiz; trafik faqat o‘z mashinangizda hosil bo‘ladi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Retransmission sonidan birgina o‘zi hujum haqida xulosa chiqarmang.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: SYN/ACK dalillari va capture qamrovining cheklovi. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Internet tarmoqlari host, subnet va router o‘rtasida bo‘linadi. 192.168.10.0/24 prefiksi 256 manzilli blokni

Texnik izoh: Retransmission sonidan birgina o‘zi hujum haqida xulosa chiqarmang. Paket yozish va paketni ko‘rsatish filtrlari farqli: capture filter yozib olinadigan trafikni, display filter ko‘rinadigan yozuvlarni belgilaydi. TCP SYN-ACK aloqa boshlanishiga doir dalildir.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

06-hafta / Hisobot va challenge

2-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

TCP handshake laboratoriya hisobot

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Packet capture va TCP handshake” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Packet capture va TCP handshake. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: SYN/ACK dalillari va capture qamrovining cheklovi.
Xavfsizlik chegarasi: Packet capture parol/cookie tutishi mumkin: faqat lo, hech qanday haqiqiy akkaunt ishlatma.

© 2026 • Xavfsiz, ruxsatli tadqiqot • Nazariya + amaliyot

07-hafta / DNS va HTTP semantikasi

2-OY • Nmap, Wireshark va paketlar | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

DNS A/AAAA/CNAME/TXT, recursive resolver, HTTP method/status/header, TLS va sertifikatlar.

Asosiy tushuncha

DNS nomni yozuvlarga yechadi; HTTP esa mijoz va server so‘rov-javob semantikasini belgilaydi. TLS sertifikatini ko‘rish shifrlashning barcha xavfsizlik xususiyatlarini isbotlamaydi.

Tayanch atamalarni ajratamiz

1. A / AAAA	Domenni IPv4 / IPv6 manziliga bog‘laydi.
2. CNAME / TXT	Alias va ixtiyoriy matnli DNS yozuvlari, masalan SPF siyosati.
3. HTTP status	200 muvaffaqiyat, 301 yo‘naltirish, 404 topilmadi kabi javob toifalari.
4. TLS certificate	Server sertifikati nom, amal muddati va ishonch zanjirini taqdim etadi.

Keng tarqalgan chalkashlik

Aniqlik: DNS javobi yoki sertifikat borligi zaiflik yoki xavfsizlikka to‘liq kafolat em.

Chuqurroq konseptual tahlil

Mutaxassis `curl -Iv https://example.com` va `openssl s_client -connect example.com:443` kabi passiv diagnostikadan boshlashi mumkin. Chiqqan chain, SAN, notBefore/notAfter va negotiated protocol qayd etiladi. Bu namuna domen bilan emas, o‘z serveri bilan bosqichma-bosqich amalda to‘liqroq tekshiriladi.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

07-hafta / Texnik mexanizm

2-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

DNS nomni yozuvlarga yechadi; HTTP esa mijoz va server so‘rov-javob semantikasini belgilaydi. TLS sertifikatini ko‘rish shifrlashning barcha xavfsizlik xususiyatlarini isbotlamaydi.

A / AAAA	CNAME / TXT	HTTP status	TLS certificate

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
dig example.com A	Ommaviy DNSdagi IPv4 A yozuvini so‘raydi; faol DNS so‘rovi.
curl -I https://example.com	HTTPS HEAD so‘rovi bilan status/headerni ko‘rsatadi.
openssl s_client -connect example.com:443	TLS server bilan handshake qilib sertifikat/aloqa tafsilotini chiqaradi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: DNS javobini qabul qilish sertifikat ishonchi bilan teng emas; TLS alohida tekshiriladi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: DNS javobi yoki sertifikat borligi zaiflik yoki xavfsizlikka to‘liq kafolat emas. Natija: DNS/HTTP/TLS kuzatuvlari, versiyalar va vaqt.

07-hafta / Xavf va himoya

2-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

DNS javobi ma’lumot; uni avtomatik “zaiflik” deb baholama.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik kompрometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: DNS/TLS observation. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

USHBU HAFTADAGI XAVF: Jamoat misol domeniga past tezlikdagi oddiy so‘rov; ko‘p marotaba skanerlama.
DALIL MEZONI: DNS/HTTP/TLS kuzatuvlari, versiyalar va vaqt.

Manba yo‘nalishi: [S16][S17][S03]. Barcha manbalar bibliografiyada berilgan.

07-hafta / Amaliy mashg‘ulot A

2-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: DNS/HTTP/TLS kuzatuvlari, versiyalar va vaqt.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 07 | Mavzuga mos amaliyot

```
dig example.com A
curl -I https://example.com
openssl s_client -connect example.com:443 \
  -servername example.com </dev/null 2>/dev/null | \
  openssl x509 -noout -subject -dates
```

KUTILGAN NATIJA: A yozuvi, HTTP statusi, sertifikat nomi va amal muddati alohida qayd etiladi.
XAVFSIZLIK: Jamoat misol domeniga past tezlikdagi oddiy so‘rov; ko‘p marotaba skanerlama.

TUSHUNTIRISH: DNS nomni yozuvlarga yechadi; HTTP esa mijoz va server so‘rov-javob semantikasini belgilaydi. TLS sertifikatini ko‘rish shifrlashning barcha xavfsizlik xususiyatlarini isbotlamaydi.
EHTIYOT: DNS javobi yoki sertifikat borligi zaiflik yoki xavfsizlikka to‘liq kafolat emas.

07-hafta / Amaliy mashg‘ulot B

2-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #7, DNS va HTTP semantikasi.
Command / tool	Linux terminal / ruxsatli lokal sinov
Expected	A yozuvi, HTTP statusi, sertifikat nomi va amal muddati alohida qayd etiladi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	DNS javobi yoki sertifikat borligi zaiflik yoki xavfsizlikka to‘liq kafolat emas.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: DNS/HTTP/TLS kuzatuvlari, versiyalar va vaqt. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: TLS handshake jarayonida mijoz va server protokol versiyasi, cipher suite va kalit almashinuvi

Texnik izoh: DNS javobi yoki sertifikat borligi zaiflik yoki xavfsizlikka to‘liq kafolat emas. DNS nomni yozuvlarga yechadi; HTTP esa mijoz va server so‘rov-javob semantikasini belgilaydi. TLS sertifikatini ko‘rish shifrlashning barcha xavfsizlik xususiyatlarini isbotlamaydi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

07-hafta / Hisobot va challenge

2-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

DNS/TLS observation

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “DNS va HTTP semantikasi” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: DNS va HTTP semantikasi. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: DNS/HTTP/TLS kuzatuvlari, versiyalar va vaqt.
Xavfsizlik chegarasi: Jamoat misol domeniga past tezlikdagi oddiy so‘rov; ko‘p marotaba skanerlama.

08-hafta / Tarmoq baseline va monitoring

2-OY • Nmap, Wireshark va paketlar | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Sog‘lom trafikni bilmasdan hujumni ajratib bo‘lmaydi: baseline, jitter, packet loss, p95 latency.

Asosiy tushuncha

Baseline sog‘lom muhitdagi odatiy xatti-harakatdir. Jitter vaqt kechikishining o‘zgarishi, packet loss yetib bormagan paketlar ulushi. Anomaliya normal o‘zgarish ham bo‘lishi mumkin.

Tayanch atamalarni ajratamiz

1. baseline	Trafik, latency, ulanish va loglarning odatiy me’yoriy profili.
2. jitter	Qo‘shni o‘lchovlar orasidagi kechikishning tebranishi.
3. packet loss	Yuborilgan va javobsiz qolgan paketlar ulushi.
4. p95 latency	Kechikish namunalarining 95-persentili; o‘rtacha qiymatdan farqli.

Keng tarqalgan chalkashlik

Aniqlik: Bitta o‘lchov baseline emas.

Chuqurroq konseptual tahlil

Packet capture orqali har bir xulosaga dalil qidir: port openmi — SYN-ACK bormi? Xizmat haqiqatan HTTPmi — Content-Type, status va server protsessi bormi? Kuzatuv lokalmi — `lo`da bo‘lgan voqeani tarmoqdagi boshqa hostga umumlashtirish mumkin emas.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

08-hafta / Texnik mexanizm

2-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Baseline sog‘lom muhitdagi odatiy xatti-harakatdir. Jitter vaqt kechikishining o‘zgarishi, packet loss yetib bormagan paketlar ulushi. Anomaliya normal o‘zgarish ham bo‘lishi mumkin.

baseline	jitter	packet loss	p95 latency

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
ping -c 3 127.0.0.1	Loopback ICMPga 3 marta ping yuboradi; RTT/loss kuzatuvi.
ss -s	Tizim TCP/UDP socketlarining umumiy statistikasi.
ip -s link	Interfeysda RX/TX va xato hisoblagichlarini ko‘rsatadi.
date -Is	Joriy vaqtni ISO-8601 va zona bilan chiqaradi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Latency va packet lossga lokal VM scheduler ham ta’sir qilishi mumkin. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Bitta o‘lchov baseline emas; kamida bir necha vaqt oralig‘ini solishtir. Natija: o‘lchov vaqti, min/avg/max va 2 davrning taqqoslanishi.

08-hafta / Xavf va himoya

2-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

VM gateway va internet host orasidagi latency farqlarini NAT bilan izohla.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Network baseline scorecard. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

TLS handshake jarayonida mijoz va server protokol versiyasi, cipher suite va kalit almashinuvi parametrlarini kelishadi. Zamonaviy xususiyatlar forward secrecy, sertifikat expiry monitoring, HSTS va server config hardening. “TLS bor” degani mutlaqo xavfsiz API emas: Authorization va business logic xatolari ham qoladi.

Manba yo‘nalishi: [S16][S17][S03]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Tashqi IPga trafik yubormasdan o‘z tizimingizda boshlang.

08-hafta / Amaliy mashg‘ulot A

2-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: o‘lchov vaqti, min/avg/max va 2 davrning taqqoslanishi.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 08 | Mavzuga mos amaliyot

```
date -Is
ping -c 5 127.0.0.1
ss -s
ip -s link show lo
```

KUTILGAN NATIJA: 5 ta loopback ping vaqti, socket statistikasi hamda interfeys hisoblagichlari qayd etiladi.
XAVFSIZLIK: Tashqi IPga trafik yubormasdan o‘z tizimingizda boshlang.

TUSHUNTIRISH: Baseline sog‘lom muhitdagi odatiy xatti-harakatdir. Jitter vaqt kechikishining o‘zgarishi, packet loss yetib bormagan paketlar ulushi. Anomaliya normal o‘zgarish ham bo‘lishi mumkin.
EHTIYOT: Bitta o‘lchov baseline emas; kamida bir necha vaqt oralig‘ini solishtir.

08-hafta / Amaliy mashg‘ulot B

2-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #8, Tarmoq baseline va monitoring.
Command / tool	Linux terminal / ruxsatli lokal sinov
Expected	5 ta loopback ping vaqti, socket statistikasi hamda interfeys hisoblagichlari qayd etiladi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Bitta o‘lchov baseline emas; kamida bir necha vaqt oralig‘ini solishtir.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: o‘lchov vaqti, min/avg/max va 2 davrning taqqoslanishi. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Nmap `-sT` TCP connect scan jarayonida standart OS connect() mexanizmidan foydalanadi. `-sV` esa

Texnik izoh: Bitta o‘lchov baseline emas; kamida bir necha vaqt oralig‘ini solishtir. Baseline sog‘lom muhitdagi odatiy xatti-harakatdir. Jitter vaqt kechikishining o‘zgarishi, packet loss yetib bormagan paketlar ulushi. Anomaliya normal o‘zgarish ham bo‘lishi mumkin.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

08-hafta / Hisobot va challenge

2-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Network baseline scorecard

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Tarmoq baseline va monitoring” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Tarmoq baseline va monitoring. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: o‘lchov vaqti, min/avg/max va 2 davrning taqqoslanishi.
Xavfsizlik chegarasi: Tashqi IPga trafik yubormasdan o‘z tizimingizda boshlang.

09-hafta / Scope va Rules of Engagement

3-OY • Pentest metodologiyasi va OSINT | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Asset owner, written permission, out-of-scope, data minimization, stop conditions, emergency contact.

Asosiy tushuncha

RoE sinovdan oldin ruxsatli aktiv, vaqt, usul, ma’lumotdan foydalanish chegarasi va favqulodda to‘xtash shartini hujjatlashtiradi. Ruxsatsiz skan – etik pentest hisoblanmaydi.

Tayanch atamalarni ajratamiz

1. scope	Ruxsat berilgan IP, domen, xizmat va tekshiruv chegaralari.
2. asset owner	Aktiv ustidan vakolati va tasdiqlash huquqi bo‘lgan tomon.
3. stop condition	Kutilmagan ta’sir, maxfiy ma’lumot yoki xizmat uzilishi paytida testni to‘xtatish sharti.
4. data minimization	Faqat zarur eng kam ma’lumotni yig‘ish tamoyili.

Keng tarqalgan chalkashlik

Aniqlik: Domen nomi kiritilmagan ruxsatni umumiy internetga taalluqli deb tushunma..

Chuqurroq konseptual tahlil

Pentesterlar aniq ruxsatli scope ichida zaiflikni topib riskini isbotlaydi; Red Team muayyan tashkilotning defense samaradorligini realistik ssenariy bilan baholaydi; Blue Team esa monitoring, incident response, recovery va threat huntingni yuritadi. Purple Team ularni umumiy test/detection feedback loopiga bog‘laydi.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

09-hafta / Texnik mexanizm

3-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

RoE sinovdan oldin ruxsatli aktiv, vaqt, usul, ma’lumotdan foydalanish chegarasi va favqulodda to‘xtash shartini hujjatlashtiradi. Ruxsatsiz skan – etik pentest hisoblanmaydi.

scope	asset owner	stop condition	data minimization

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
cat	Fayl matnini stdoutga ko‘rsatadi; maxfiy faylni ko‘rsatishda ehtiyot.
sha256sum	Faylning SHA-256 digestini hisoblaydi; o‘zi xavfsizlikni isbotlamaydi.
date -Is	Joriy vaqtni ISO-8601 va zona bilan chiqaradi.
git status	Lokal Git ishchi katalogi holatini o‘qiydi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: RoE `allowed`, `excluded`, start/end time va contactni aniq belgilaydi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Domen nomi kiritilmagan ruxsatni umumiy internetga taalluqli deb tushunma. Natija: RoE matni, sana va scope ro‘yxati.

09-hafta / Xavf va himoya

3-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Scope ruxsatida IP va domain bo‘lmasa scan qilmaslik qoidasini tatbiq et.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: RoE shabloni. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Sertifikatlar ma’lum yo‘lni tartiblaydi, lekin ish tajribasini to‘liq almashtirmaydi. Network+/Security+ kabi nazariy poydevor, eJPT kabi entry-level amaliyot, keyin OSCP, web security, cloud/DFIR yoki detection engineering ixtisoslashuvi. Har birini moliyaviy qiymat va bo‘sh vaqtga mos o‘rganing.

Manba yo‘nalishi: [S12][S01][S05][S14]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Yozma ruxsat aktiv egasidan olinadi; talabaning o‘z akkaunti uchinchi tomon serverini ruxsatli qilmaydi.

09-hafta / Amaliy mashg‘ulot A

3-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: RoE matni, sana va scope ro‘yxati.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 09 | Mavzuga mos amaliyot

```
mkdir -p ~/ehs/week09
cat > ~/ehs/week09/roe.txt <<'EOF'
Owner: self
Allowed: 127.0.0.1
Forbidden: third-party systems
Stop: unexpected data exposure
Window: local study session
EOF
cat ~/ehs/week09/roe.txt
```

KUTILGAN NATIJA: RoE hujjatida aniq 5 band mavjud; real tashqi tizimlarga buyruq yuborilmaydi.
XAVFSIZLIK: Yozma ruxsat aktiv egasidan olinadi; talabaning o‘z akkaunti uchinchi tomon serverini ruxsatli qilmaydi.

TUSHUNTIRISH: RoE sinovdan oldin ruxsatli aktiv, vaqt, usul, ma’lumotdan foydalanish chegarasi va favqulodda to‘xtash shartini hujjatlashtiradi. Ruxsatsiz skan – etik pentest hisoblanmaydi.
EHTIYOT: Domen nomi kiritilmagan ruxsatni umumiy internetga taalluqli deb tushunma.

09-hafta / Amaliy mashg‘ulot B

3-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #9, Scope va Rules of Engagement.
Command / tool	Linux terminal / ruxsatli lokal sinov
Expected	RoE hujjatida aniq 5 band mavjud; real tashqi tizimlarga buyruq yuborilmaydi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Domen nomi kiritilmagan ruxsatni umumiy internetga taalluqli deb tushunma.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: RoE matni, sana va scope ro‘yxati. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Tarmoq auditida manzilning o‘zi emas, asset owner va ruxsat scope asos. Natijalar jadvalida interface,

Texnik izoh: Domen nomi kiritilmagan ruxsatni umumiy internetga taalluqli deb tushunma. RoE sinovdan oldin ruxsatli aktiv, vaqt, usul, ma’lumotdan foydalanish chegarasi va favqulodda to‘xtash shartini hujjatlashtiradi. Ruxsatsiz skan – etik pentest hisoblanmaydi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

09-hafta / Hisobot va challenge

3-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

RoE shabloni

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Scope va Rules of Engagement” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Scope va Rules of Engagement. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: RoE matni, sana va scope ro‘yxati.
Xavfsizlik chegarasi: Yozma ruxsat aktiv egasidan olinadi; talabaning o‘z akkaunti uchinchi tomon serverini ruxsatli qilmaydi.

10-hafta / Passiv OSINT

3-OY • Pentest metodologiyasi va OSINT | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Rasmiy domaining, metadata, public docs, WHOIS va DNS, sensitive info oversharing.

Asosiy tushuncha

Passiv OSINT ommaga ochiq ma’lumotlarni ruxsat va maxfiylikni hurmat qilgan holda tahlil qiladi. Domenning ochiq DNS yozuvi ixtiyorsiz konfiguratsiya oshkor bo‘lganini albatta anglatmaydi.

Tayanch atamalarni ajratamiz

1. WHOIS/RDAP	Domen ro‘yxatdan o‘tishi haqidagi ommaviy metama’lumotlar.
2. metadata	Fayl/domen/hujjat bilan bog‘liq tavsifiy ma’lumotlar.
3. passive OSINT	Ma’lum manbalarni bevosita ekspluatatsiyasiz o‘rganish.
4. attack surface	Tashqaridan o‘zaro aloqaga ochiq nuqtalar va interfeyslar to‘plami.

Keng tarqalgan chalkashlik

Aniqlik: Nmap port skani passiv OSINT emas.

Chuqurroq konseptual tahlil

Routing jadvalida “default via” odatda boshqa ko‘proq xos marshrutga mos kelmagan paketlarning next hopini ko‘rsatadi. Masalan, `10.0.2.0/24 dev eth0` lokal kanalga kiradi, `default via 10.0.2.2` esa tashqi manzilga gateway. VirtualBox NAT IP manzilini LAN-dagi fizik Wi-Fi qurilmalar bilan bir xil deb qabul qilish katta diagnostika xatosidir.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

10-hafta / Texnik mexanizm

3-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Passiv OSINT ommaga ochiq ma’lumotlarni ruxsat va maxfiylikni hurmat qilgan holda tahlil qiladi. Domenning ochiq DNS yozuvi ixtiyorsiz konfiguratsiya oshkor bo‘lganini albatta anglatmaydi.

WHOIS/RDAP	metadata	passive OSINT	attack surface

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
whois example.com	Ommaviy registratsiya ma’lumotlarini so‘raydi; shaxsiylik cheklovlari bor.
dig example.com TXT	Domen TXT yozuvlarini DNSdan oladi.
curl -I https://example.com	HTTPS HEAD so‘rovi bilan status/headerni ko‘rsatadi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Nmap `-sV` xizmat haqidagi taxmin; banner spoofing ehtimoli mavjud. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Nmap port skani passiv OSINT emas: u aktiv tarmoq so‘rovi hisoblanadi. Natija: 2 ochiq manba, observation va riskga ehtiyotkor baho.

10-hafta / Xavf va himoya

3-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Shaxsiy odam profiliga hujum uchun ma’lumot to‘plashning o‘rniga aktivga bog‘langan riskni bahola.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik kompрometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Passive footprint matritsasi. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Tarmoq auditida manzilning o‘zi emas, asset owner va ruxsat scope asos. Natijalar jadvalida interface, IPv4/IPv6, mask, route, source of evidence, confidence va timestamp bo‘lishi kerak. Screenshot bir lahzalik kuzatuv; DHCP lease yoki VPN ulanishi bilan IP o‘zgarishi mumkin.

Manba yo‘nalishi: [S12][S01][S05][S14]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Haqiqiy shaxslar, email ro‘yxatlari yoki ijtimoiy tarmoq profillarini hujum uchun to‘plama.

10-hafta / Amaliy mashg‘ulot A

3-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: 2 ochiq manba, observation va riskga ehtiyotkor baho.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 10 | Mavzuga mos amaliyot

```
dig example.com A
curl -I https://example.com
# Topilmalarni yozib qo‘ying:
printf 'domain,source,risk\nexample.com,DNS,unknown\n' \
 > ~/ehs/week10.csv
cat ~/ehs/week10.csv
```

KUTILGAN NATIJA: Faqat ommaga ochiq example.com kuzatuvlari va riskni UNKNOWN deb baholash.
XAVFSIZLIK: Haqiqiy shaxslar, email ro‘yxatlari yoki ijtimoiy tarmoq profillarini hujum uchun to‘plama.

TUSHUNTIRISH: Passiv OSINT ommaga ochiq ma’lumotlarni ruxsat va maxfiylikni hurmat qilgan holda tahlil qiladi. Domenning ochiq DNS yozuvi ixtiyorsiz konfiguratsiya oshkor bo‘lganini albatta anglatmaydi.
EHTIYOT: Nmap port skani passiv OSINT emas: u aktiv tarmoq so‘rovi hisoblanadi.

10-hafta / Amaliy mashg‘ulot B

3-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #10, Passiv OSINT.
Command / tool	Linux terminal / ruxsatli lokal sinov
Expected	Faqat ommaga ochiq example.com kuzatuvlari va riskni UNKNOWN deb baholash.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Nmap port skani passiv OSINT emas: u aktiv tarmoq so‘rovi hisoblanadi.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: 2 ochiq manba, observation va riskga ehtiyotkor baho. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Pentesterlar aniq ruxsatli scope ichida zaiflikni topib riskini isbotlaydi; Red Team muayyan tashkilotning

Texnik izoh: Nmap port skani passiv OSINT emas: u aktiv tarmoq so‘rovi hisoblanadi. Passiv OSINT ommaga ochiq ma’lumotlarni ruxsat va maxfiylikni hurmat qilgan holda tahlil qiladi. Domenning ochiq DNS yozuvi ixtiyorsiz konfiguratsiya oshkor bo‘lganini albatta anglatmaydi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

10-hafta / Hisobot va challenge

3-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Passive footprint matritsasi

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Passiv OSINT” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Passiv OSINT. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: 2 ochiq manba, observation va riskga ehtiyotkor baho.
Xavfsizlik chegarasi: Haqiqiy shaxslar, email ro‘yxatlari yoki ijtimoiy tarmoq profillarini hujum uchun to‘plama.

© 2026 • Xavfsiz, ruxsatli tadqiqot • Nazariya + amaliyot

11-hafta / Threat modeling

3-OY • Pentest metodologiyasi va OSINT | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

STRIDE, DFD, trust boundaries, assets, threat actor capabilities va mitigations.

Asosiy tushuncha

Threat modeling aktivlar, ishonch chegaralari, tahdidlar va nazoratlar orasidagi sabab-oqibatni ko‘rsatadi. STRIDE xavf turlarini tartiblaydi; u avtomatik ravishda ekspluatatsiya borligini tasdiqlamaydi.

Tayanch atamalarni ajratamiz

1. DFD	Ma’lumot oqimi diagrammasi: jarayon, saqlash va kirish-chiqish chegaralari.
2. STRIDE	Spoofing, Tampering, Repudiation, Information disclosure, DoS, Elevation.
3. trust boundary	Turli ishonch darajasidagi komponentlar o‘rtasidagi chegara.
4. mitigation	Muayyan tahdid ehtimoli yoki ta’sirini kamaytiradigan nazorat.

Keng tarqalgan chalkashlik

Aniqlik: Tahdid modeli ruxsatli aktivlar ro‘yxati va data flow dan boshlanadi..

Chuqurroq konseptual tahlil

Sertifikatlar ma’lum yo‘lni tartiblaydi, lekin ish tajribasini to‘liq almashtirmaydi. Network+/Security+ kabi nazariy poydevor, eJPT kabi entry-level amaliyot, keyin OSCP, web security, cloud/DFIR yoki detection engineering ixtisoslashuvi. Har birini moliyaviy qiymat va bo‘sh vaqtga mos o‘rganing.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

11-hafta / Texnik mexanizm

3-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Threat modeling aktivlar, ishonch chegaralari, tahdidlar va nazoratlar orasidagi sabab-oqibatni ko‘rsatadi. STRIDE xavf turlarini tartiblaydi; u avtomatik ravishda ekspluatatsiya borligini tasdiqlamaydi.

DFD	STRIDE	trust boundary	mitigation

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
git log --oneline	Git commit tarixini qisqa formatda ko‘rsatadi.
find . -maxdepth 2 -type f	Joriy katalogdan ikki darajagacha oddiy fayllarni topadi.
grep -R	Ko‘rsatilgan papka ichida satr bo‘yicha rekursiv qidiradi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Process va port mapping uchun PID, namespace va privilege nazoratini ham yozing. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Tahdid modeli ruxsatli aktivlar ro‘yxati va data flow dan boshlanadi. Natija: DFD + 3 STRIDE tahdid + nazorat.

11-hafta / Xavf va himoya

3-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

AuthN va AuthZ alohida nazorat; credential token kabi sensitive data saqlash nazorati.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Threat model 1.0. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Pentesterlar aniq ruxsatli scope ichida zaiflikni topib riskini isbotlaydi; Red Team muayyan tashkilotning defense samaradorligini realistik ssenariy bilan baholaydi; Blue Team esa monitoring, incident response, recovery va threat huntingni yuritadi. Purple Team ularni umumiy test/detection feedback loopiga bog‘laydi.

Manba yo‘nalishi: [S12][S01][S05][S14]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Model farazidir; real tizimning zaifligi deb e’lon qilma.

11-hafta / Amaliy mashg‘ulot A

3-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: DFD + 3 STRIDE tahdid + nazorat.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 11 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
assets=['browser','api','database']
flows=[('browser','api'),('api','database')]
for a,b in flows: print(a,'->',b,'boundary: check')
print('controls: auth, validation, least privilege')
PYLAB
```

KUTILGAN NATIJA: Ikki oqim va ularning tekshirilishi kerak bo‘lgan ishonch chegaralari chiqadi.
XAVFSIZLIK: Model farazidir; real tizimning zaifligi deb e’lon qilma.

TUSHUNTIRISH: Threat modeling aktivlar, ishonch chegaralari, tahdidlar va nazoratlar orasidagi sabab-oqibatni ko‘rsatadi. STRIDE xavf turlarini tartiblaydi; u avtomatik ravishda ekspluatatsiya borligini tasdiqlamaydi.
EHTIYOT: Tahdid modeli ruxsatli aktivlar ro‘yxati va data flow dan boshlanadi.

11-hafta / Amaliy mashg‘ulot B

3-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #11, Threat modeling.
Command / tool	Python3 (sintetik sinov)
Expected	Ikki oqim va ularning tekshirilishi kerak bo‘lgan ishonch chegaralari chiqadi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Tahdid modeli ruxsatli aktivlar ro‘yxati va data flow dan boshlanadi.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: DFD + 3 STRIDE tahdid + nazorat. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Routing jadvalida “default via” odatda boshqa ko‘proq xos marshrutga mos kelmagan paketlarning next

Texnik izoh: Tahdid modeli ruxsatli aktivlar ro‘yxati va data flow dan boshlanadi. Threat modeling aktivlar, ishonch chegaralari, tahdidlar va nazoratlar orasidagi sabab-oqibatni ko‘rsatadi. STRIDE xavf turlarini tartiblaydi; u avtomatik ravishda ekspluatatsiya borligini tasdiqlamaydi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

11-hafta / Hisobot va challenge

3-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Threat model 1.0

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Threat modeling” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Threat modeling. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: DFD + 3 STRIDE tahdid + nazorat.
Xavfsizlik chegarasi: Model farazidir; real tizimning zaifligi deb e’lon qilma.

© 2026 • Xavfsiz, ruxsatli tadqiqot • Nazariya + amaliyot

12-hafta / Zaiflikni baholash va reporting

3-OY • Pentest metodologiyasi va OSINT | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

CVE, CWE, CVSS v4, CISA KEV, likelihood-impact, evidence va reproduction xavfsizligi.

Asosiy tushuncha

Zaiflikni baholashda CVE dasturiy kamchilik identifikatori, CWE kamchilik sinfi va CVSS ko‘pincha og‘irlik ko‘rsatkichidir. Biznes riski aktiv konteksti va real ta’sirga ham bog‘liq.

Tayanch atamalarni ajratamiz

1. CVE	Ommaga e’lon qilingan muayyan zaiflik identifikatori.
2. CWE	Dastur/dizayndagi zaiflik sinfi, masalan noto‘g‘ri input validatsiyasi.
3. CVSS	Og‘irlikni metrikalar yordamida ballash tizimi; biznes riski bilan aynan bir xil emas.
4. KEV	CISA faol ekspluatatsiya qilingani ma’lum zaifliklar katalogi.

Keng tarqalgan chalkashlik

Aniqlik: Scanner xulosasi false positive bo‘lishi mumkin..

Chuqurroq konseptual tahlil

Tarmoq auditida manzilning o‘zi emas, asset owner va ruxsat scope asos. Natijalar jadvalida interface, IPv4/IPv6, mask, route, source of evidence, confidence va timestamp bo‘lishi kerak. Screenshot bir lahzalik kuzatuv; DHCP lease yoki VPN ulanishi bilan IP o‘zgarishi mumkin.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

12-hafta / Texnik mexanizm

3-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Zaiflikni baholashda CVE dasturiy kamchilik identifikatori, CWE kamchilik sinfi va CVSS ko‘pincha og‘irlik ko‘rsatkichidir. Biznes riski aktiv konteksti va real ta’sirga ham bog‘liq.

CVE	CWE	CVSS	KEV

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
sha256sum	Faylning SHA-256 digestini hisoblaydi; o‘zi xavfsizlikni isbotlamaydi.
file	Fayl formatini magic/header orqali taxmin qiladi.
nmap -sV -p 8000 127.0.0.1	Lokal 8000 portdagi servisni probe orqali taxmin qiladi; natija ehtimoliy.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sabablardan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: CVE — identifikator; CVSS — og‘irlik; real xavf exploitation, scope va biznes ta’siriga bog‘liq. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Scanner xulosasi false positive bo‘lishi mumkin. Natija: finding, reproduksiya, ta’sir, fix va retest maydonlari.

12-hafta / Xavf va himoya

3-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Scanner topgan versiya exploitationni isbotlamasligini himoya qil.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik kompрometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: 1-sifatli finding + remediatsiya. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Routing jadvalida “default via” odatda boshqa ko‘proq xos marshrutga mos kelmagan paketlarning next hopini ko‘rsatadi. Masalan, `10.0.2.0/24 dev eth0` lokal kanalga kiradi, `default via 10.0.2.2` esa tashqi manzilga gateway. VirtualBox NAT IP manzilini LAN-dagi fizik Wi-Fi qurilmalar bilan bir xil deb qabul qilish katta diagnostika xatosidir.

Manba yo‘nalishi: [S12][S01][S05][S14]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Zaiflikni isbotsiz CVE yoki CVSS bilan baholama; real ekspluatatsiya shart emas.

12-hafta / Amaliy mashg‘ulot A

3-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: finding, reproduksiya, ta’sir, fix va retest maydonlari.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 12 | Mavzuga mos amaliyot

```
mkdir -p ~/ehs/week12
printf 'asset,finding,evidence,status\nlab-app,missing-check,unit-test,open\n' \
 > ~/ehs/week12/findings.csv
cat ~/ehs/week12/findings.csv
```

KUTILGAN NATIJA: Risk registri faqat sintetik aktiv va sinov daliliga ega; CVE to‘qib chiqarilmaydi.
XAVFSIZLIK: Zaiflikni isbotsiz CVE yoki CVSS bilan baholama; real ekspluatatsiya shart emas.

TUSHUNTIRISH: Zaiflikni baholashda CVE dasturiy kamchilik identifikatori, CWE kamchilik sinfi va CVSS ko‘pincha og‘irlik ko‘rsatkichidir. Biznes riski aktiv konteksti va real ta’sirga ham bog‘liq.
EHTIYOT: Scanner xulosasi false positive bo‘lishi mumkin.

12-hafta / Amaliy mashg‘ulot B

3-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #12, Zaiflikni baholash va reporting.
Command / tool	Linux terminal / ruxsatli lokal sinov
Expected	Risk registri faqat sintetik aktiv va sinov daliliga ega; CVE to‘qib chiqarilmaydi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Scanner xulosasi false positive bo‘lishi mumkin.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: finding, reproduksiya, ta’sir, fix va retest maydonlari. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Sertifikatlar ma’lum yo‘lni tartiblaydi, lekin ish tajribasini to‘liq almashtirmaydi. Network+/Security+ kabi

Texnik izoh: Scanner xulosasi false positive bo‘lishi mumkin. Zaiflikni baholashda CVE dasturiy kamchilik identifikatori, CWE kamchilik sinfi va CVSS ko‘pincha og‘irlik ko‘rsatkichidir. Biznes riski aktiv konteksti va real ta’sirga ham bog‘liq.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

12-hafta / Hisobot va challenge

3-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

1-sifatli finding + remediatsiya

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Zaiflikni baholash va reporting” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Zaiflikni baholash va reporting. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: finding, reproduksiya, ta’sir, fix va retest maydonlari.
Xavfsizlik chegarasi: Zaiflikni isbotsiz CVE yoki CVSS bilan baholama; real ekspluatatsiya shart emas.

© 2026 • Xavfsiz, ruxsatli tadqiqot • Nazariya + amaliyot

13-hafta / HTTP request/response va Burp

4-OY • HTTP, autentifikatsiya va web sinovlari | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Method, URI, header, body, status, cookie flags, origin va referer; proxy tushunchasi.

Asosiy tushuncha

HTTP so‘rov method, path, header, body va javob statusini o‘z ichiga oladi. Burp Proxy kabi asboblar ruxsatli test trafikini o‘rganadi; brauzer seansidagi maxfiy ma’lumotni yozib olmaslik kerak.

Tayanch atamalarni ajratamiz

1. method	GET o‘qish, POST yuborish kabi so‘rov maqsadi.
2. header	Request yoki response metama’lumot maydoni.
3. cookie flags	Secure, HttpOnly, SameSite brauzer cookie ishloviga ta’sir qiladi.
4. origin	Sxema + host + port kombinatsiyasi, brauzer xavfsizlik chegarasi.

Keng tarqalgan chalkashlik

Aniqlik: HTTP 200 javobi autentifikatsiya va ruxsat nazorati to‘g‘ri ekanini isbotlamay.

Chuqurroq konseptual tahlil

Login jarayonini state machine sifatida ko‘ring: anonymous → challenge → primary verified → MFA verified → session established → authorized operation → revoke/expire. Har bir o‘tish serverda qat’iy tekshiriladi. Front-end user “MFA passed” degan flag yuborsa, server uni ishonchli haqiqat sifatida qabul qilmasligi kerak.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

13-hafta / Texnik mexanizm

4-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

HTTP so‘rov method, path, header, body va javob statusini o‘z ichiga oladi. Burp Proxy kabi asboblar ruxsatli test trafikini o‘rganadi; brauzer seansidagi maxfiy ma’lumotni yozib olmaslik kerak.

method	header	cookie flags	origin

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
curl -i http://127.0.0.1:8000/	Bu buyruq uchun --help/man sahifasidan variant, kirish va chiqishni tekshiring; faqat ruxsatli muhitda.
curl -I https://example.com	HTTPS HEAD so‘rovi bilan status/headerni ko‘rsatadi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: HTTP request statusi ilovaning foydalanuvchi vakolatlarini tasdiqlamaydi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: HTTP 200 javobi autentifikatsiya va ruxsat nazorati to‘g‘ri ekanini isbotlamaydi. Natija: HTTP request/response juftligi, header tarjimasi.

13-hafta / Xavf va himoya

4-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Secretni proxy tarixida qoldirmaslik uchun faqat test qiymatlaridan foydalan.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Annotated HTTP transcript. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Passkey/WebAuthn modelida server private key’ni olmaydi; authenticator challenge’ni origin’ga bog‘liq holda imzolaydi. Bunday mexanizm fishingga chidamliroq, lekin account recovery, session revocation, mobil device security va social engineering risklari baribir boshqarilishi kerak.

Manba yo‘nalishi: [S04][S05][S11][S18][S35]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Faqat localhost; haqiqiy Authorization header yoki cookie’larni hisobotga ko‘chirma.

13-hafta / Amaliy mashg‘ulot A

4-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: HTTP request/response juftligi, header tarjimasi.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 13 | Mavzuga mos amaliyot

```
# Terminal A
python3 -m http.server 8000 --bind 127.0.0.1
# Terminal B
curl -v -I http://127.0.0.1:8000/ 2>&1 | head -30
# Terminal A: Ctrl+C
```

KUTILGAN NATIJA: HTTP method, request header, response statusi va server sarlavhalari ajratiladi.
XAVFSIZLIK: Faqat localhost; haqiqiy Authorization header yoki cookie’larni hisobotga ko‘chirma.

TUSHUNTIRISH: HTTP so‘rov method, path, header, body va javob statusini o‘z ichiga oladi. Burp Proxy kabi asboblar ruxsatli test trafikini o‘rganadi; brauzer seansidagi maxfiy ma’lumotni yozib olmaslik kerak.
EHTIYOT: HTTP 200 javobi autentifikatsiya va ruxsat nazorati to‘g‘ri ekanini isbotlamaydi.

13-hafta / Amaliy mashg‘ulot B

4-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #13, HTTP request/response va Burp.
Command / tool	Python3 (sintetik sinov)
Expected	HTTP method, request header, response statusi va server sarlavhalari ajratiladi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	HTTP 200 javobi autentifikatsiya va ruxsat nazorati to‘g‘ri ekanini isbotlamaydi.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: HTTP request/response juftligi, header tarjimasi. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Auditda topilgan zaiflik talab etilgan scope’da xavfsiz unit/integration test orqali tekshiriladi. Uchinchi tomon live OAuth sessionlarida token qidirish yoki o‘g‘irlashga urinmaymiz; nazoratli sample auth provider ishlatamiz.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

13-hafta / Hisobot va challenge

4-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Annotated HTTP transcript

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “HTTP request/response va Burp” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: HTTP request/response va Burp. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: HTTP request/response juftligi, header tarjimasi.
Xavfsizlik chegarasi: Faqat localhost; haqiqiy Authorization header yoki cookie’larni hisobotga ko‘chirma.

14-hafta / Parol hashing va MFA

4-OY • HTTP, autentifikatsiya va web sinovlari | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Salt, password stretching, Argon2id, PBKDF2, WebAuthn, recovery, rate limiting.

Asosiy tushuncha

Parollarni oddiy SHA-256 bilan saqlash o‘rniga salt bilan maxsus sekin KDF kerak. MFA parol o‘g‘irlansa ham qo‘shimcha nazorat beradi; recovery mexanizmi ham tahdid modeli tarkibida.

Tayanch atamalarni ajratamiz

1. salt	Har bir parol uchun alohida tasodifiy qo‘shimcha; bir xil parollarni farqlaydi.
2. KDF	Parolni tekshirishga mo‘ljallangan resurs talab qiluvchi hosila funksiya.
3. Argon2id	Parol hashing uchun zamonaviy memory-hard algoritm.
4. WebAuthn	Phishingga chidamli autentifikatsiya uchun public-key asosli mexanizm.

Keng tarqalgan chalkashlik

Aniqlik: Hashing va shifrlash boshqa-boshqa vazifa.

Chuqurroq konseptual tahlil

Security review’da redirect URI exact matching, PKCE, state/nonce, audience, issuer, scope minimization va token storage ko‘riladi. Tokenni JavaScript localStorage’da saqlashning risklari browser XSS threat modeliga bog‘liq; universal bitta javob yo‘q.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

14-hafta / Texnik mexanizm

4-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Parollarni oddiy SHA-256 bilan saqlash o‘rniga salt bilan maxsus sekin KDF kerak. MFA parol o‘g‘irlansa ham qo‘shimcha nazorat beradi; recovery mexanizmi ham tahdid modeli tarkibida.

salt	KDF	Argon2id	WebAuthn

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
python3 --version	Python interpreter versiyasini ko‘rsatadi.
openssl rand -hex 16	Kriptografik random generator bilan 16 bayt hex chiqaradi.
python3 -m venv .venv	Joriy papkada alohida Python muhitini yaratadi; diskka yozadi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sabablardan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Salt sir emas; password hashingda memory-hard KDF maqsadi offline guessing narxini oshirishdir. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Hashing va shifrlash boshqa-boshqa vazifa; salt sir bo‘lishi shart emas. Natija: PBKDF2 natijasi, salt roli va Argon2id bilan farqi.

14-hafta / Xavf va himoya

4-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Hash≠encryption; maxfiy kalit serverga chiqmasligi kerakligini tushuntir.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Authentication hardening checklist. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Auditda topilgan zaiflik talab etilgan scope’da xavfsiz unit/integration test orqali tekshiriladi. Uchinchi tomon live OAuth sessionlarida token qidirish yoki o‘g‘irlashga urinmaymiz; nazoratli sample auth provider ishlatamiz.

Manba yo‘nalishi: [S04][S05][S11][S18][S35]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Real foydalanuvchi parolini, dump yoki credentialni sinovga kiritma.

14-hafta / Amaliy mashg‘ulot A

4-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: PBKDF2 natijasi, salt roli va Argon2id bilan farqi.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 14 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
import os,hashlib
password=b'synthetic-password'
keys=[]
for i in range(2):
 salt=os.urandom(16)
 dk=hashlib.pbkdf2_hmac('sha256',password,salt,200000)
 keys.append(dk)
 print('derived-key prefix:',dk.hex()[:10])
print('different salts, different outputs:',keys[0]!=keys[1])
PYLAB
```

KUTILGAN NATIJA: Ikki turli salt uchun hash ko‘rinishi har xil chiqadi; real parol ishlatilmaydi.
XAVFSIZLIK: Real foydalanuvchi parolini, dump yoki credentialni sinovga kiritma.

TUSHUNTIRISH: Parollarni oddiy SHA-256 bilan saqlash o‘rniga salt bilan maxsus sekin KDF kerak. MFA parol o‘g‘irlansa ham qo‘shimcha nazorat beradi; recovery mexanizmi ham tahdid modeli tarkibida.
EHTIYOT: Hashing va shifrlash boshqa-boshqa vazifa; salt sir bo‘lishi shart emas.

14-hafta / Amaliy mashg‘ulot B

4-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #14, Parol hashing va MFA.
Command / tool	Python3 (sintetik sinov)
Expected	Ikki turli salt uchun hash ko‘rinishi har xil chiqadi; real parol ishlatilmaydi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Hashing va shifrlash boshqa-boshqa vazifa; salt sir bo‘lishi shart emas.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: PBKDF2 natijasi, salt roli va Argon2id bilan farqi. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Login jarayonini state machine sifatida ko‘ring: anonymous → challenge → primary verified → MFA verified

Texnik izoh: Hashing va shifrlash boshqa-boshqa vazifa; salt sir bo‘lishi shart emas. Parollarni oddiy SHA-256 bilan saqlash o‘rniga salt bilan maxsus sekin KDF kerak. MFA parol o‘g‘irlansa ham qo‘shimcha nazorat beradi; recovery mexanizmi ham tahdid modeli tarkibida.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

14-hafta / Hisobot va challenge

4-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Authentication hardening checklist

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Parol hashing va MFA” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Parol hashing va MFA. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: PBKDF2 natijasi, salt roli va Argon2id bilan farqi.
Xavfsizlik chegarasi: Real foydalanuvchi parolini, dump yoki credentialni sinovga kiritma.

© 2026 • Xavfsiz, ruxsatli tadqiqot • Nazariya + amaliyot

15-hafta / Session security, JWT va OAuth

4-OY • HTTP, autentifikatsiya va web sinovlari | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Session ID, rotate/revoke, HttpOnly, Secure, SameSite, JWT claims/signature, OIDC vs OAuth.

Asosiy tushuncha

JWT uch qismdan iborat bo‘lishi mumkin, ammo payloadni oddiy base64url dan ochish tokenni tekshirish bilan bir xil emas. Imzo, issuer, audience, expiry va sessiya bekor qilinishini server baholaydi.

Tayanch atamalarni ajratamiz

1. session ID	Server seansiga bog‘lovchi oldindan taxmin qilib bo‘lmaydigan identifikator.
2. JWT claims	sub, iss, aud, exp kabi bayonlar; imzosiz ko‘rinishiga ishonib bo‘lmaydi.
3. rotation/revoke	Sessiya identifikatorini almashtirish va eski huquqni bekor qilish.
4. SameSite/HttpOnly	Cookie’ning jo‘natish qamrovi va JavaScript orqali o‘qilishini boshqaradi.

Keng tarqalgan chalkashlik

Aniqlik: Dekodlash autentifikatsiya emas.

Chuqurroq konseptual tahlil

Passkey/WebAuthn modelida server private key’ni olmaydi; authenticator challenge’ni origin’ga bog‘liq holda imzolaydi. Bunday mexanizm fishingga chidamliroq, lekin account recovery, session revocation, mobil device security va social engineering risklari baribir boshqarilishi kerak.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

15-hafta / Texnik mexanizm

4-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

JWT uch qismdan iborat bo‘lishi mumkin, ammo payloadni oddiy base64url dan ochish tokenni tekshirish bilan bir xil emas. Imzo, issuer, audience, expiry va sessiya bekor qilinishini server baholaydi.

session ID	JWT claims	rotation/revoke	SameSite/HttpOnly

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
python3 -m json.tool	JSON matnining sintaksisini tekshiradi/formatlaydi.
base64 --decode	Base64ni dekodlaydi, kriptografik imzo yoki autentifikatsiyani tekshirmaydi.
curl -I	URLga HEAD so‘rov yuborib javob headerini ko‘rsatadi; tashqi hostga trafik ketishi mumkin.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: JWT payload kodini o‘qish oson, uni ishonchli deyish uchun signature, issuer va audience tekshiriladi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Dekodlash autentifikatsiya emas; server har bir muhim amalni o‘zi tekshirishi zarur. Natija: claim va imzo validatsiyasi farqini yozma tushuntirish.

15-hafta / Xavf va himoya

4-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

ID token va access token farqi; token theft signallari.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik kompрometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Session lifecycle diagram. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Login jarayonini state machine sifatida ko‘ring: anonymous → challenge → primary verified → MFA verified → session established → authorized operation → revoke/expire. Har bir o‘tish serverda qat’iy tekshiriladi. Front-end user “MFA passed” degan flag yuborsa, server uni ishonchli haqiqat sifatida qabul qilmasligi kerak.

Manba yo‘nalishi: [S04][S05][S11][S18][S35]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Haqiqiy access token yoki refresh tokenni terminal/logga chiqarma.

15-hafta / Amaliy mashg‘ulot A

4-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: claim va imzo validatsiyasi farqini yozma tushuntirish.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 15 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
import base64,json
obj={'sub':'lab','iss':'local','exp':0}
raw=base64.urlsafe_b64encode(json.dumps(obj).encode())
print('payload (NOT verified):',raw.decode())
print(json.loads(base64.urlsafe_b64decode(raw)))
PYLAB
```

KUTILGAN NATIJA: Sintetik claimlarni dekodlash ishlaydi; hech qanday JWT imzosi tekshirilmagan.
XAVFSIZLIK: Haqiqiy access token yoki refresh tokenni terminal/logga chiqarma.

TUSHUNTIRISH: JWT uch qismdan iborat bo‘lishi mumkin, ammo payloadni oddiy base64url dan ochish tokenni tekshirish bilan bir xil emas. Imzo, issuer, audience, expiry va sessiya bekor qilinishini server baholaydi.
EHTIYOT: Dekodlash autentifikatsiya emas; server har bir muhim amalni o‘zi tekshirishi zarur.

15-hafta / Amaliy mashg‘ulot B

4-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #15, Session security, JWT va OAuth.
Command / tool	Python3 (sintetik sinov)
Expected	Sintetik claimlarni dekodlash ishlaydi; hech qanday JWT imzosi tekshirilmagan.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Dekodlash autentifikatsiya emas; server har bir muhim amalni o‘zi tekshirishi zarur.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: claim va imzo validatsiyasi farqini yozma tushuntirish. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Security review’da redirect URI exact matching, PKCE, state/nonce, audience, issuer, scope minimization

Texnik izoh: Dekodlash autentifikatsiya emas; server har bir muhim amalni o‘zi tekshirishi zarur. JWT uch qismdan iborat bo‘lishi mumkin, ammo payloadni oddiy base64url dan ochish tokenni tekshirish bilan bir xil emas. Imzo, issuer, audience, expiry va sessiya bekor qilinishini server baholaydi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

15-hafta / Hisobot va challenge

4-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Session lifecycle diagram

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Session security, JWT va OAuth” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Session security, JWT va OAuth. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: claim va imzo validatsiyasi farqini yozma tushuntirish.
Xavfsizlik chegarasi: Haqiqiy access token yoki refresh tokenni terminal/logga chiqarma.

16-hafta / Access control va IDOR

4-OY • HTTP, autentifikatsiya va web sinovlari | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Broken object-level authorization, server-side check, tenant isolation, horizontal/vertical access.

Asosiy tushuncha

IDOR/BOLA foydalanuvchi o‘ziga tegishli bo‘lmagan obyektga noto‘g‘ri ruxsat olganda yuz beradi. Ruxsat tekshiruvi faqat UI’da emas, har bir server so‘rovida ham bajariladi.

Tayanch atamalarni ajratamiz

1. IDOR	Object identifikatorini almashtirish orqali ruxsatsiz obyektga kirish zaifligi.
2. BOLA	API darajasida object-level authorization buzilishi.
3. RBAC	Ruxsatlarni role orqali nazorat qilish.
4. tenant isolation	Bir tashkilot ma’lumoti boshqasidan qat’iy ajratilishi.

Keng tarqalgan chalkashlik

Aniqlik: UI tugmasini yashirish server avtorizatsiyasi emas..

Chuqurroq konseptual tahlil

Auditda topilgan zaiflik talab etilgan scope’da xavfsiz unit/integration test orqali tekshiriladi. Uchinchi tomon live OAuth sessionlarida token qidirish yoki o‘g‘irlashga urinmaymiz; nazoratli sample auth provider ishlatamiz.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

16-hafta / Texnik mexanizm

4-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

IDOR/BOLA foydalanuvchi o‘ziga tegishli bo‘lmagan obyektga noto‘g‘ri ruxsat olganda yuz beradi. Ruxsat tekshiruvi faqat UI’da emas, har bir server so‘rovida ham bajariladi.

IDOR	BOLA	RBAC	tenant isolation

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
grep -R	Ko‘rsatilgan papka ichida satr bo‘yicha rekursiv qidiradi.
pytest -q	Lokal testlarni ishga tushiradi; test kodini avval tekshir.
git diff	Commit qilinmagan o‘zgarishlarni ko‘rsatadi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Tenant ID frontenddan kelgan bo‘lsa, server o‘zining vakolatli kontekstida verify qilishi kerak. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: UI tugmasini yashirish server avtorizatsiyasi emas. Natija: ijobiy va salbiy authorization unit-test.

16-hafta / Xavf va himoya

4-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Login qilingan foydalanuvchi ham begona obyektga kirishi mumkinligini isbotla.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: AuthZ unit tests. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Security review’da redirect URI exact matching, PKCE, state/nonce, audience, issuer, scope minimization va token storage ko‘riladi. Tokenni JavaScript localStorage’da saqlashning risklari browser XSS threat modeliga bog‘liq; universal bitta javob yo‘q.

Manba yo‘nalishi: [S04][S05][S11][S18][S35]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Test uchun sintetik obyektlar; haqiqiy akkaunt IDlarini almashtirib sinama.

16-hafta / Amaliy mashg‘ulot A

4-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: ijobiy va salbiy authorization unit-test.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 16 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
def allowed(actor,resource):
 return actor['tenant']==resource['tenant'] and actor['role'] in {'admin','owner'}
a={'tenant':'A','role':'admin'}
assert allowed(a,{'tenant':'A'})
assert not allowed(a,{'tenant':'B'})
print('cross-tenant denied: PASS')
PYLAB
```

KUTILGAN NATIJA: Bitta tenantdagi admin PASS, boshqa tenantdagi obyekt DENIED.
XAVFSIZLIK: Test uchun sintetik obyektlar; haqiqiy akkaunt IDlarini almashtirib sinama.

TUSHUNTIRISH: IDOR/BOLA foydalanuvchi o‘ziga tegishli bo‘lmagan obyektga noto‘g‘ri ruxsat olganda yuz beradi. Ruxsat tekshiruvi faqat UI’da emas, har bir server so‘rovida ham bajariladi.
EHTIYOT: UI tugmasini yashirish server avtorizatsiyasi emas.

16-hafta / Amaliy mashg‘ulot B

4-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #16, Access control va IDOR.
Command / tool	Python3 (sintetik sinov)
Expected	Bitta tenantdagi admin PASS, boshqa tenantdagi obyekt DENIED.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	UI tugmasini yashirish server avtorizatsiyasi emas.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: ijobiy va salbiy authorization unit-test. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Passkey/WebAuthn modelida server private key’ni olmaydi; authenticator challenge’ni origin’ga bog‘liq

Texnik izoh: UI tugmasini yashirish server avtorizatsiyasi emas. IDOR/BOLA foydalanuvchi o‘ziga tegishli bo‘lmagan obyektga noto‘g‘ri ruxsat olganda yuz beradi. Ruxsat tekshiruvi faqat UI’da emas, har bir server so‘rovida ham bajariladi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

16-hafta / Hisobot va challenge

4-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

AuthZ unit tests

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Access control va IDOR” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Access control va IDOR. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: ijobiy va salbiy authorization unit-test.
Xavfsizlik chegarasi: Test uchun sintetik obyektlar; haqiqiy akkaunt IDlarini almashtirib sinama.

17-hafta / SQLi va parametrli query

5-OY • Secure coding, API va web tahdidlar | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

SQL parser va data/code chegarasi, prepared statement, schema constraints va privilege.

Asosiy tushuncha

SQL injection ilova matnni SQL kodi bilan aralashtirib yuborganida paydo bo‘ladi. Prepared statement foydalanuvchi qiymatini so‘rov kodidan ajratadi, ammo noto‘g‘ri dinamik jadval nomlarini avtomatik himoya qilmaydi.

Tayanch atamalarni ajratamiz

1. SQLi	Ma’lumot qiymati SQL sintaksisi sifatida talqin etiladigan zaiflik.
2. prepared statement	SQL struktura va parametr qiymatlarini ajratib bajarish.
3. schema constraint	Ma’lumotning mumkin bo‘lgan shakli va bog‘lanishini DB darajasida cheklash.
4. least privilege	Ilova DB foydalanuvchisiga faqat zarur amallarni berish.

Keng tarqalgan chalkashlik

Aniqlik: Parametrli query dinamik column/table nomlarini avtomatik xavfsiz qilmaydi..

Chuqurroq konseptual tahlil

OWASP Top 10:2025 Broken Access Control, Security Misconfiguration, Software Supply Chain Failures, Cryptographic Failures, Injection, Insecure Design, Authentication Failures, Software or Data Integrity Failures, Security Logging & Alerting Failures va Mishandling of Exceptional Conditions kategoriyalaridan iborat. Bu to‘liq vulnerability katalogi emas, balki xavf haqidagi awareness hujjati.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

17-hafta / Texnik mexanizm

5-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

SQL injection ilova matnni SQL kodi bilan aralashtirib yuborganida paydo bo‘ladi. Prepared statement foydalanuvchi qiymatini so‘rov kodidan ajratadi, ammo noto‘g‘ri dinamik jadval nomlarini avtomatik himoya qilmaydi.

SQLi	prepared statement	schema constraint	least privilege

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
sqlite3 --version	Lokal SQLite versiyasi; SQL ishlatmaydi.
python3 -m sqlite3 --help	Python sqlite3 CLI moduli yordamini ko‘rsatadi (versiyaga bog‘liq).
pytest -q	Lokal testlarni ishga tushiradi; test kodini avval tekshir.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Parameterized query SQL parserning kod/ma’lumot chegarasini mustahkamlaydi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Parametrli query dinamik column/table nomlarini avtomatik xavfsiz qilmaydi. Natija: prepared query va input data/code chegarasi.

17-hafta / Xavf va himoya

5-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Production SQL loglarida kutilmagan query shape signalini izohla.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Secure database access demo. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Professional test dasturi kategoriyalarni jadvalga tashlaydi: asset, control, test evidence, expected result, result, finding, priority, owner, due date, retest. Eng avval ishlab turgan nazoratni tekshirish, keyin benign negative test va authorized lab challenge ishlatish kerak.

Manba yo‘nalishi: [S04][S05][S18][S35]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Ma’lumotlar faqat in-memory SQLite’da; ishlab turgan DBga tegilmaydi.

17-hafta / Amaliy mashg‘ulot A

5-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: prepared query va input data/code chegarasi.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 17 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
import sqlite3
c=sqlite3.connect(':memory:')
c.execute('create table users(name text)')
c.execute('insert into users values (?)',('Ali',))
assert c.execute('select name from users where name=?',('Ali',)).fetchone()==('Ali',)
print('parameterized query: PASS')
PYLAB
```

KUTILGAN NATIJA: SQL parametr orqali beriladi; ishlayotgan so‘rov xavfsiz qiymat bog‘lashini namoyish qiladi.
XAVFSIZLIK: Ma’lumotlar faqat in-memory SQLite’da; ishlab turgan DBga tegilmaydi.

TUSHUNTIRISH: SQL injection ilova matnni SQL kodi bilan aralashtirib yuborganida paydo bo‘ladi. Prepared statement foydalanuvchi qiymatini so‘rov kodidan ajratadi, ammo noto‘g‘ri dinamik jadval nomlarini avtomatik himoya qilmaydi.
EHTIYOT: Parametrli query dinamik column/table nomlarini avtomatik xavfsiz qilmaydi.

17-hafta / Amaliy mashg‘ulot B

5-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #17, SQLi va parametrli query.
Command / tool	Python3 (sintetik sinov)
Expected	
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Parametrli query dinamik column/table nomlarini avtomatik xavfsiz qilmaydi.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: prepared query va input data/code chegarasi. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: OWASP Juice Shop kabi ataylab zaif ilova laboratoriyasida riskni ko‘rish mumkin. Production tizimda

Texnik izoh: Parametrli query dinamik column/table nomlarini avtomatik xavfsiz qilmaydi. SQL injection ilova matnni SQL kodi bilan aralashtirib yuborganida paydo bo‘ladi. Prepared statement foydalanuvchi qiymatini so‘rov kodidan ajratadi, ammo noto‘g‘ri dinamik jadval nomlarini avtomatik himoya qilmaydi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

17-hafta / Hisobot va challenge

5-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Secure database access demo

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “SQLi va parametrli query” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: SQLi va parametrli query. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: prepared query va input data/code chegarasi.
Xavfsizlik chegarasi: Ma’lumotlar faqat in-memory SQLite’da; ishlab turgan DBga tegilmaydi.

18-hafta / XSS va browser trust

5-OY • Secure coding, API va web tahdidlar | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

HTML context, DOM, CSP, output encoding, unsafe innerHTML va cookie xavfi.

Asosiy tushuncha

XSS ma’lumot brauzerda HTML/JavaScript sifatida noto‘g‘ri talqin qilinganda yuz beradi. Himoya ko‘rsatiladigan kontekstga mos escaping va DOM xavfsiz API bilan boshlanadi.

Tayanch atamalarni ajratamiz

1. HTML escaping	<, >, &, qo‘shtirnoq kabi belgilarni HTML matni uchun kodlash.
2. DOM sink	Matnni HTML/JSga kiritadigan innerHTML singari joy.
3. CSP	Brauzerga ruxsatli skript manbalarini cheklovchi siyosat.
4. output context	HTML matni, atribut, URL va JS kontekstlari turlicha kodlash talab qiladi.

Keng tarqalgan chalkashlik

Aniqlik: html.escape JS, CSS va URL kontekstlarini universal himoyalamaydi..

Chuqurroq konseptual tahlil

SQLite, PostgreSQL va boshqa RDBMS turli driver va parametr usullariga ega. ORM ishlatilsa ham raw SQL yoki dinamik table/column nomlari bilan risk qaytishi mumkin. Parameter binding to‘g‘ri bo‘lishi bilan birga, DB credential least privilege, schema constraints va read-only service role ham zarur.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

18-hafta / Texnik mexanizm

5-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

XSS ma’lumot brauzerda HTML/JavaScript sifatida noto‘g‘ri talqin qilinganda yuz beradi. Himoya ko‘rsatiladigan kontekstga mos escaping va DOM xavfsiz API bilan boshlanadi.

HTML escaping	DOM sink	CSP	output context

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
curl -I	URLga HEAD so‘rov yuborib javob headerini ko‘rsatadi; tashqi hostga trafik ketishi mumkin.
grep -R "innerHTML" .	Koddagi innerHTML qo‘llanishlarini izlaydi; topilma XSS isboti emas.
npm audit --omit=dev	Dependency audit uchun registrga so‘rov yuboradi; audit natijasi dalil talab qiladi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: HTML escape har bir kontekst uchun umumiy emas; HTML atributi, URL va JS kontekstlari farq qiladi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: html.escape JS, CSS va URL kontekstlarini universal himoyalamaydi. Natija: raw va escaped matn farqi, kontekst jadvali.

18-hafta / Xavf va himoya

5-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Trusted Types/CSP nima uchun qo‘shimcha qatlamligini tushuntir.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Frontend secure-coding memo. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

OWASP Juice Shop kabi ataylab zaif ilova laboratoriyasida riskni ko‘rish mumkin. Production tizimda “payload” ishlatib ko‘rish uchun alohida yozma ruxsat, rate limit, emergency stop, foydalanuvchi ma’lumoti chegarasi va rollback bo‘lishi kerak.

Manba yo‘nalishi: [S04][S05][S18][S35]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Real saytga script yuborish emas, faqat offline matn kodlash sinovi.

18-hafta / Amaliy mashg‘ulot A

5-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: raw va escaped matn farqi, kontekst jadvali.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 18 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
import html
user_text='<b>Lab</b> & test'
print('raw:',user_text)
print('escaped:',html.escape(user_text,quote=True))
assert '&lt;b&gt;' in html.escape(user_text)
PYLAB
```

KUTILGAN NATIJA: HTML uchun kodlangan matn tag sifatida ishlamaydi.
XAVFSIZLIK: Real saytga script yuborish emas, faqat offline matn kodlash sinovi.

TUSHUNTIRISH: XSS ma’lumot brauzerda HTML/JavaScript sifatida noto‘g‘ri talqin qilinganda yuz beradi. Himoya ko‘rsatiladigan kontekstga mos escaping va DOM xavfsiz API bilan boshlanadi.
EHTIYOT: html.escape JS, CSS va URL kontekstlarini universal himoyalamaydi.

18-hafta / Amaliy mashg‘ulot B

5-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #18, XSS va browser trust.
Command / tool	Python3 (sintetik sinov)
Expected	HTML uchun kodlangan matn tag sifatida ishlamaydi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	html.escape JS, CSS va URL kontekstlarini universal himoyalamaydi.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: raw va escaped matn farqi, kontekst jadvali. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: OWASP Top 10:2025 Broken Access Control, Security Misconfiguration, Software Supply Chain Failures,

Texnik izoh: html.escape JS, CSS va URL kontekstlarini universal himoyalamaydi. XSS ma’lumot brauzerda HTML/JavaScript sifatida noto‘g‘ri talqin qilinganda yuz beradi. Himoya ko‘rsatiladigan kontekstga mos escaping va DOM xavfsiz API bilan boshlanadi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

18-hafta / Hisobot va challenge

5-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Frontend secure-coding memo

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “XSS va browser trust” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: XSS va browser trust. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: raw va escaped matn farqi, kontekst jadvali.
Xavfsizlik chegarasi: Real saytga script yuborish emas, faqat offline matn kodlash sinovi.

19-hafta / API security

5-OY • Secure coding, API va web tahdidlar | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

REST, JSON schema, BOLA, RBAC/ABAC, idempotency, pagination, rate limiting, audit.

Asosiy tushuncha

REST API resurs va HTTP usul orqali murojaatni tashkil qiladi. Har bir obyekt so‘rovida authorization, input schema va rate limit serverda bajarilishi zarur; cookie sozlamasi butun API himoyasi emas.

Tayanch atamalarni ajratamiz

1. REST	Resursga URI va HTTP metodlari orqali murojaat arxitekturasi.
2. JSON Schema	Kirish ma’lumoti turi, majburiy maydon va formatini belgilaydi.
3. BOLA	API obyektiga boshqa foydalanuvchining ruxsatsiz kirishi.
4. rate limiting	So‘rov tezligini cheklash; autentifikatsiya o‘rnini bosmaydi.

Keng tarqalgan chalkashlik

Aniqlik: Rate limiting bo‘lsa ham noto‘g‘ri avtorizatsiya hal bo‘lmaydi..

Chuqurroq konseptual tahlil

Professional test dasturi kategoriyalarni jadvalga tashlaydi: asset, control, test evidence, expected result, result, finding, priority, owner, due date, retest. Eng avval ishlab turgan nazoratni tekshirish, keyin benign negative test va authorized lab challenge ishlatish kerak.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

19-hafta / Texnik mexanizm

5-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

REST API resurs va HTTP usul orqali murojaatni tashkil qiladi. Har bir obyekt so‘rovida authorization, input schema va rate limit serverda bajarilishi zarur; cookie sozlamasi butun API himoyasi emas.

REST	JSON Schema	BOLA	rate limiting

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
python3 -m json.tool	JSON matnining sintaksisini tekshiradi/formatlaydi.
curl -i 127.0.0.1:8000	Lokal serverga HTTP so‘rov yuborib response header+body chiqaradi.
jq .	JSONni formatlaydi yoki jq ifodasi bilan filtrlaydi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: SameSite CSRF xavfini kamaytiradi, ammo to‘liq authorizationni almashtirmaydi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Rate limiting bo‘lsa ham noto‘g‘ri avtorizatsiya hal bo‘lmaydi. Natija: schema/authorization xatolari bo‘yicha 3 unit-test.

19-hafta / Xavf va himoya

5-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Client-side “admin” tugmasini yashirish AuthZ o‘rnini bosmasligini yoz.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: API test matrix. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

USHBU HAFTADAGI XAVF: Test offline; ishlab turgan APIga flood yoki kirish sinovi yuborilmaydi.
DALIL MEZONI: schema/authorization xatolari bo‘yicha 3 unit-test.

Manba yo‘nalishi: [S04][S05][S18][S35]. Barcha manbalar bibliografiyada berilgan.

19-hafta / Amaliy mashg‘ulot A

5-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: schema/authorization xatolari bo‘yicha 3 unit-test.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 19 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
def validate(req):
 return isinstance(req.get('id'),int) and req.get('tenant')=='T1'
assert validate({'id':7,'tenant':'T1'})
assert not validate({'id':7,'tenant':'T2'})
assert not validate({'id':'7','tenant':'T1'})
print('schema + tenant checks: PASS')
PYLAB
```

KUTILGAN NATIJA: Tur va tenant bo‘yicha 1 ijobiy, 2 salbiy test ishlaydi.
XAVFSIZLIK: Test offline; ishlab turgan APIga flood yoki kirish sinovi yuborilmaydi.

TUSHUNTIRISH: REST API resurs va HTTP usul orqali murojaatni tashkil qiladi. Har bir obyekt so‘rovida authorization, input schema va rate limit serverda bajarilishi zarur; cookie sozlamasi butun API himoyasi emas.
EHTIYOT: Rate limiting bo‘lsa ham noto‘g‘ri avtorizatsiya hal bo‘lmaydi.

19-hafta / Amaliy mashg‘ulot B

5-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #19, API security.
Command / tool	Python3 (sintetik sinov)
Expected	Tur va tenant bo‘yicha 1 ijobiy, 2 salbiy test ishlaydi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Rate limiting bo‘lsa ham noto‘g‘ri avtorizatsiya hal bo‘lmaydi.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: schema/authorization xatolari bo‘yicha 3 unit-test. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: SQLite, PostgreSQL va boshqa RDBMS turli driver va parametr usullariga ega. ORM ishlatilsa ham raw SQL

Texnik izoh: Rate limiting bo‘lsa ham noto‘g‘ri avtorizatsiya hal bo‘lmaydi. REST API resurs va HTTP usul orqali murojaatni tashkil qiladi. Har bir obyekt so‘rovida authorization, input schema va rate limit serverda bajarilishi zarur; cookie sozlamasi butun API himoyasi emas.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

19-hafta / Hisobot va challenge

5-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

API test matrix

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “API security” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: API security. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: schema/authorization xatolari bo‘yicha 3 unit-test.
Xavfsizlik chegarasi: Test offline; ishlab turgan APIga flood yoki kirish sinovi yuborilmaydi.

20-hafta / Supply chain va secrets

5-OY • Secure coding, API va web tahdidlar | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

SBOM, dependency pinning, signed builds, secret scanning, CI/CD risk va policy checks.

Asosiy tushuncha

Supply-chain xavfi dependency yoki build jarayoni orqali kelishi mumkin. Version pinning, SBOM, signed artifact va maxfiy kalitlarni serverda saqlash mustaqil himoya qatlamlaridir.

Tayanch atamalarni ajratamiz

1. SBOM	Loyihadagi paketlar va versiyalarining dasturiy materiallar ro‘yxati.
2. pinning	Dependency versiyasini nazoratli aniq versiyaga biriktirish.
3. secret scanning	Token/parol tasodifan kiritilganini aniqlash tekshiruvi.
4. signed build	Artefakt kimdan kelganini va yaxlitligini tasdiqlovchi imzo.

Keng tarqalgan chalkashlik

Aniqlik: Yashirilgan qiymat har doim xavfsiz saqlangan degani emas.

Chuqurroq konseptual tahlil

OWASP Juice Shop kabi ataylab zaif ilova laboratoriyasida riskni ko‘rish mumkin. Production tizimda “payload” ishlatib ko‘rish uchun alohida yozma ruxsat, rate limit, emergency stop, foydalanuvchi ma’lumoti chegarasi va rollback bo‘lishi kerak.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

20-hafta / Texnik mexanizm

5-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Supply-chain xavfi dependency yoki build jarayoni orqali kelishi mumkin. Version pinning, SBOM, signed artifact va maxfiy kalitlarni serverda saqlash mustaqil himoya qatlamlaridir.

SBOM	pinning	secret scanning	signed build

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
git status	Lokal Git ishchi katalogi holatini o‘qiydi.
git log -5	Oxirgi besh commitni ko‘rsatadi.
pip list --format=freeze	Lokal Python paketlari va versiyalar ro‘yxati.
sha256sum	Faylning SHA-256 digestini hisoblaydi; o‘zi xavfsizlikni isbotlamaydi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sabablardan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Rate-limit faqat IP bo‘yicha bo‘lsa NAT userlarini noto‘g‘ri bloklashi mumkin. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Yashirilgan qiymat har doim xavfsiz saqlangan degani emas; server scoping muhim. Natija: secret/public matritsa va dependency inventari.

20-hafta / Xavf va himoya

5-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Dependency vulnerability bilan exploitable risk farqi.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik kompрometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: SBOM + supply-chain findings. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

SQLite, PostgreSQL va boshqa RDBMS turli driver va parametr usullariga ega. ORM ishlatilsa ham raw SQL yoki dinamik table/column nomlari bilan risk qaytishi mumkin. Parameter binding to‘g‘ri bo‘lishi bilan birga, DB credential least privilege, schema constraints va read-only service role ham zarur.

Manba yo‘nalishi: [S04][S05][S18][S35]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Secretni konsolga chiqarish yoki repoga commit qilishdan saqlan.

20-hafta / Amaliy mashg‘ulot A

5-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: secret/public matritsa va dependency inventari.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 20 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
config={'PUBLIC_API_URL':'https://example.com','PRIVATE_TOKEN':'PLACEHOLDER'}
assert 'TOKEN' not in config['PUBLIC_API_URL']
for key in config:
 print(key,'=>', 'sensitive' if 'TOKEN' in key else 'public')
PYLAB
```

KUTILGAN NATIJA: Public URL bilan token kaliti farqlanadi; haqiqiy token yo‘q.
XAVFSIZLIK: Secretni konsolga chiqarish yoki repoga commit qilishdan saqlan.

TUSHUNTIRISH: Supply-chain xavfi dependency yoki build jarayoni orqali kelishi mumkin. Version pinning, SBOM, signed artifact va maxfiy kalitlarni serverda saqlash mustaqil himoya qatlamlaridir.
EHTIYOT: Yashirilgan qiymat har doim xavfsiz saqlangan degani emas; server scoping muhim.

20-hafta / Amaliy mashg‘ulot B

5-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #20, Supply chain va secrets.
Command / tool	Python3 (sintetik sinov)
Expected	Public URL bilan token kaliti farqlanadi; haqiqiy token yo‘q.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Yashirilgan qiymat har doim xavfsiz saqlangan degani emas; server scoping muhim.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: secret/public matritsa va dependency inventari. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Professional test dasturi kategoriyalarni jadvalga tashlaydi: asset, control, test evidence, expected result,

Texnik izoh: Yashirilgan qiymat har doim xavfsiz saqlangan degani emas; server scoping muhim. Supply-chain xavfi dependency yoki build jarayoni orqali kelishi mumkin. Version pinning, SBOM, signed artifact va maxfiy kalitlarni serverda saqlash mustaqil himoya qatlamlaridir.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

20-hafta / Hisobot va challenge

5-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

SBOM + supply-chain findings

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Supply chain va secrets” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Supply chain va secrets. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: secret/public matritsa va dependency inventari.
Xavfsizlik chegarasi: Secretni konsolga chiqarish yoki repoga commit qilishdan saqlan.

21-hafta / Windows arxitekturasi

6-OY • Windows, Active Directory va identifikatsiya | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

NTFS ACL, Registry, services, process identity, event log va UAC konseptlari.

Asosiy tushuncha

Windows Security loglari autentifikatsiya holatini, servislar esa operatsion tizim jarayonlarini ko‘rsatadi. UAC va administrator roli bir xil emas; logdagi bitta event komprometatsiyani isbotlamaydi.

Tayanch atamalarni ajratamiz

1. NTFS ACL	Fayl/katalogga kim qaysi huquqda kirishini ko‘rsatuvchi Windows ro‘yxati.
2. Registry	Windows konfiguratsiyasining iyerarxik saqlash joyi.
3. Event 4624/4625	Muvaffaqiyatli va muvaffaqiyatsiz kirish bilan bog‘liq Security eventlar.
4. UAC	Ma’muriy jarayon uchun interaktiv huquq ko‘tarish nazorati.

Keng tarqalgan chalkashlik

Aniqlik: 4625 har doim hujum emas.

Chuqurroq konseptual tahlil

Windowsda logon event 4624 muvaffaqiyatli authentication, 4625 muvaffaqiyatsiz urinish haqida ma’lumot beradi. Ammo turli logon type, workstation, source address va logon ID sababli bitta qatorni to‘g‘ri kontekstga qo‘yish zarur. Domain controller va endpoint loglarining roli farq qiladi.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

21-hafta / Texnik mexanizm

6-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Windows Security loglari autentifikatsiya holatini, servislar esa operatsion tizim jarayonlarini ko‘rsatadi. UAC va administrator roli bir xil emas; logdagi bitta event komprometatsiyani isbotlamaydi.

NTFS ACL	Registry	Event 4624/4625	UAC

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
whoami /all	Windows user SID, guruhlar va huquqlarni ko‘rsatadi.
Get-Process	Windows ishlayotgan jarayonlarini sanaydi.
Get-Service	Windows servislarining joriy statusini ko‘rsatadi.
Get-ComputerInfo	Windows OS va apparat haqida metadata yig‘adi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: EventID 4624/4625 muvaffaqiyatli/nomuvaffaqiyatli login hodisalari; logon type ham muhim. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: 4625 har doim hujum emas: foydalanuvchi xatosi ham bo‘lishi mumkin. Natija: event-ID izohi, natija soni va muqobil sabab.

21-hafta / Xavf va himoya

6-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Service va process o‘rtasidagi farqni tushuntir.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik kompрometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Windows inventory. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

AD’da privilege graph ko‘p qirralik: user→group→resource→policy. Nested groups, delegation, service accounts va “break glass” kirish yo‘llari nazorat qilinishi kerak. Lokal administrators guruhiga a’zolik Windows forest administrator huquqiga teng emas.

Manba yo‘nalishi: [S01][S07][S11]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Maxfiy log, SID va user nomlarini tashqi xizmatga yuborma.

21-hafta / Amaliy mashg‘ulot A

6-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: event-ID izohi, natija soni va muqobil sabab.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 21 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
events=[4625,4625,4624]
print('successful:',events.count(4624))
print('failed:',events.count(4625))
assert events.count(4625)==2
PYLAB
```

KUTILGAN NATIJA: Sintetik Windows eventlari sanaladi; haqiqiy Security log o‘zgartirilmaydi.
XAVFSIZLIK: Maxfiy log, SID va user nomlarini tashqi xizmatga yuborma.

TUSHUNTIRISH: Windows Security loglari autentifikatsiya holatini, servislar esa operatsion tizim jarayonlarini ko‘rsatadi. UAC va administrator roli bir xil emas; logdagi bitta event komprometatsiyani isbotlamaydi.
EHTIYOT: 4625 har doim hujum emas: foydalanuvchi xatosi ham bo‘lishi mumkin.

21-hafta / Amaliy mashg‘ulot B

6-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #21, Windows arxitekturasi.
Command / tool	Python3 (sintetik sinov)
Expected	Sintetik Windows eventlari sanaladi; haqiqiy Security log o‘zgartirilmaydi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	4625 har doim hujum emas: foydalanuvchi xatosi ham bo‘lishi mumkin.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: event-ID izohi, natija soni va muqobil sabab. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Productionda `sudo`, `chmod`, `chown`, `systemctl restart` kabi buyruqlarni avtomatik qo‘llashdan oldin

Texnik izoh: 4625 har doim hujum emas: foydalanuvchi xatosi ham bo‘lishi mumkin. Windows Security loglari autentifikatsiya holatini, servislar esa operatsion tizim jarayonlarini ko‘rsatadi. UAC va administrator roli bir xil emas; logdagi bitta event kompрometatsiyani isbotlamaydi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

21-hafta / Hisobot va challenge

6-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Windows inventory

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Windows arxitekturasi” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Windows arxitekturasi. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: event-ID izohi, natija soni va muqobil sabab.
Xavfsizlik chegarasi: Maxfiy log, SID va user nomlarini tashqi xizmatga yuborma.

22-hafta / AD/LDAP va Kerberos

6-OY • Windows, Active Directory va identifikatsiya | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Domain, DC, object, SID, SPN, ticket, delegation, group nesting, GPO.

Asosiy tushuncha

Active Directory foydalanuvchi, guruh va kompyuter obyektlari orqali markaziy identifikatsiyani boshqaradi. Kerberos ticketga ishonch muddati, xizmat nomi va delegatsiya siyosati ta’sir qiladi.

Tayanch atamalarni ajratamiz

1. Domain Controller	AD domenidagi identifikatsiya xizmati serveri.
2. SID	Windows principaliga tegishli xavfsizlik identifikatori.
3. SPN	Kerberos servis identifikatori; xato sozlash auth muammosi keltiradi.
4. GPO	Domen obyektlariga qo‘llanadigan Group Policy konfiguratsiyasi.

Keng tarqalgan chalkashlik

Aniqlik: AD group nesting kutilmagan meros huquqlarini berishi mumkin..

Chuqurroq konseptual tahlil

SUID/SGID va Linux capabilities ayrim utilitalarga cheklangan yuqori vakolatlarni beradi. Bu normal tizim dizaynida kerakli mexanizm bo‘lishi mumkin. `getcap` chiqishi mavjud privilege modelini tasvirlaydi; xatolik deb belgilash uchun nega berilgani va uni ishlatadigan servis ehtiyoji tekshiriladi.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

22-hafta / Texnik mexanizm

6-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Active Directory foydalanuvchi, guruh va kompyuter obyektlari orqali markaziy identifikatsiyani boshqaradi. Kerberos ticketga ishonch muddati, xizmat nomi va delegatsiya siyosati ta’sir qiladi.

Domain Controller	SID	SPN	GPO

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
Get-LocalUser	Lokal Windows akkauntlarini ko‘rsatadi; kompyuterga bog‘liq.
Get-LocalGroup	Lokal Windows guruhlari ro‘yxatini ko‘rsatadi.
Get-LocalGroupMember Administrators	Mahalliy Administrators guruhi a’zolarini o‘qiydi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Default deny RBAC/ABAC uchun xavfsiz baza, ammo keraksiz break-glass access ham xavf. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: AD group nesting kutilmagan meros huquqlarini berishi mumkin. Natija: SID/SPN/GPO lug‘ati va RBAC matritsasi.

22-hafta / Xavf va himoya

6-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Har bitta privilege delegatsiyasi auditga mos bo‘lishi kerak.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik kompрometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Privilege graph. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Productionda `sudo`, `chmod`, `chown`, `systemctl restart` kabi buyruqlarni avtomatik qo‘llashdan oldin snapshot/backup, change window va rollback tayyorlash kerak. Darsda read-only kuzatuv va o‘z sample fayli bilan permission sinovlari orasidagi farq doim ajratiladi.

Manba yo‘nalishi: [S01][S07][S11]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Haqiqiy domen bilan ulanmaydi; faqat sintetik role siyosati.

22-hafta / Amaliy mashg‘ulot A

6-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: SID/SPN/GPO lug‘ati va RBAC matritsasi.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 22 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
roles={'student':{'read'},'admin':{'read','approve'}}
for role in roles:
 print(role,sorted(roles[role]))
assert 'approve' not in roles['student']
PYLAB
```

KUTILGAN NATIJA: Role matritsasida student approve huquqisiz qoladi.
XAVFSIZLIK: Haqiqiy domen bilan ulanmaydi; faqat sintetik role siyosati.

TUSHUNTIRISH: Active Directory foydalanuvchi, guruh va kompyuter obyektlari orqali markaziy identifikatsiyani boshqaradi. Kerberos ticketga ishonch muddati, xizmat nomi va delegatsiya siyosati ta’sir qiladi.
EHTIYOT: AD group nesting kutilmagan meros huquqlarini berishi mumkin.

22-hafta / Amaliy mashg‘ulot B

6-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #22, AD/LDAP va Kerberos.
Command / tool	Python3 (sintetik sinov)
Expected	Role matritsasida student approve huquqisiz qoladi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	AD group nesting kutilmagan meros huquqlarini berishi mumkin.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: SID/SPN/GPO lug‘ati va RBAC matritsasi. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Windowsda logon event 4624 muvaffaqiyatli authentication, 4625 muvaffaqiyatsiz urinish haqida

Texnik izoh: AD group nesting kutilmagan meros huquqlarini berishi mumkin. Active Directory foydalanuvchi, guruh va kompyuter obyektlari orqali markaziy identifikatsiyani boshqaradi. Kerberos ticketga ishonch muddati, xizmat nomi va delegatsiya siyosati ta’sir qiladi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

22-hafta / Hisobot va challenge

6-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Privilege graph

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “AD/LDAP va Kerberos” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: AD/LDAP va Kerberos. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: SID/SPN/GPO lug‘ati va RBAC matritsasi.
Xavfsizlik chegarasi: Haqiqiy domen bilan ulanmaydi; faqat sintetik role siyosati.

23-hafta / Windows telemetriya

6-OY • Windows, Active Directory va identifikatsiya | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Security Event 4624/4625, Sysmon 1/3/11, PowerShell transcript va audit policy.

Asosiy tushuncha

Windows telemetriyasi Security, Sysmon va PowerShell jurnalida turlicha qamrov beradi. Event ID dalilning faqat turi; process context va vaqt korrelyatsiyasi kerak.

Tayanch atamalarni ajratamiz

1. Security 4624/4625	Kirish urinishlari natijasiga oid Windows xavfsizlik hodisalari.
2. Sysmon Event 1	Sozlangan bo‘lsa yangi jarayonning yaratilishi haqida telemetriya.
3. Sysmon Event 3	Sozlangan bo‘lsa jarayon tarmoq ulanishi haqida telemetriya.
4. transcript	PowerShell seansi konsol faoliyatining qo‘shimcha yozuvi.

Keng tarqalgan chalkashlik

Aniqlik: Sysmon faqat o‘rnatilgan va sozlangan hodisalarni beradi..

Chuqurroq konseptual tahlil

AD’da privilege graph ko‘p qirralik: user→group→resource→policy. Nested groups, delegation, service accounts va “break glass” kirish yo‘llari nazorat qilinishi kerak. Lokal administrators guruhiga a’zolik Windows forest administrator huquqiga teng emas.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

23-hafta / Texnik mexanizm

6-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Windows telemetriyasi Security, Sysmon va PowerShell jurnalida turlicha qamrov beradi. Event ID dalilning faqat turi; process context va vaqt korrelyatsiyasi kerak.

Security 4624/4625	Sysmon Event 1	Sysmon Event 3	transcript

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
Get-WinEvent -ListLog Security	Windows Security event log mavjudligi va xususiyatlarini ko‘rsatadi.
Get-WinEvent -MaxEvents 5 -LogName System	Ko‘rsatilgan Windows jurnaldan oxirgi 5 yozuvni o‘qiydi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Kerberos ticket amal muddati, renewal va delegation yuzasini izohlang. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Sysmon faqat o‘rnatilgan va sozlangan hodisalarni beradi. Natija: event manbasi, timestamp va qamrov jadvali.

23-hafta / Xavf va himoya

6-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Successful login ≠ authorized action.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Detection event map. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Windowsda logon event 4624 muvaffaqiyatli authentication, 4625 muvaffaqiyatsiz urinish haqida ma’lumot beradi. Ammo turli logon type, workstation, source address va logon ID sababli bitta qatorni to‘g‘ri kontekstga qo‘yish zarur. Domain controller va endpoint loglarining roli farq qiladi.

Manba yo‘nalishi: [S01][S07][S11]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Real foydalanuvchi login ma’lumotlarini hisobotga kiritma.

23-hafta / Amaliy mashg‘ulot A

6-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: event manbasi, timestamp va qamrov jadvali.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 23 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
log=[{'id':4625,'host':'LAB1'},{'id':4624,'host':'LAB1'},
     {'id':1,'process':'notepad.exe'}]
for e in log: print(e)
assert len([x for x in log if x['id']==4625])==1
PYLAB
```

KUTILGAN NATIJA: 3 sintetik event izohlanadi; bitta xato login indikator sifatida saqlanadi.
XAVFSIZLIK: Real foydalanuvchi login ma’lumotlarini hisobotga kiritma.

TUSHUNTIRISH: Windows telemetriyasi Security, Sysmon va PowerShell jurnalida turlicha qamrov beradi. Event ID dalilning faqat turi; process context va vaqt korrelyatsiyasi kerak.
EHTIYOT: Sysmon faqat o‘rnatilgan va sozlangan hodisalarni beradi.

23-hafta / Amaliy mashg‘ulot B

6-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #23, Windows telemetriya.
Command / tool	Python3 (sintetik sinov)
Expected	3 sintetik event izohlanadi; bitta xato login indikator sifatida saqlanadi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Sysmon faqat o‘rnatilgan va sozlangan hodisalarni beradi.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: event manbasi, timestamp va qamrov jadvali. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: SUID/SGID va Linux capabilities ayrim utilitalarga cheklangan yuqori vakolatlarni beradi. Bu normal tizim

Texnik izoh: Sysmon faqat o‘rnatilgan va sozlangan hodisalarni beradi. Windows telemetriyasi Security, Sysmon va PowerShell jurnalida turlicha qamrov beradi. Event ID dalilning faqat turi; process context va vaqt korrelyatsiyasi kerak.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

23-hafta / Hisobot va challenge

6-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Detection event map

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Windows telemetriya” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Windows telemetriya. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: event manbasi, timestamp va qamrov jadvali.
Xavfsizlik chegarasi: Real foydalanuvchi login ma’lumotlarini hisobotga kiritma.

24-hafta / AD risk assessment

6-OY • Windows, Active Directory va identifikatsiya | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Delegation, stale accounts, local admin sprawl, service account passwords, managed identities.

Asosiy tushuncha

Active Directory xavf bahosida eskirgan akkauntlar, ortiqcha local admin huquqi, servis akkauntlari va delegatsiya ko‘riladi. Topilma haqiqiy obyekt dalilisiz confirmed bo‘lmaydi.

Tayanch atamalarni ajratamiz

1. stale account	Uzoq vaqt ishlatilmagan, ammo faol qolgan hisob.
2. admin sprawl	Ortiqcha ko‘p foydalanuvchida ma’muriy huquqlar bo‘lishi.
3. delegation	Xizmat yoki identity nomidan so‘rov qilish huquqini topshirish.
4. least privilege	Hisobga faqat ishini bajarish uchun kerakli huquqni berish.

Keng tarqalgan chalkashlik

Aniqlik: 90 kunlik threshold doimo tashkilot siyosatiga mos bo‘lishi kerak..

Chuqurroq konseptual tahlil

Productionda `sudo`, `chmod`, `chown`, `systemctl restart` kabi buyruqlarni avtomatik qo‘llashdan oldin snapshot/backup, change window va rollback tayyorlash kerak. Darsda read-only kuzatuv va o‘z sample fayli bilan permission sinovlari orasidagi farq doim ajratiladi.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

24-hafta / Texnik mexanizm

6-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Active Directory xavf bahosida eskirgan akkauntlar, ortiqcha local admin huquqi, servis akkauntlari va delegatsiya ko‘riladi. Topilma haqiqiy obyekt dalilisiz confirmed bo‘lmaydi.

stale account	admin sprawl	delegation	least privilege

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
Get-LocalGroupMember Administrators	Mahalliy Administrators guruhi a’zolarini o‘qiydi.
icacls .	Joriy katalog Windows ACL ruxsatlarini ko‘rsatadi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Administrator loginini ochiq qoldirish laboratoriyadan tashqari tavsiya emas. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: 90 kunlik threshold doimo tashkilot siyosatiga mos bo‘lishi kerak. Natija: risk registri + tavsiya + qo‘shimcha verifikatsiya.

24-hafta / Xavf va himoya

6-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Productionda o‘zgartirishdan oldin change control zarur.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Identity risk assessment. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

SUID/SGID va Linux capabilities ayrim utilitalarga cheklangan yuqori vakolatlarni beradi. Bu normal tizim dizaynida kerakli mexanizm bo‘lishi mumkin. `getcap` chiqishi mavjud privilege modelini tasvirlaydi; xatolik deb belgilash uchun nega berilgani va uni ishlatadigan servis ehtiyoji tekshiriladi.

Manba yo‘nalishi: [S01][S07][S11]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Haqiqiy AD group/member obyektlariga yozish amali yo‘q.

24-hafta / Amaliy mashg‘ulot A

6-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: risk registri + tavsiya + qo‘shimcha verifikatsiya.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 24 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
accounts=[{'name':'labA','days':5,'admin':False},
          {'name':'labB','days':200,'admin':True}]
for a in accounts:
 if a['days']>90 and a['admin']:
  print('review needed:',a['name'])
PYLAB
```

KUTILGAN NATIJA: Faqat labB review uchun belgilanadi; akkaunt o‘chirilmaydi.
XAVFSIZLIK: Haqiqiy AD group/member obyektlariga yozish amali yo‘q.

TUSHUNTIRISH: Active Directory xavf bahosida eskirgan akkauntlar, ortiqcha local admin huquqi, servis akkauntlari va delegatsiya ko‘riladi. Topilma haqiqiy obyekt dalilisiz confirmed bo‘lmaydi.
EHTIYOT: 90 kunlik threshold doimo tashkilot siyosatiga mos bo‘lishi kerak.

24-hafta / Amaliy mashg‘ulot B

6-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #24, AD risk assessment.
Command / tool	Python3 (sintetik sinov)
Expected	Faqat labB review uchun belgilanadi; akkaunt o‘chirilmaydi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	90 kunlik threshold doimo tashkilot siyosatiga mos bo‘lishi kerak.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: risk registri + tavsiya + qo‘shimcha verifikatsiya. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: AD’da privilege graph ko‘p qirralik: user→group→resource→policy. Nested groups, delegation, service

Texnik izoh: 90 kunlik threshold doimo tashkilot siyosatiga mos bo‘lishi kerak. Active Directory xavf bahosida eskirgan akkauntlar, ortiqcha local admin huquqi, servis akkauntlari va delegatsiya ko‘riladi. Topilma haqiqiy obyekt dalilisiz confirmed bo‘lmaydi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

24-hafta / Hisobot va challenge

6-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Identity risk assessment

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “AD risk assessment” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: AD risk assessment. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: risk registri + tavsiya + qo‘shimcha verifikatsiya.
Xavfsizlik chegarasi: Haqiqiy AD group/member obyektlariga yozish amali yo‘q.

25-hafta / Linux privilege boundaries

7-OY • Linux hardening, konteyner va cloud | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

UID/GID, sudoers, capabilities, SUID/SGID, systemd service isolation, AppArmor.

Asosiy tushuncha

Linux privilege boundary UID/GID, file capability, sudoers va systemd isolationga bog‘liq. SUID bitni ko‘rish hujumga isbot emas; servis huquqlarini minimal tutish kerak.

Tayanch atamalarni ajratamiz

1. UID/GID	Jarayon va fayl egasi/guruhi identifikatorlari.
2. SUID/SGID	Bajariladigan fayl vaqtinchalik egasi/guruh huquqida ishlashi mumkin.
3. capabilities	Rootning ayrim imtiyozlarini kichik qismlarga ajratadi.
4. sudoers	Qaysi foydalanuvchi qanday ma’muriy buyruq bajarishini belgilaydi.

Keng tarqalgan chalkashlik

Aniqlik: Ruxsatning faqat POSIX bitlari ACL va capability haqida hammasini aytmaydi..

Chuqurroq konseptual tahlil

Wi-Fi xavfsizligi birgina paroldan iborat emas. WPA2-Personal odatda oldindan kelishilgan passphrase va 4-way handshake asosida ulanishni himoyalaydi; WPA3-Personal esa SAE kabi yaxshiroq autentifikatsiya usullarini qo‘llaydi. WPA2-Enterprise 802.1X/EAP va RADIUS orqali foydalanuvchi identifikatsiyasini ajratadi.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

25-hafta / Texnik mexanizm

7-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Linux privilege boundary UID/GID, file capability, sudoers va systemd isolationga bog‘liq. SUID bitni ko‘rish hujumga isbot emas; servis huquqlarini minimal tutish kerak.

UID/GID	SUID/SGID	capabilities	sudoers

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
id	UID, GID va guruhlar ro‘yxatini chiqaradi; privilege kontekstini tekshirish uchun.
getcap -r /usr/bin 2>/dev/null	usr/bin ichidagi fayl capabilities ro‘yxati; joriy tizimda ruxsat talab qilishi mumkin.
systemctl --type=service --state=running	systemd xizmatlarining running status ro‘yxati.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: SSIDni yashirish o‘zi kriptografik himoya emas; WPA3 yoki mustahkam WPA2 sozlamasi zarur. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Ruxsatning faqat POSIX bitlari ACL va capability haqida hammasini aytmaydi. Natija: privilege boundary sxemasi va mavjud ruxsat kuzatuvi.

25-hafta / Xavf va himoya

7-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Least-privilege bilan root-permission farqini misollarda tasdiqla.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Linux host hardening baseline. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Kali Linux VirtualBox NAT adapteri odatda fizik 802.11 radio interfeys emas. `eth0` orqali standart Wi-Fi RF management frame’larni ko‘rishni kutish xato. O‘z routerini qonuniy tekshirishda avval router admin panelidan encryption, WPS, firmware va guest policy ma’lumotlarini hujjatlashtiring.

Manba yo‘nalishi: [S07][S10][S15]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: SUID/capability o‘zgartirma, sudoersni tahrir qilma.

25-hafta / Amaliy mashg‘ulot A

7-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: privilege boundary sxemasi va mavjud ruxsat kuzatuvi.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 25 | Mavzuga mos amaliyot

```
id
umask
stat -c '%a %U %G %n' "$HOME"
# Agar mavjud bo‘lsa: getcap /usr/bin/ping
```

KUTILGAN NATIJA: UID/GID, umask, home katalog ruxsatlari va (ixtiyoriy) capability ko‘riladi.
XAVFSIZLIK: SUID/capability o‘zgartirma, sudoersni tahrir qilma.

TUSHUNTIRISH: Linux privilege boundary UID/GID, file capability, sudoers va systemd isolationga bog‘liq. SUID bitni ko‘rish hujumga isbot emas; servis huquqlarini minimal tutish kerak.
EHTIYOT: Ruxsatning faqat POSIX bitlari ACL va capability haqida hammasini aytmaydi.

25-hafta / Amaliy mashg‘ulot B

7-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #25, Linux privilege boundaries.
Command / tool	i Linux terminal / ruxsatli lokal sinov
Expected	UID/GID, umask, home katalog ruxsatlari va (ixtiyoriy) capability ko‘riladi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Ruxsatning faqat POSIX bitlari ACL va capability haqida hammasini aytmaydi.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: privilege boundary sxemasi va mavjud ruxsat kuzatuvi. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: IaC (Terraform/CloudFormation) ichida public ingress, public storage, embedded secret va deprecated

Texnik izoh: Ruxsatning faqat POSIX bitlari ACL va capability haqida hammasini aytmaydi. Linux privilege boundary UID/GID, file capability, sudoers va systemd isolationga bog‘liq. SUID bitni ko‘rish hujumga isbot emas; servis huquqlarini minimal tutish kerak.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

25-hafta / Hisobot va challenge

7-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Linux host hardening baseline

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Linux privilege boundaries” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Linux privilege boundaries. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: privilege boundary sxemasi va mavjud ruxsat kuzatuvi.
Xavfsizlik chegarasi: SUID/capability o‘zgartirma, sudoersni tahrir qilma.

© 2026 • Xavfsiz, ruxsatli tadqiqot • Nazariya + amaliyot

26-hafta / Container security

7-OY • Linux hardening, konteyner va cloud | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Images/layers, namespaces, cgroups, bind mounts, published ports, container-to-host boundary.

Asosiy tushuncha

Container kernelni host bilan bo‘lishadi; image layer va runtime konfiguratsiyasi alohida xavflarga ega. Published port, bind mount va root user hujum yuzasini oshirishi mumkin.

Tayanch atamalarni ajratamiz

1. image/layer	Container fayl tizimi qatlamlari va qayta ishlab chiqariluvchi artefakt.
2. namespace	Jarayon, tarmoq yoki mount kabi resurs ko‘rinishini ajratish.
3. cgroups	CPU/xotira kabi resurs sarfini boshqarish mexanizmi.
4. published port	Container xizmatining host interfeysiga chiqarilishi.

Keng tarqalgan chalkashlik

Aniqlik: Container VM kabi alohida kernelga ega emas..

Chuqurroq konseptual tahlil

Docker container host kernel bilan umumiy qatlamga ega bo‘lishi mumkin. `--privileged`, host PID/net namespaces, Docker socket mount yoki host filesystem bind mount kabi konfiguratsiyalar isolation riskini oshiradi. Bularni productionda ekspluatatsiya qilish o‘rniga o‘z lab image’ining configini `docker inspect` orqali audit qiling.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

26-hafta / Texnik mexanizm

7-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Container kernelni host bilan bo‘lishadi; image layer va runtime konfiguratsiyasi alohida xavflarga ega. Published port, bind mount va root user hujum yuzasini oshirishi mumkin.

image/layer	namespace	cgroups	published port

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
docker ps	Ishlayotgan containerlar ro‘yxatini o‘qiydi; Docker access talab qiladi.
docker image ls	Hostdagi mavjud container image ro‘yxatini o‘qiydi.
docker inspect <own-container>	Faqat O‘Z containeringiz konfiguratsiyasini chiqaradi; bu shablondir.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Wireshark filtrlarida capture filter va display filter sintaksislari farq qiladi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Container VM kabi alohida kernelga ega emas. Natija: container risk matrix: user, mounts, ports, capabilities.

26-hafta / Xavf va himoya

7-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

--privileged va host mount nima uchun katta riskligini tushuntir.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Container threat model. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

IaC (Terraform/CloudFormation) ichida public ingress, public storage, embedded secret va deprecated TLS configlarni CI’da tekshirish mumkin. CI alert “medium” bo‘lishi bilan avtomatik block qilinmaydi; kontekst, rollback va exception workflow bo‘lishi kerak.

Manba yo‘nalishi: [S07][S10][S15]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Docker socketni, /var/run/docker.sock ni noma’lum containerga mount qilmang.

26-hafta / Amaliy mashg‘ulot A

7-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: container risk matrix: user, mounts, ports, capabilities.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 26 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
config={'user':'1000','ports':['127.0.0.1:8080:80'],
        'privileged':False,'mounts':['readonly']}
assert not config['privileged']
assert all(p.startswith('127.0.0.1:') for p in config['ports'])
print('offline container policy: PASS')
PYLAB
```

KUTILGAN NATIJA: Synthetic container config: no privileged mode, faqat loopback port.
XAVFSIZLIK: Docker socketni, /var/run/docker.sock ni noma’lum containerga mount qilmang.

TUSHUNTIRISH: Container kernelni host bilan bo‘lishadi; image layer va runtime konfiguratsiyasi alohida xavflarga ega. Published port, bind mount va root user hujum yuzasini oshirishi mumkin.
EHTIYOT: Container VM kabi alohida kernelga ega emas.

26-hafta / Amaliy mashg‘ulot B

7-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #26, Container security.
Command / tool	Python3 (sintetik sinov)
Expected	Synthetic container config: no privileged mode, faqat loopback port.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Container VM kabi alohida kernelga ega emas.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: container risk matrix: user, mounts, ports, capabilities. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Wi-Fi xavfsizligi birgina paroldan iborat emas. WPA2-Personal odatda oldindan kelishilgan passphrase va

Texnik izoh: Container VM kabi alohida kernelga ega emas. Container kernelni host bilan bo‘lishadi; image layer va runtime konfiguratsiyasi alohida xavflarga ega. Published port, bind mount va root user hujum yuzasini oshirishi mumkin.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

26-hafta / Hisobot va challenge

7-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Container threat model

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Container security” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Container security. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: container risk matrix: user, mounts, ports, capabilities.
Xavfsizlik chegarasi: Docker socketni, /var/run/docker.sock ni noma’lum containerga mount qilmang.

27-hafta / Cloud IAM

7-OY • Linux hardening, konteyner va cloud | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Principal, resource, policy, conditional access, short-lived credentials, public storage.

Asosiy tushuncha

Cloud IAM principal, resource, action va condition kesimida baholanadi. Qisqa muddatli hisob ma’lumotlari va scoped policies doimiy kalitlardan yaxshiroq boshqariladi.

Tayanch atamalarni ajratamiz

1. principal	Ruxsat so‘raydigan user, service account yoki workload identity.
2. resource	Kirish so‘ralayotgan cloud obyekt yoki xizmat.
3. IAM policy	Action va resursga shartli allow/deny qarori.
4. short-lived creds	Muddat bilan cheklangan credential; sizib chiqish oynasini kichraytiradi.

Keng tarqalgan chalkashlik

Aniqlik: 'Administrator' yorlig‘i berilgan xizmatga cheklovsiz huquq bermaslik kerak..

Chuqurroq konseptual tahlil

Kali Linux VirtualBox NAT adapteri odatda fizik 802.11 radio interfeys emas. `eth0` orqali standart Wi-Fi RF management frame’larni ko‘rishni kutish xato. O‘z routerini qonuniy tekshirishda avval router admin panelidan encryption, WPS, firmware va guest policy ma’lumotlarini hujjatlashtiring.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

27-hafta / Texnik mexanizm

7-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Cloud IAM principal, resource, action va condition kesimida baholanadi. Qisqa muddatli hisob ma’lumotlari va scoped policies doimiy kalitlardan yaxshiroq boshqariladi.

principal	resource	IAM policy	short-lived creds

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
python3 -m json.tool	JSON matnining sintaksisini tekshiradi/formatlaydi.
jq .	JSONni formatlaydi yoki jq ifodasi bilan filtrlaydi.
sha256sum	Faylning SHA-256 digestini hisoblaydi; o‘zi xavfsizlikni isbotlamaydi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: IAM JSONdagi action resource contextdan mustaqil baholanmaydi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: 'Administrator' yorlig‘i berilgan xizmatga cheklovsiz huquq bermaslik kerak. Natija: permission matrix, allow/deny sababi va least privilege.

27-hafta / Xavf va himoya

7-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

CloudTrail/Cloud audit events uchun signal katalogini yarat.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Cloud IAM policy review. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Wi-Fi xavfsizligi birgina paroldan iborat emas. WPA2-Personal odatda oldindan kelishilgan passphrase va 4-way handshake asosida ulanishni himoyalaydi; WPA3-Personal esa SAE kabi yaxshiroq autentifikatsiya usullarini qo‘llaydi. WPA2-Enterprise 802.1X/EAP va RADIUS orqali foydalanuvchi identifikatsiyasini ajratadi.

Manba yo‘nalishi: [S07][S10][S15]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Hech bir real cloud hisob sozlamasi o‘zgarmaydi.

27-hafta / Amaliy mashg‘ulot A

7-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: permission matrix, allow/deny sababi va least privilege.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 27 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
policy={'actions':['storage:ReadObject'],'resources':['lab-bucket/*']}
assert 'storage:DeleteObject' not in policy['actions']
print('read-only scoped policy:',policy)
PYLAB
```

KUTILGAN NATIJA: Policy faqat lab bucket uchun o‘qish huquqiga ega.
XAVFSIZLIK: Hech bir real cloud hisob sozlamasi o‘zgarmaydi.

TUSHUNTIRISH: Cloud IAM principal, resource, action va condition kesimida baholanadi. Qisqa muddatli hisob ma’lumotlari va scoped policies doimiy kalitlardan yaxshiroq boshqariladi.
EHTIYOT: 'Administrator' yorlig‘i berilgan xizmatga cheklovsiz huquq bermaslik kerak.

27-hafta / Amaliy mashg‘ulot B

7-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #27, Cloud IAM.
Command / tool	Python3 (sintetik sinov)
Expected	Policy faqat lab bucket uchun o‘qish huquqiga ega.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	'Administrator' yorlig‘i berilgan xizmatga cheklovsiz huquq bermaslik kerak.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: permission matrix, allow/deny sababi va least privilege. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Docker container host kernel bilan umumiy qatlamga ega bo‘lishi mumkin. `--privileged`, host PID/net

Texnik izoh: 'Administrator' yorlig‘i berilgan xizmatga cheklovsiz huquq bermaslik kerak. Cloud IAM principal, resource, action va condition kesimida baholanadi. Qisqa muddatli hisob ma’lumotlari va scoped policies doimiy kalitlardan yaxshiroq boshqariladi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

27-hafta / Hisobot va challenge

7-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Cloud IAM policy review

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Cloud IAM” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Cloud IAM. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: permission matrix, allow/deny sababi va least privilege.
Xavfsizlik chegarasi: Hech bir real cloud hisob sozlamasi o‘zgarmaydi.

28-hafta / Zero Trust va secret management

7-OY • Linux hardening, konteyner va cloud | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Trust no implicit network, verified identity/device, mTLS, service-to-service secrets, rotation.

Asosiy tushuncha

Zero Trust tarmoq joylashuviga avtomatik ishonmaydi: identity, qurilma, kontekst va resurs doim tekshiriladi. Secret management kalitni saqlash, aylantirish, bekor qilish va kirishni auditlashni qamraydi.

Tayanch atamalarni ajratamiz

1. Zero Trust	Ichki tarmoqda bo‘lishning o‘zi ruxsat emas.
2. mTLS	Mijoz va server o‘zaro sertifikat bilan autentifikatsiyalanadi.
3. secret rotation	Maxfiy kalitni rejali ravishda yangisi bilan almashtirish.
4. policy decision	Identity, resurs va kontekstga qarab ruxsat qarori.

Keng tarqalgan chalkashlik

Aniqlik: VPN ichida bo‘lish Zero Trust tekshiruvidan ozod etmaydi..

Chuqurroq konseptual tahlil

IaC (Terraform/CloudFormation) ichida public ingress, public storage, embedded secret va deprecated TLS configlarni CI’da tekshirish mumkin. CI alert “medium” bo‘lishi bilan avtomatik block qilinmaydi; kontekst, rollback va exception workflow bo‘lishi kerak.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

28-hafta / Texnik mexanizm

7-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Zero Trust tarmoq joylashuviga avtomatik ishonmaydi: identity, qurilma, kontekst va resurs doim tekshiriladi. Secret management kalitni saqlash, aylantirish, bekor qilish va kirishni auditlashni qamraydi.

Zero Trust	mTLS	secret rotation	policy decision

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
openssl version	Mahalliy OpenSSL versiyasini ko‘rsatadi.
openssl x509 -in sample.crt -noout -dates	Mavjud lokal sertifikatning amal muddatini ko‘rsatadi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Container VM emas; image trust, runtime capabilities va network bindingni alohida ko‘ring. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: VPN ichida bo‘lish Zero Trust tekshiruvidan ozod etmaydi. Natija: 3 policy test va deny sabablar.

28-hafta / Xavf va himoya

7-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Secret value’lar logga yozilmasligi kerak.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Zero-trust access matrix. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Docker container host kernel bilan umumiy qatlamga ega bo‘lishi mumkin. `--privileged`, host PID/net namespaces, Docker socket mount yoki host filesystem bind mount kabi konfiguratsiyalar isolation riskini oshiradi. Bularni productionda ekspluatatsiya qilish o‘rniga o‘z lab image’ining configini `docker inspect` orqali audit qiling.

Manba yo‘nalishi: [S07][S10][S15]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Real token, TLS private key yoki production secret qo‘llanmaydi.

28-hafta / Amaliy mashg‘ulot A

7-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: 3 policy test va deny sabablar.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 28 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
def allow(r):
 return r['verified'] and r['device_ok'] and r['scope']=='read'
assert allow(dict(verified=True,device_ok=True,scope='read'))
assert not allow(dict(verified=True,device_ok=False,scope='read'))
print('context-based allow/deny: PASS')
PYLAB
```

KUTILGAN NATIJA: Qurilma mos emas bo‘lsa, tasdiqlangan user ham DENY oladi.
XAVFSIZLIK: Real token, TLS private key yoki production secret qo‘llanmaydi.

TUSHUNTIRISH: Zero Trust tarmoq joylashuviga avtomatik ishonmaydi: identity, qurilma, kontekst va resurs doim tekshiriladi. Secret management kalitni saqlash, aylantirish, bekor qilish va kirishni auditlashni qamraydi.
EHTIYOT: VPN ichida bo‘lish Zero Trust tekshiruvidan ozod etmaydi.

28-hafta / Amaliy mashg‘ulot B

7-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #28, Zero Trust va secret management.
Command / tool	Python3 (sintetik sinov)
Expected	Qurilma mos emas bo‘lsa, tasdiqlangan user ham DENY oladi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	VPN ichida bo‘lish Zero Trust tekshiruvidan ozod etmaydi.

i

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: 3 policy test va deny sabablar. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Kali Linux VirtualBox NAT adapteri odatda fizik 802.11 radio interfeys emas. `eth0` orqali standart Wi-Fi

Texnik izoh: VPN ichida bo‘lish Zero Trust tekshiruvidan ozod etmaydi. Zero Trust tarmoq joylashuviga avtomatik ishonmaydi: identity, qurilma, kontekst va resurs doim tekshiriladi. Secret management kalitni saqlash, aylantirish, bekor qilish va kirishni auditlashni qamraydi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

28-hafta / Hisobot va challenge

7-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Zero-trust access matrix

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Zero Trust va secret management” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Zero Trust va secret management. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: 3 policy test va deny sabablar.
Xavfsizlik chegarasi: Real token, TLS private key yoki production secret qo‘llanmaydi.

29-hafta / Malware taksonomiyasi

8-OY • Malware anatomiyasi va reverse engineering | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Virus, worm, trojan, loader, dropper, spyware, stealer, rootkit, botnet, ransomware, wiper.

Asosiy tushuncha

Malware nomlari tarqalish va bajarilish mexanizmiga qarab farqlanadi: virus host faylga bog‘lanishi, worm o‘zi tarqalishi, trojan esa aldamchi ko‘rinish bilan kelishi mumkin.

Tayanch atamalarni ajratamiz

1. virus	Boshqa fayl/hostga bog‘lanib ko‘payadigan zararli kod.
2. worm	Tarmoq yoki boshqa mexanizm orqali mustaqil tarqaluvchi zararli kod.
3. trojan	Foydali dastur sifatida ko‘rinib zararli funksiya yashiruvchi dastur.
4. loader/rootkit	Loader boshqa kodni yuklaydi; rootkit mavjudlikni yashirishga urinadi.

Keng tarqalgan chalkashlik

Aniqlik: Bir oilaning funksiyalari bir nechta toifaga mos kelishi mumkin..

Chuqurroq konseptual tahlil

PE (Windows) va ELF (Linux) executable formatlarida header, sections, imports va entry point mavjud. Malware yozish shart emas: statik vositalar bilan bu bo‘laklarni ko‘rib, jarayon qanday ishga tushishini, qaysi library’ga bog‘langanini va byte distribution qanaqa ekanini tushunish mumkin.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

29-hafta / Texnik mexanizm

8-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Malware nomlari tarqalish va bajarilish mexanizmiga qarab farqlanadi: virus host faylga bog‘lanishi, worm o‘zi tarqalishi, trojan esa aldamchi ko‘rinish bilan kelishi mumkin.

virus	worm	trojan	loader/rootkit

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
file sample.bin	sample.bin mavjud bo‘lsa magic bo‘yicha formatini taxmin qiladi.
sha256sum sample.bin	Mavjud sample.bin uchun SHA-256 chiqaradi; fayl ishga tushmaydi.
strings -n 6 sample.bin	Fayldagi ko‘rinadigan belgilar ketma-ketligini chiqaradi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: ELF imports va section headers malware mavjudligini yolg‘iz isbotlamaydi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Bir oilaning funksiyalari bir nechta toifaga mos kelishi mumkin. Natija: oilalar matritsasi va aniqlash indikatorlari.

29-hafta / Xavf va himoya

8-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Binary imzo bilan haqiqiy zararli xulqni ajratib yoz.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik kompрometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Malware classification tree. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Static triage misollari: file type, file size, compiled timestamp (soxtalashtirilgan bo‘lishi mumkin), section permissions, imports, strings, code signing va version resource. Sharhda “observed”, “inferred”, “not validated” kabi dalil darajalari ajratiladi.

Manba yo‘nalishi: [S07][S21][S09]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Real malware namunalarini kundalik kompyuterda ishga tushirma.

29-hafta / Amaliy mashg‘ulot A

8-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: oilalar matritsasi va aniqlash indikatorlari.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 29 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
examples={'sample-A':'worm','sample-B':'trojan','sample-C':'loader'}
for sample,category in examples.items():
 print(sample,category)
PYLAB
```

KUTILGAN NATIJA: Zararsiz uchta sintetik metadata yozuvi tasniflanadi; bajariladigan zararli fayl yo‘q.
XAVFSIZLIK: Real malware namunalarini kundalik kompyuterda ishga tushirma.

TUSHUNTIRISH: Malware nomlari tarqalish va bajarilish mexanizmiga qarab farqlanadi: virus host faylga bog‘lanishi, worm o‘zi tarqalishi, trojan esa aldamchi ko‘rinish bilan kelishi mumkin.
EHTIYOT: Bir oilaning funksiyalari bir nechta toifaga mos kelishi mumkin.

29-hafta / Amaliy mashg‘ulot B

8-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #29, Malware taksonomiyasi.
Command / tool	f Python3 (sintetik sinov)
Expected	Zararsiz uchta sintetik metadata yozuvi tasniflanadi; bajariladigan zararli fayl yo‘q.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Bir oilaning funksiyalari bir nechta toifaga mos kelishi mumkin.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: oilalar matritsasi va aniqlash indikatorlari. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Virus/wormni “yaratish” uchun executable replication kodi kerak bo‘lmaydi: xavfsiz darsda graph

Texnik izoh: Bir oilaning funksiyalari bir nechta toifaga mos kelishi mumkin. Malware nomlari tarqalish va bajarilish mexanizmiga qarab farqlanadi: virus host faylga bog‘lanishi, worm o‘zi tarqalishi, trojan esa aldamchi ko‘rinish bilan kelishi mumkin.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

29-hafta / Hisobot va challenge

8-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Malware classification tree

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Malware taksonomiyasi” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Malware taksonomiyasi. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: oilalar matritsasi va aniqlash indikatorlari.
Xavfsizlik chegarasi: Real malware namunalarini kundalik kompyuterda ishga tushirma.

© 2026 • Xavfsiz, ruxsatli tadqiqot • Nazariya + amaliyot

30-hafta / Static triage

8-OY • Malware anatomiyasi va reverse engineering | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

PE/ELF/Mach-O, headers, imports, sections, packer belgisi, entropy va hashes.

Asosiy tushuncha

Static triage namunaning ishga tushirilmagan holatdagi headerlari, fayl turi, hash va imports/stringsni kuzatishdir. Entropy yoki 'packer' belgisi yakka o‘zi zararli ekanini isbotlamaydi.

Tayanch atamalarni ajratamiz

1. PE/ELF	Windows va Linux bajariladigan fayl formatlari.
2. headers	Arxitektura, section va entry point kabi metadata maydonlari.
3. imports	Tashqi funksiyalarga qaramlik ro‘yxati.
4. SHA-256	Fayl kontenti uchun 256-bitli digest; zararli ekanining isboti emas.

Keng tarqalgan chalkashlik

Aniqlik: Bitta hash virus indikatoriga avtomatik teng emas..

Chuqurroq konseptual tahlil

Modulli malware oilalari “loader → payload → persistence/collection/impact” kabi bosqichlardan iborat bo‘lishi mumkin, lekin hammasi bir xil emas. “Troyan” so‘zi ko‘proq dastur foydali ko‘rinib zararli imkoniyat olib kirishini ifodalaydi. Wiper tiklashni maqsadli qiyinlashtiradi, ba’zi “ransomware” hodisalari aslida destruktiv wiper bo‘lishi mumkin.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

30-hafta / Texnik mexanizm

8-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Static triage namunaning ishga tushirilmagan holatdagi headerlari, fayl turi, hash va imports/stringsni kuzatishdir. Entropy yoki 'packer' belgisi yakka o‘zi zararli ekanini isbotlamaydi.

PE/ELF	headers	imports	SHA-256

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
file	Fayl formatini magic/header orqali taxmin qiladi.
xxd -l 64	Faylning 64 baytigacha hex ko‘rinishda chiqaradi; argument talab qilinadi.
readelf -h /bin/ls	Tanish ELF faylining sarlavhasini chiqaradi.
objdump -f /bin/ls	Bajariladigan faylning format/head metama’lumoti.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Yuqori entropy encryption, compression yoki packagingdan ham kelishi mumkin. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Bitta hash virus indikatoriga avtomatik teng emas. Natija: fayl formati, hash, tool versiyasi.

30-hafta / Xavf va himoya

8-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Entropy yuqori bo‘lishi “malware”ni isbotlamaydi.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Static triage sheet. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Virus/wormni “yaratish” uchun executable replication kodi kerak bo‘lmaydi: xavfsiz darsda graph simulator har bir iteratsiyada qaysi node hipotetik yuqqanini ko‘rsatadi. Bu tarmoqka real paket yubormaydi, faylni infektsiya qilmaydi.

Manba yo‘nalishi: [S07][S21][S09]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Noma’lum exe/ELFni ishga tushirma; tahlil uchun faqat tanish OS fayli.

30-hafta / Amaliy mashg‘ulot A

8-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: fayl formati, hash, tool versiyasi.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 30 | Mavzuga mos amaliyot

```
file /bin/ls
sha256sum /bin/ls
# mavjud bo‘lsa: readelf -h /bin/ls | head -20
```

KUTILGAN NATIJA: Mahalliy ishonchli /bin/ls faylining turi, hash va ELF sarlavhasi ko‘riladi.
XAVFSIZLIK: Noma’lum exe/ELFni ishga tushirma; tahlil uchun faqat tanish OS fayli.

TUSHUNTIRISH: Static triage namunaning ishga tushirilmagan holatdagi headerlari, fayl turi, hash va imports/stringsni kuzatishdir. Entropy yoki 'packer' belgisi yakka o‘zi zararli ekanini isbotlamaydi.
EHTIYOT: Bitta hash virus indikatoriga avtomatik teng emas.

30-hafta / Amaliy mashg‘ulot B

8-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #30, Static triage.
Command / tool	f Linux terminal / ruxsatli lokal sinov
Expected	Mahalliy ishonchli /bin/ls faylining turi, hash va ELF sarlavhasi ko‘riladi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Bitta hash virus indikatoriga avtomatik teng emas.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: fayl formati, hash, tool versiyasi. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: PE (Windows) va ELF (Linux) executable formatlarida header, sections, imports va entry point mavjud.

Texnik izoh: Bitta hash virus indikatoriga avtomatik teng emas. Static triage namunaning ishga tushirilmagan holatdagi headerlari, fayl turi, hash va imports/stringsni kuzatishdir. Entropy yoki 'packer' belgisi yakka o‘zi zararli ekanini isbotlamaydi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

30-hafta / Hisobot va challenge

8-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Static triage sheet

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Static triage” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Static triage. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: fayl formati, hash, tool versiyasi.
Xavfsizlik chegarasi: Noma’lum exe/ELFni ishga tushirma; tahlil uchun faqat tanish OS fayli.

31-hafta / Dynamic behavior & telemetry

8-OY • Malware anatomiyasi va reverse engineering | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Sandbox isolation, process tree, DNS, file changes, registry, network flow, timeline.

Asosiy tushuncha

Dynamic malware tahlilida process tree, tarmoq, registry va fayl hodisalari muhim. Lekin xavfsiz mashqda haqiqiy malware emas, o‘zining benign fayl o‘zgarishi kuzatiladi.

Tayanch atamalarni ajratamiz

1. sandbox	Tajriba ta’siri boshqa tizimlarga tarqalmaydigan nazoratli muhit.
2. process tree	Parent-child jarayon bog‘lanishlari.
3. file telemetry	Fayl yaratilishi, nomi o‘zgarishi va yozilishi hodisalari.
4. detonation risk	Noma’lum kodni ishga tushirish orqali zarar yetkazish ehtimoli.

Keng tarqalgan chalkashlik

Aniqlik: Fayl yozilishining o‘zi ransomware belgisi emas.

Chuqurroq konseptual tahlil

Static triage misollari: file type, file size, compiled timestamp (soxtalashtirilgan bo‘lishi mumkin), section permissions, imports, strings, code signing va version resource. Sharhda “observed”, “inferred”, “not validated” kabi dalil darajalari ajratiladi.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

31-hafta / Texnik mexanizm

8-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Dynamic malware tahlilida process tree, tarmoq, registry va fayl hodisalari muhim. Lekin xavfsiz mashqda haqiqiy malware emas, o‘zining benign fayl o‘zgarishi kuzatiladi.

sandbox	process tree	file telemetry	detonation risk

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
ps aux	Jarayonlar ro‘yxatini chiqaradi; maxfiy argumentlar ko‘rinishi mumkin.
ss -tupan	Aktiv TCP/UDP soket va jarayon metadata; mahalliy kuzatuv.
journalctl --since today	Bugungi systemd eventlarini o‘qiydi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: YARA marker rule mazmuni pattern match, behavioral detection emas. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Fayl yozilishining o‘zi ransomware belgisi emas; tezlik va kontekst muhim. Natija: oldin/keyin eventlar va cleanup log.

31-hafta / Xavf va himoya

8-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

True malware namunalarini host Windows’da ochma; offline sandbox snapshot must.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Behavior observation card. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

PE (Windows) va ELF (Linux) executable formatlarida header, sections, imports va entry point mavjud. Malware yozish shart emas: statik vositalar bilan bu bo‘laklarni ko‘rib, jarayon qanday ishga tushishini, qaysi library’ga bog‘langanini va byte distribution qanaqa ekanini tushunish mumkin.

Manba yo‘nalishi: [S07][S21][S09]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Haqiqiy shubhali binary yoki makrosni ishga tushirma.

31-hafta / Amaliy mashg‘ulot A

8-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: oldin/keyin eventlar va cleanup log.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 31 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
from pathlib import Path
from tempfile import TemporaryDirectory
with TemporaryDirectory() as d:
 p=Path(d)/'lab.txt'; p.write_text('hello')
 print('created:',p.name,'bytes:',p.stat().st_size)
 p.write_text('hello world');print('updated bytes:',p.stat().st_size)
print('temporary files cleaned')
PYLAB
```

KUTILGAN NATIJA: Vaqtinchalik papkada benign fayl yaratiladi va o‘zgaradi; keyin tozalanadi.
XAVFSIZLIK: Haqiqiy shubhali binary yoki makrosni ishga tushirma.

TUSHUNTIRISH: Dynamic malware tahlilida process tree, tarmoq, registry va fayl hodisalari muhim. Lekin xavfsiz mashqda haqiqiy malware emas, o‘zining benign fayl o‘zgarishi kuzatiladi.
EHTIYOT: Fayl yozilishining o‘zi ransomware belgisi emas; tezlik va kontekst muhim.

31-hafta / Amaliy mashg‘ulot B

8-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #31, Dynamic behavior & telemetry.
Command / tool	Python3 (sintetik sinov)
Expected	Vaqtinchalik papkada benign fayl yaratiladi va o‘zgaradi; keyin tozalanadi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Fayl yozilishining o‘zi ransomware belgisi emas; tezlik va kontekst muhim.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: oldin/keyin eventlar va cleanup log. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Modulli malware oilalari “loader → payload → persistence/collection/impact” kabi bosqichlardan iborat

Texnik izoh: Fayl yozilishining o‘zi ransomware belgisi emas; tezlik va kontekst muhim. Dynamic malware tahlilida process tree, tarmoq, registry va fayl hodisalari muhim. Lekin xavfsiz mashqda haqiqiy malware emas, o‘zining benign fayl o‘zgarishi kuzatiladi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

31-hafta / Hisobot va challenge

8-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Behavior observation card

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Dynamic behavior & telemetry” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Dynamic behavior & telemetry. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: oldin/keyin eventlar va cleanup log.
Xavfsizlik chegarasi: Haqiqiy shubhali binary yoki makrosni ishga tushirma.

32-hafta / Detection signatures

8-OY • Malware anatomiyasi va reverse engineering | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

IOC vs behavior, YARA-X rules, Sigma rules, false positive, rule lifecycle.

Asosiy tushuncha

Signature fayl belgilari yoki xatti-harakatni aniqlashga yordam beradi; bitta IOC ko‘pincha eskiradi. False positive va false negative qoidaning tekshirilishi lozim bo‘lgan asosiy xatolaridir.

Tayanch atamalarni ajratamiz

1. IOC	Hash, domen, fayl belgisi singari kuzatiladigan indikator.
2. YARA-X	Fayl yoki memory kontentidagi patternni aniqlash qoidalari.
3. Sigma	Log hodisalari uchun platforma-agnostik qoidalar tavsifi.
4. false positive	Qoidaning aslida benign holatni xavfli deb belgilashi.

Keng tarqalgan chalkashlik

Aniqlik: Text marker match ishlab chiqarishdagi YARA qoidasini to‘liq sinovdan o‘tkazma.

Chuqurroq konseptual tahlil

Virus/wormni “yaratish” uchun executable replication kodi kerak bo‘lmaydi: xavfsiz darsda graph simulator har bir iteratsiyada qaysi node hipotetik yuqqanini ko‘rsatadi. Bu tarmoqka real paket yubormaydi, faylni infektsiya qilmaydi.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

32-hafta / Texnik mexanizm

8-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Signature fayl belgilari yoki xatti-harakatni aniqlashga yordam beradi; bitta IOC ko‘pincha eskiradi. False positive va false negative qoidaning tekshirilishi lozim bo‘lgan asosiy xatolaridir.

IOC	YARA-X	Sigma	false positive

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
sha256sum	Faylning SHA-256 digestini hisoblaydi; o‘zi xavfsizlikni isbotlamaydi.
grep -R	Ko‘rsatilgan papka ichida satr bo‘yicha rekursiv qidiradi.
yr --version	YARA-X CLI o‘rnatilgan bo‘lsa versiyasini chiqaradi; nom mavjudlikka bog‘liq.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Sandbox tashqi tarmoq bilan bog‘lansa zararli namuna qarshi hujum qilishi mumkin; izolyatsiya zarur. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Text marker match ishlab chiqarishdagi YARA qoidasini to‘liq sinovdan o‘tkazmaydi. Natija: TP/FP sinov holatlari va imzo cheklovi.

32-hafta / Xavf va himoya

8-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Hash-based signature bitta namunaga bog‘langan, behavior generalizable.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Detection rule + test vectors. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Modulli malware oilalari “loader → payload → persistence/collection/impact” kabi bosqichlardan iborat bo‘lishi mumkin, lekin hammasi bir xil emas. “Troyan” so‘zi ko‘proq dastur foydali ko‘rinib zararli imkoniyat olib kirishini ifodalaydi. Wiper tiklashni maqsadli qiyinlashtiradi, ba’zi “ransomware” hodisalari aslida destruktiv wiper bo‘lishi mumkin.

Manba yo‘nalishi: [S07][S21][S09]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Reallikka o‘xshash zararli payload ishlatma; harmless marker kifoya.

32-hafta / Amaliy mashg‘ulot A

8-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: TP/FP sinov holatlari va imzo cheklovi.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 32 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
samples=['LAB_MARKER safe text','normal document']
for text in samples:
 print('marker_match=', 'LAB_MARKER' in text)
PYLAB
```

KUTILGAN NATIJA: Sintetik marker bor satr true, oddiy satr false chiqadi.
XAVFSIZLIK: Reallikka o‘xshash zararli payload ishlatma; harmless marker kifoya.

TUSHUNTIRISH: Signature fayl belgilari yoki xatti-harakatni aniqlashga yordam beradi; bitta IOC ko‘pincha eskiradi. False positive va false negative qoidaning tekshirilishi lozim bo‘lgan asosiy xatolaridir.
EHTIYOT: Text marker match ishlab chiqarishdagi YARA qoidasini to‘liq sinovdan o‘tkazmaydi.

32-hafta / Amaliy mashg‘ulot B

8-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #32, Detection signatures.
Command / tool	Python3 (sintetik sinov)
Expected	Sintetik marker bor satr true, oddiy satr false chiqadi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Text marker match ishlab chiqarishdagi YARA qoidasini to‘liq sinovdan o‘tkazmaydi.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: TP/FP sinov holatlari va imzo cheklovi. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Static triage misollari: file type, file size, compiled timestamp (soxtalashtirilgan bo‘lishi mumkin), section

Texnik izoh: Text marker match ishlab chiqarishdagi YARA qoidasini to‘liq sinovdan o‘tkazmaydi. Signature fayl belgilari yoki xatti-harakatni aniqlashga yordam beradi; bitta IOC ko‘pincha eskiradi. False positive va false negative qoidaning tekshirilishi lozim bo‘lgan asosiy xatolaridir.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

32-hafta / Hisobot va challenge

8-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Detection rule + test vectors

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Detection signatures” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Detection signatures. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: TP/FP sinov holatlari va imzo cheklovi.
Xavfsizlik chegarasi: Reallikka o‘xshash zararli payload ishlatma; harmless marker kifoya.

33-hafta / Ransomware kill chain

9-OY • Ransomware, worm, virus va tiklash | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Initial access → execution → discovery → lateral movement → impact/extortion; RaaS iqtisodi.

Asosiy tushuncha

Ransomware zanjirida kirish, bajarilish, discovery, tarqalish va impact bo‘lishi mumkin. Himoyada nazoratli, hech narsani shifrlamaydigan file-churn signallaridan foydalanish mumkin.

Tayanch atamalarni ajratamiz

1. initial access	Hujumchining birinchi ruxsatsiz kirish imkoniyati.
2. impact	Shifrlash, ma’lumot mavjudligini buzish yoki xizmatni to‘xtatish oqibati.
3. file churn	Fayl yaratilishi/yozilishi/nomi almashishi chastotasi.
4. immutable backup	Asosiy tizim tomonidan o‘zgartirib bo‘lmaydigan backup nusxasi.

Keng tarqalgan chalkashlik

Aniqlik: Fayl ko‘pligi backup yoki dastur o‘rnatish paytida ham sodir bo‘ladi..

Chuqurroq konseptual tahlil

Virus odatda host fayl/hujjat bilan bog‘liq bo‘lib, ko‘payish uchun foydalanuvchi interaksiyasini talab qilishi mumkin; worm esa boshqa hostlarga avtomatik tarqalish bilan belgilanadi. Botnetning ajralib turuvchi jihati ko‘p endpointning bir boshqaruv modeli orqali muvofiqlashtirilishi; ransomware esa data availability va extortionga yo‘naltiriladi.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

33-hafta / Texnik mexanizm

9-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Ransomware zanjirida kirish, bajarilish, discovery, tarqalish va impact bo‘lishi mumkin. Himoyada nazoratli, hech narsani shifrlamaydigan file-churn signallaridan foydalanish mumkin.

initial access	impact	file churn	immutable backup

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
sha256sum	Faylning SHA-256 digestini hisoblaydi; o‘zi xavfsizlikni isbotlamaydi.
find	Bu buyruq uchun --help/man sahifasidan variant, kirish va chiqishni tekshiring; faqat ruxsatli muhitda.
stat	Fayl metama’lumoti, permission va vaqtlarni chiqaradi; argument kerak.
journalctl	systemd jurnalini o‘qiydi; ayrim yozuvlar uchun guruh/ruxsat kerak.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Bulk file modification backup dasturi yoki build jarayoni ham bo‘lishi mumkin. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Fayl ko‘pligi backup yoki dastur o‘rnatish paytida ham sodir bo‘ladi. Natija: threshold, test papkasi, cleanup va false positive izohi.

33-hafta / Xavf va himoya

9-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Prevention va response orasida backup integrity va account containment.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik kompрometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Ransomware ATT&CK map. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Tarqalish modeli matematik graf sifatida ko‘rilsa xavf aniqroq: hostlar tugun, ruxsatli network flows qirra, infection probability va patch factor parametrlar. Isolation, credential reset va vulnerability patching qirralar sonini yoki muvaffaqiyat ehtimolini pasaytiradi.

Manba yo‘nalishi: [S08][S13][S23][S24][S29]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Hech qanday shifrlash, shadow copy o‘chirish yoki real papkaga tegish yo‘q.

33-hafta / Amaliy mashg‘ulot A

9-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: threshold, test papkasi, cleanup va false positive izohi.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 33 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
from tempfile import TemporaryDirectory
from pathlib import Path
with TemporaryDirectory() as d:
 for i in range(12): (Path(d)/f'test{i}.txt').write_text('demo')
 count=len(list(Path(d).glob('*.txt')))
 print('benign creations:',count,'review_needed:',count>=10)
PYLAB
```

KUTILGAN NATIJA: 12 ta vaqtinchalik zararsiz fayl yaratiladi, threshold sinovi qayd etiladi.
XAVFSIZLIK: Hech qanday shifrlash, shadow copy o‘chirish yoki real papkaga tegish yo‘q.

TUSHUNTIRISH: Ransomware zanjirida kirish, bajarilish, discovery, tarqalish va impact bo‘lishi mumkin. Himoyada nazoratli, hech narsani shifrlamaydigan file-churn signallaridan foydalanish mumkin.
EHTIYOT: Fayl ko‘pligi backup yoki dastur o‘rnatish paytida ham sodir bo‘ladi.

33-hafta / Amaliy mashg‘ulot B

9-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #33, Ransomware kill chain.
Command / tool	Python3 (sintetik sinov)
Expected	12 ta vaqtinchalik zararsiz fayl yaratiladi, threshold sinovi qayd etiladi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Fayl ko‘pligi backup yoki dastur o‘rnatish paytida ham sodir bo‘ladi.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: threshold, test papkasi, cleanup va false positive izohi. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Response vaqtida xodim bilan aloqa, evidence preservation, identity disable, host isolation va business

Texnik izoh: Fayl ko‘pligi backup yoki dastur o‘rnatish paytida ham sodir bo‘ladi. Ransomware zanjirida kirish, bajarilish, discovery, tarqalish va impact bo‘lishi mumkin. Himoyada nazoratli, hech narsani shifrlamaydigan file-churn signallaridan foydalanish mumkin.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

33-hafta / Hisobot va challenge

9-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Ransomware ATT&CK map

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Ransomware kill chain” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Ransomware kill chain. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: threshold, test papkasi, cleanup va false positive izohi.
Xavfsizlik chegarasi: Hech qanday shifrlash, shadow copy o‘chirish yoki real papkaga tegish yo‘q.

© 2026 • Xavfsiz, ruxsatli tadqiqot • Nazariya + amaliyot

34-hafta / Worm va propagation

9-OY • Ransomware, worm, virus va tiklash | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Self-replication, attack surface, fan-out, epidemiologik spreading va segmentation.

Asosiy tushuncha

Worm o‘z-o‘zidan tarqaladigan tahdid bo‘lib, fan-out va tarmoq segmentatsiyasi ta’sirini grafik orqali xavfsiz modellashtirish mumkin. Bu internetga paket yuborishni talab qilmaydi.

Tayanch atamalarni ajratamiz

1. self propagation	Boshqa tugunga insonning qo‘lda bajarishisiz o‘tish xususiyati.
2. fan-out	Bitta tugundan nechta yangi tugunga ulanish mavjudligi.
3. segmentation	Tarmoq zonalari orasidagi erkin aloqani cheklash.
4. graph reachability	Grafda boshlang‘ich nuqtadan borish mumkin bo‘lgan tugunlar.

Keng tarqalgan chalkashlik

Aniqlik: Graf reachability real zaiflik mavjudligiga teng emas..

Chuqurroq konseptual tahlil

“Backup bor” degani “tiklay olamiz” emas. Zaxira nusxa threat actor kirish huquqidan mustaqil bo‘lishi, air-gapped/immutable komponentga ega bo‘lishi, retention sog‘lom va restore muntazam sinovdan o‘tishi kerak. RPO va RTO biznesning qanchalik ma’lumot/vaqt yo‘qotishga chiday olishini ifodalaydi.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

34-hafta / Texnik mexanizm

9-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Worm o‘z-o‘zidan tarqaladigan tahdid bo‘lib, fan-out va tarmoq segmentatsiyasi ta’sirini grafik orqali xavfsiz modellashtirish mumkin. Bu internetga paket yuborishni talab qilmaydi.

self propagation	fan-out	segmentation	graph reachability

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
python3 --version	Python interpreter versiyasini ko‘rsatadi.
ip route	Mahalliy routing jadvali; aktiv skan emas.
ss -ltn	Tinglayotgan TCP portlarni jarayon nomisiz ro‘yxatlaydi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Backup nusxa borligi recovery test o‘tganini isbotlamaydi; RTO/RPO bilan baholang. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Graf reachability real zaiflik mavjudligiga teng emas. Natija: segmentatsiyadan oldin/keyin tugunlar soni.

34-hafta / Xavf va himoya

9-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Network segmentation va patching R0 ni qanday kamaytirishini izohla.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik kompрometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Safe graph simulation report. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Response vaqtida xodim bilan aloqa, evidence preservation, identity disable, host isolation va business continuity o‘rtasida to‘g‘ri navbat belgilanadi. Ilk kirish mexanizmi bartaraf etilmasdan clean image restore qilish qayta kompрometatsiyaga olib kelishi mumkin.

Manba yo‘nalishi: [S08][S13][S23][S24][S29]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Haqiqiy skan, exploit va propagation kodi ishlatilmaydi.

34-hafta / Amaliy mashg‘ulot A

9-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: segmentatsiyadan oldin/keyin tugunlar soni.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 34 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
graph={'A':['B','C'],'B':['D'],'C':[],'D':[]}
seen={'A'};todo=['A']
while todo:
 for nxt in graph[todo.pop(0)]:
  if nxt not in seen: seen.add(nxt);todo.append(nxt)
print('reachable:',sorted(seen))
PYLAB
```

KUTILGAN NATIJA: Faqat Python ichidagi graf tugunlari hisoblanadi; hech qanday tarmoqqa chiqilmaydi.
XAVFSIZLIK: Haqiqiy skan, exploit va propagation kodi ishlatilmaydi.

TUSHUNTIRISH: Worm o‘z-o‘zidan tarqaladigan tahdid bo‘lib, fan-out va tarmoq segmentatsiyasi ta’sirini grafik orqali xavfsiz modellashtirish mumkin. Bu internetga paket yuborishni talab qilmaydi.
EHTIYOT: Graf reachability real zaiflik mavjudligiga teng emas.

34-hafta / Amaliy mashg‘ulot B

9-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #34, Worm va propagation.
Command / tool	Python3 (sintetik sinov)
Expected	Faqat Python ichidagi graf tugunlari hisoblanadi; hech qanday tarmoqqa chiqilmaydi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Graf reachability real zaiflik mavjudligiga teng emas.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: segmentatsiyadan oldin/keyin tugunlar soni. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Virus odatda host fayl/hujjat bilan bog‘liq bo‘lib, ko‘payish uchun foydalanuvchi interaksiyasini talab

Texnik izoh: Graf reachability real zaiflik mavjudligiga teng emas. Worm o‘z-o‘zidan tarqaladigan tahdid bo‘lib, fan-out va tarmoq segmentatsiyasi ta’sirini grafik orqali xavfsiz modellashtirish mumkin. Bu internetga paket yuborishni talab qilmaydi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

34-hafta / Hisobot va challenge

9-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Safe graph simulation report

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Worm va propagation” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Worm va propagation. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: segmentatsiyadan oldin/keyin tugunlar soni.
Xavfsizlik chegarasi: Haqiqiy skan, exploit va propagation kodi ishlatilmaydi.

35-hafta / Ransomware detection engineering

9-OY • Ransomware, worm, virus va tiklash | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

High-rate file rename/write, backup deletion attempts, shadow copy signals, canary, shadow storage.

Asosiy tushuncha

Ransomware detection ko‘plab indikatorlarning vaqt bo‘yicha birikmasini baholaydi: file-churn, backup tampering, imtiyoz o‘zgarishi, shubhali jarayon. Har signalning o‘z false positive’i bor.

Tayanch atamalarni ajratamiz

1. file-churn rate	Qisqa muddatda fayllar ustida amallar chastotasi.
2. backup tampering	Zaxira nusxa yoki tiklash vositasini buzishga urinish.
3. correlation	Bir nechta hodisani vaqt/aktiv bo‘yicha birlashtirish.
4. containment	Aniqlangan xavfni cheklash; xato qaror biznesga zarar yetkazishi mumkin.

Keng tarqalgan chalkashlik

Aniqlik: Detektor signalini avtomatik tasdiqlangan komprometatsiya deb baholama..

Chuqurroq konseptual tahlil

Tarqalish modeli matematik graf sifatida ko‘rilsa xavf aniqroq: hostlar tugun, ruxsatli network flows qirra, infection probability va patch factor parametrlar. Isolation, credential reset va vulnerability patching qirralar sonini yoki muvaffaqiyat ehtimolini pasaytiradi.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

35-hafta / Texnik mexanizm

9-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Ransomware detection ko‘plab indikatorlarning vaqt bo‘yicha birikmasini baholaydi: file-churn, backup tampering, imtiyoz o‘zgarishi, shubhali jarayon. Har signalning o‘z false positive’i bor.

file-churn rate	backup tampering	correlation	containment

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
find ~/ehs -type f	Faqat o‘zingizning ehs katalogingizdagi fayllarni sanaydi.
stat	Fayl metama’lumoti, permission va vaqtlarni chiqaradi; argument kerak.
sha256sum	Faylning SHA-256 digestini hisoblaydi; o‘zi xavfsizlikni isbotlamaydi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sabablardan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Worm simulyatsiyasi grafdagi hipotetik qirralardan foydalanadi, real tarmoqqa paket yubormaydi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Detektor signalini avtomatik tasdiqlangan kompрometatsiya deb baholama. Natija: FP/FN misollari, threshold va operator tasdiqlash nuqtasi.

35-hafta / Xavf va himoya

9-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

False positive: backup/ETL katta file churn ham yaratishi mumkin.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Ransomware detector test plan. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Virus odatda host fayl/hujjat bilan bog‘liq bo‘lib, ko‘payish uchun foydalanuvchi interaksiyasini talab qilishi mumkin; worm esa boshqa hostlarga avtomatik tarqalish bilan belgilanadi. Botnetning ajralib turuvchi jihati ko‘p endpointning bir boshqaruv modeli orqali muvofiqlashtirilishi; ransomware esa data availability va extortionga yo‘naltiriladi.

Manba yo‘nalishi: [S08][S13][S23][S24][S29]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Haqiqiy jarayonni o‘chirish yoki karantinga yuborish yo‘q.

35-hafta / Amaliy mashg‘ulot A

9-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: FP/FN misollari, threshold va operator tasdiqlash nuqtasi.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 35 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
events=[{'writes':3,'backup':False},{'writes':25,'backup':True}]
for e in events:
 alert=e['writes']>20 and e['backup']
 print('review=',alert)
PYLAB
```

KUTILGAN NATIJA: Ikkinchi synthetic event review deb belgilanadi; avtomatik bloklash bajarilmaydi.
XAVFSIZLIK: Haqiqiy jarayonni o‘chirish yoki karantinga yuborish yo‘q.

TUSHUNTIRISH: Ransomware detection ko‘plab indikatorlarning vaqt bo‘yicha birikmasini baholaydi: file-churn, backup tampering, imtiyoz o‘zgarishi, shubhali jarayon. Har signalning o‘z false positive’i bor.
EHTIYOT: Detektor signalini avtomatik tasdiqlangan komprometatsiya deb baholama.

35-hafta / Amaliy mashg‘ulot B

9-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #35, Ransomware detection engineering.
Command / tool	f Python3 (sintetik sinov)
Expected	Ikkinchi synthetic event review deb belgilanadi; avtomatik bloklash bajarilmaydi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Detektor signalini avtomatik tasdiqlangan komprometatsiya deb baholama.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: FP/FN misollari, threshold va operator tasdiqlash nuqtasi. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: “Backup bor” degani “tiklay olamiz” emas. Zaxira nusxa threat actor kirish huquqidan mustaqil bo‘lishi,

Texnik izoh: Detektor signalini avtomatik tasdiqlangan komprometatsiya deb baholama. Ransomware detection ko‘plab indikatorlarning vaqt bo‘yicha birikmasini baholaydi: file-churn, backup tampering, imtiyoz o‘zgarishi, shubhali jarayon. Har signalning o‘z false positive’i bor.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

35-hafta / Hisobot va challenge

9-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Ransomware detector test plan

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Ransomware detection engineering” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Ransomware detection engineering. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: FP/FN misollari, threshold va operator tasdiqlash nuqtasi.
Xavfsizlik chegarasi: Haqiqiy jarayonni o‘chirish yoki karantinga yuborish yo‘q.

36-hafta / Incident response va recovery

9-OY • Ransomware, worm, virus va tiklash | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Containment, scoping, forensics, image, restore, immutable backup, tabletop; NIST 800-61r3.

Asosiy tushuncha

Incident response tayyorlanish, aniqlash/tahlil, cheklash, tiklash va saboq olish kabi ishlardan iborat. Recovery haqiqiy tiklangan ma’lumotni checksum bilan qayta sinashni talab qiladi.

Tayanch atamalarni ajratamiz

1. containment	Tahdid tarqalishini cheklash, dalilni saqlash bilan muvozanatlash.
2. chain of custody	Dalil kimda, qachon va qanday saqlangani qaydi.
3. restore	Backupdan ish faoliyati uchun kerakli holatga qaytarish.
4. retest	Tiklashdan keyin xatti-harakat va yaxlitlikni tekshirish.

Keng tarqalgan chalkashlik

Aniqlik: Backup borligi restore ishlashini kafolatlamaydi.

Chuqurroq konseptual tahlil

Response vaqtida xodim bilan aloqa, evidence preservation, identity disable, host isolation va business continuity o‘rtasida to‘g‘ri navbat belgilanadi. Ilk kirish mexanizmi bartaraf etilmasdan clean image restore qilish qayta kompрometatsiyaga olib kelishi mumkin.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

36-hafta / Texnik mexanizm

9-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Incident response tayyorlanish, aniqlash/tahlil, cheklash, tiklash va saboq olish kabi ishlardan iborat. Recovery haqiqiy tiklangan ma’lumotni checksum bilan qayta sinashni talab qiladi.

containment	chain of custody	restore	retest

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
date -Is	Joriy vaqtni ISO-8601 va zona bilan chiqaradi.
sha256sum	Faylning SHA-256 digestini hisoblaydi; o‘zi xavfsizlikni isbotlamaydi.
journalctl	systemd jurnalini o‘qiydi; ayrim yozuvlar uchun guruh/ruxsat kerak.
rsync --dry-run	Ko‘chirishni bajarmasdan rejalashtirilgan harakatlarni ko‘rsatadi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: WannaCry hamda NotPetya zarar va mexanizmlariga ko‘ra bir xil ransomware emas. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Backup borligi restore ishlashini kafolatlamaydi; tekshiruv zarur. Natija: restoration checksum va RTO/RPO savollari.

36-hafta / Xavf va himoya

9-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Qayta tiklashdan avval ilk kirish nuqtasini yo‘qotish kerak.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik kompрometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Ransomware tabletop package. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

“Backup bor” degani “tiklay olamiz” emas. Zaxira nusxa threat actor kirish huquqidan mustaqil bo‘lishi, air-gapped/immutable komponentga ega bo‘lishi, retention sog‘lom va restore muntazam sinovdan o‘tishi kerak. RPO va RTO biznesning qanchalik ma’lumot/vaqt yo‘qotishga chiday olishini ifodalaydi.

Manba yo‘nalishi: [S08][S13][S23][S24][S29]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Hech qanday ishlab turgan backup yoki production ma’lumot o‘zgartirilmaydi.

36-hafta / Amaliy mashg‘ulot A

9-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: restoration checksum va RTO/RPO savollari.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 36 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
from tempfile import TemporaryDirectory
from pathlib import Path
import hashlib
with TemporaryDirectory() as d:
 a=Path(d)/'a';b=Path(d)/'restored'
 a.write_bytes(b'backup-lab');b.write_bytes(a.read_bytes())
 print('restored
integrity:',hashlib.sha256(a.read_bytes()).digest()==hashlib.sha256(b.read_bytes()).digest())
PYLAB
```

KUTILGAN NATIJA: Original va tiklangan sintetik kontentning SHA-256 natijasi bir xil.
XAVFSIZLIK: Hech qanday ishlab turgan backup yoki production ma’lumot o‘zgartirilmaydi.

TUSHUNTIRISH: Incident response tayyorlanish, aniqlash/tahlil, cheklash, tiklash va saboq olish kabi ishlardan iborat. Recovery haqiqiy tiklangan ma’lumotni checksum bilan qayta sinashni talab qiladi.
EHTIYOT: Backup borligi restore ishlashini kafolatlamaydi; tekshiruv zarur.

36-hafta / Amaliy mashg‘ulot B

9-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #36, Incident response va recovery.
Command / tool	Python3 (sintetik sinov)
Expected	Original va tiklangan sintetik kontentning SHA-256 natijasi bir xil.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Backup borligi restore ishlashini kafolatlamaydi; tekshiruv zarur.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: restoration checksum va RTO/RPO savollari. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Tarqalish modeli matematik graf sifatida ko‘rilsa xavf aniqroq: hostlar tugun, ruxsatli network flows qirra,

Texnik izoh: Backup borligi restore ishlashini kafolatlamaydi; tekshiruv zarur. Incident response tayyorlanish, aniqlash/tahlil, cheklash, tiklash va saboq olish kabi ishlardan iborat. Recovery haqiqiy tiklangan ma’lumotni checksum bilan qayta sinashni talab qiladi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

36-hafta / Hisobot va challenge

9-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Ransomware tabletop package

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Incident response va recovery” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Incident response va recovery. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: restoration checksum va RTO/RPO savollari.
Xavfsizlik chegarasi: Hech qanday ishlab turgan backup yoki production ma’lumot o‘zgartirilmaydi.

37-hafta / Log pipeline va data schema

10-OY • SOC, SIEM, XDR va detection engineering | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Source→collector→parser→normalized schema→enrichment→rule→case.

Asosiy tushuncha

Log pipeline turli formatlardan kelgan hodisalarni bitta schema orqali qidiriladigan ko‘rinishga keltiradi. Normalizatsiyada manba, vaqt, host, tenant va event turi saqlanishi zarur.

Tayanch atamalarni ajratamiz

1. collector	Turli manbalardan logni qabul qiluvchi komponent.
2. parser	Xom yozuvni aniq maydonlarga ajratuvchi bosqich.
3. normalized schema	Barcha loglar uchun umumiy nomlangan maydonlar modeli.
4. enrichment	Hodisaga asset, user, threat intel kabi qo‘shimcha kontekst bog‘lash.

Keng tarqalgan chalkashlik

Aniqlik: Schema moslashuvi haqiqiy event semantikasini noto‘g‘ri o‘zgartirmasligi kerak.

Chuqurroq konseptual tahlil

Detection rule samarasi true positive (TP), false positive (FP), false negative (FN) va true negative (TN) bilan baholanadi. Precision = TP/(TP+FP), recall = TP/(TP+FN). Birini oshirish ikkinchisini kamaytirishi mumkin; buni qaysi hodisa biznes uchun qimmatroq ekaniga qarab muvozanatlashtiring.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

37-hafta / Texnik mexanizm

10-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Log pipeline turli formatlardan kelgan hodisalarni bitta schema orqali qidiriladigan ko‘rinishga keltiradi. Normalizatsiyada manba, vaqt, host, tenant va event turi saqlanishi zarur.



Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
jq .	JSONni formatlaydi yoki jq ifodasi bilan filtrlaydi.
python3 -m json.tool	JSON matnining sintaksisini tekshiradi/formatlaydi.
journalctl -o json	systemd jurnal yozuvlarini JSON ko‘rinishida beradi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Telemetry coverage va attack coverage bir xil metrika emas. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Schema moslashuvi haqiqiy event semantikasini noto‘g‘ri o‘zgartirmasligi kerak. Natija: 3 input, 3 normalized output va assertions.

37-hafta / Xavf va himoya

10-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Telemetry yo‘qolsa “healthy” ko‘rsatmaslik: fail-closed reporting.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik kompрometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Normalized event schema. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Security-first control plane request’lari tokenni tashqi proxyga chiqarmasligi, redirectda credential leak qilmasligi, TLS verify hamda tenant boundary’ni to‘g‘ri qo‘llashi kerak. Audit qoidalari read-only health check va live CrashGuard storage lock’ni to‘qnashmasligi uchun alohida hayot sikliga ega bo‘lishi mumkin.

Manba yo‘nalishi: [S07][S09][S10][S20]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Haqiqiy log/token/username ishlatilmaydi; manba synthetic deb belgilanadi.

37-hafta / Amaliy mashg‘ulot A

10-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: 3 input, 3 normalized output va assertions.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 37 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
rows=[{'event':4625,'user':'ali'},
      {'event_id':'4624','username':'vali'},
      {'type':'login_fail','account':'test'}]
def normalize(r):
 code=str(r.get('event',r.get('event_id',r.get('type'))))
 return {'source':'synthetic','user':r.get('user',r.get('username',r.get('account'))),'event':code}
out=[normalize(x) for x in rows]
assert len(out)==3 and all(set(x)=={'source','user','event'} for x in out)
print(out)
PYLAB
```

KUTILGAN NATIJA: Uch xil boshlang‘ich formatdan uchta bir xil kalitli normalized event olinadi.
XAVFSIZLIK: Haqiqiy log/token/username ishlatilmaydi; manba synthetic deb belgilanadi.

TUSHUNTIRISH: Log pipeline turli formatlardan kelgan hodisalarni bitta schema orqali qidiriladigan ko‘rinishga keltiradi. Normalizatsiyada manba, vaqt, host, tenant va event turi saqlanishi zarur.
EHTIYOT: Schema moslashuvi haqiqiy event semantikasini noto‘g‘ri o‘zgartirmasligi kerak.

37-hafta / Amaliy mashg‘ulot B

10-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #37, Log pipeline va data schema.
Command / tool	j Python3 (sintetik sinov)
Expected	Uch xil boshlang‘ich formatdan uchta bir xil kalitli normalized event olinadi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Schema moslashuvi haqiqiy event semantikasini noto‘g‘ri o‘zgartirmasligi kerak.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: 3 input, 3 normalized output va assertions. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Detektor alert qilganda avtomatik host isolate har doim ham to‘g‘ri emas. Muhim server, tibbiy/OT tuguni

Texnik izoh: Schema moslashuvi haqiqiy event semantikasini noto‘g‘ri o‘zgartirmasligi kerak. Log pipeline turli formatlardan kelgan hodisalarni bitta schema orqali qidiriladigan ko‘rinishga keltiradi. Normalizatsiyada manba, vaqt, host, tenant va event turi saqlanishi zarur.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

37-hafta / Hisobot va challenge

10-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Normalized event schema

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Log pipeline va data schema” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Log pipeline va data schema. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: 3 input, 3 normalized output va assertions.
Xavfsizlik chegarasi: Haqiqiy log/token/username ishlatilmaydi; manba synthetic deb belgilanadi.

© 2026 • Xavfsiz, ruxsatli tadqiqot • Nazariya + amaliyot

38-hafta / Sigma & correlation

10-OY • SOC, SIEM, XDR va detection engineering | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Rule metadata, selection/filter/condition, temporal windows, event grouping.

Asosiy tushuncha

Sigma qoidasi selection/filter/condition bilan log patternlarini tavsiflaydi. Ko‘p marta muvaffaqiyatsiz login, so‘ng muvaffaqiyatli kirishni bitta user va vaqt oynasida korrelyatsiya qilish zarur.

Tayanch atamalarni ajratamiz

1. selection	Qoidada aniqlanayotgan hodisa maydonlari va qiymatlar.
2. filter	Noto‘g‘ri triggerlarni kamaytiruvchi istisno mantiqi.
3. temporal window	Korrelyatsiyaga olinadigan vaqt oralig‘i.
4. precision/recall	Ogohlantirish tozaligi va haqiqiy tahdidni topish qamrovi.

Keng tarqalgan chalkashlik

Aniqlik: Precision/recall hisoblash korrelyatsiya qoidasi yozilganini isbotlamaydi..

Chuqurroq konseptual tahlil

Dalillar bilan ishlashda time-zone, wall-clock drift, NTP holati, host identity, acquisition agent version va hash manifest qayd etiladi. Bir vaqtning o‘zida uch manbadan yig‘ilgan loglarda timestamp turli granularity bo‘lishi mumkin; timeline’ni qayta qurishda shuni ochiq yozish kerak.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

38-hafta / Texnik mexanizm

10-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Sigma qoidasi selection/filter/condition bilan log patternlarini tavsiflaydi. Ko‘p marta muvaffaqiyatsiz login, so‘ng muvaffaqiyatli kirishni bitta user va vaqt oynasida korrelyatsiya qilish zarur.

selection	filter	temporal window	precision/recall

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
grep -R	Ko‘rsatilgan papka ichida satr bo‘yicha rekursiv qidiradi.
pytest -q	Lokal testlarni ishga tushiradi; test kodini avval tekshir.
git diff	Commit qilinmagan o‘zgarishlarni ko‘rsatadi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sabablardan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Precision 60%, Recall 75% kabi natija biznes kontekstisiz «yaxshi» deb baholanmaydi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Precision/recall hisoblash korrelyatsiya qoidasi yozilganini isbotlamaydi. Natija: positive/negative tests va korrelyatsiya oynasi.

38-hafta / Xavf va himoya

10-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

P1/P0 alertlarda audit va suppression sinovlari.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Sigma-style detection. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Detektor alert qilganda avtomatik host isolate har doim ham to‘g‘ri emas. Muhim server, tibbiy/OT tuguni yoki business critical xizmatga xavf yetishi mumkin. Buning uchun response gate, allowlist, role approval, stop condition va rollback talab etiladi.

Manba yo‘nalishi: [S07][S09][S10][S20]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Faqat sun’iy loginlar; haqiqiy parol taxmin qilish yoki brute-force yo‘q.

38-hafta / Amaliy mashg‘ulot A

10-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: positive/negative tests va korrelyatsiya oynasi.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 38 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
events=[('lab',t,'fail') for t in (0,5,10,15,20)] + [('lab',30,'success')]
fail=[e for e in events if e[0]=='lab' and e[2]=='fail' and 30-e[1]<=60]
success=any(e[2]=='success' and e[0]=='lab' and e[1]==30 for e in events)
alert=len(fail)>=5 and success
assert alert
print('5 failures + success in 60s:',alert)
PYLAB
```

KUTILGAN NATIJA: Aynan bitta userda 60 sekund ichida 5 fail + success korrelyatsiyasi true.
XAVFSIZLIK: Faqat sun’iy loginlar; haqiqiy parol taxmin qilish yoki brute-force yo‘q.

TUSHUNTIRISH: Sigma qoidasi selection/filter/condition bilan log patternlarini tavsiflaydi. Ko‘p marta muvaffaqiyatsiz login, so‘ng muvaffaqiyatli kirishni bitta user va vaqt oynasida korrelyatsiya qilish zarur.
EHTIYOT: Precision/recall hisoblash korrelyatsiya qoidasi yozilganini isbotlamaydi.

38-hafta / Amaliy mashg‘ulot B

10-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #38, Sigma & correlation.
Command / tool	Python3 (sintetik sinov)
Expected	Aynan bitta userda 60 sekund ichida 5 fail + success korrelyatsiyasi true.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Precision/recall hisoblash korrelyatsiya qoidasi yozilganini isbotlamaydi.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: positive/negative tests va korrelyatsiya oynasi. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: NIST 800-61r3 incident response’ni CSF 2.0 risk managementga bog‘laydi. Hodisa sodir bo‘lgandan so‘ng

Texnik izoh: Precision/recall hisoblash korrelyatsiya qoidasi yozilganini isbotlamaydi. Sigma qoidasi selection/filter/condition bilan log patternlarini tavsiflaydi. Ko‘p marta muvaffaqiyatsiz login, so‘ng muvaffaqiyatli kirishni bitta user va vaqt oynasida korrelyatsiya qilish zarur.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

38-hafta / Hisobot va challenge

10-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Sigma-style detection

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Sigma & correlation” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Sigma & correlation. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: positive/negative tests va korrelyatsiya oynasi.
Xavfsizlik chegarasi: Faqat sun’iy loginlar; haqiqiy parol taxmin qilish yoki brute-force yo‘q.

© 2026 • Xavfsiz, ruxsatli tadqiqot • Nazariya + amaliyot

39-hafta / Threat hunting

10-OY • SOC, SIEM, XDR va detection engineering | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Hypothesis→data source→query→evidence→assessment; living off the land signal.

Asosiy tushuncha

Threat hunting oldindan yozilgan gipoteza va dalillar bilan ishlaydi. MITRE ATT&CK technique ID hukm emas, faqat xatti-harakat tasnifi; soxta ijobiy holat va sensor qamrovini yozish kerak.

Tayanch atamalarni ajratamiz

1. hypothesis	Tekshiriladigan tahdid xatti-harakati haqida konkret faraz.
2. data source	Farazni tasdiqlashga yaroqli log yoki telemetriya manbasi.
3. query	Aynan shu farazga bog‘liq eventlarni chiqaruvchi ifoda.
4. assessment	Kuzatuv, muqobil sabab va ishonch darajasi bo‘yicha xulosa.

Keng tarqalgan chalkashlik

Aniqlik: ATT&CK mapping dalil sifatida emas, tahlil koordinatasi sifatida..

Chuqurroq konseptual tahlil

Security-first control plane request’lari tokenni tashqi proxyga chiqarmasligi, redirectda credential leak qilmasligi, TLS verify hamda tenant boundary’ni to‘g‘ri qo‘llashi kerak. Audit qoidalari read-only health check va live CrashGuard storage lock’ni to‘qnashmasligi uchun alohida hayot sikliga ega bo‘lishi mumkin.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

39-hafta / Texnik mexanizm

10-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Threat hunting oldindan yozilgan gipoteza va dalillar bilan ishlaydi. MITRE ATT&CK technique ID hukm emas, faqat xatti-harakat tasnifi; soxta ijobiy holat va sensor qamrovini yozish kerak.

sourc

hypothesis	data source	query	assessment

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
journalctl	systemd jurnalini o‘qiydi; ayrim yozuvlar uchun guruh/ruxsat kerak.
ss	Socket statistikasi va holatini mahalliy o‘qish asbobi.
ps	Mahalliy jarayonlarni ko‘rish.
sha256sum	Faylning SHA-256 digestini hisoblaydi; o‘zi xavfsizlikni isbotlamaydi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sabablardan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: ATT&CK tactic/technique mapping hujumchi guruhini mustaqil tasdiqlamaydi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: ATT&CK mapping dalil sifatida emas, tahlil koordinatasi sifatida. Natija: gipoteza, query, dalil, alternativ izoh.

39-hafta / Xavf va himoya

10-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Dual-use admin commands kontekstsiz IOC bo‘la olmaydi.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik kompрometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Hunt hypothesis notebook. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

NIST 800-61r3 incident response’ni CSF 2.0 risk managementga bog‘laydi. Hodisa sodir bo‘lgandan so‘ng bitta “antivirus bilan tozalash” yetarli emas: verify, scope, containment, recovery va lessons learned bir tizim bo‘lishi zarur.

Manba yo‘nalishi: [S07][S09][S10][S20]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Threat-hunt sintetik datasetda; jonli tenant loglarini nusxalama.

39-hafta / Amaliy mashg‘ulot A

10-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: gipoteza, query, dalil, alternativ izoh.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 39 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
events=[{'user':'lab','action':'login_failed'},{'user':'lab','action':'login_ok'}]
hits=[e for e in events if e['action']=='login_failed']
print('hunt hypothesis: repeated failed logins')
print('evidence count:',len(hits),'verdict: insufficient')
PYLAB
```

KUTILGAN NATIJA: Bir failed login yolg‘iz o‘zi gipotezani tasdiqlamaydi.
XAVFSIZLIK: Threat-hunt sintetik datasetda; jonli tenant loglarini nusxalama.

TUSHUNTIRISH: Threat hunting oldindan yozilgan gipoteza va dalillar bilan ishlaydi. MITRE ATT&CK technique ID hukm emas, faqat xatti-harakat tasnifi; soxta ijobiy holat va sensor qamrovini yozish kerak.
EHTIYOT: ATT&CK mapping dalil sifatida emas, tahlil koordinatasi sifatida.

39-hafta / Amaliy mashg‘ulot B

10-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #39, Threat hunting.
Command / tool	j Python3 (sintetik sinov)
Expected	Bir failed login yolg‘iz o‘zi gipotezani tasdiqlamaydi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	ATT&CK mapping dalil sifatida emas, tahlil koordinatasi sifatida.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: gipoteza, query, dalil, alternativ izoh. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Queue to‘lganda silent drop xavfli: loss, duplicate, ordering, backpressure va protected reserve kabi

Texnik izoh: ATT&CK mapping dalil sifatida emas, tahlil koordinatasi sifatida. Threat hunting oldindan yozilgan gipoteza va dalillar bilan ishlaydi. MITRE ATT&CK technique ID hukm emas, faqat xatti-harakat tasnifi; soxta ijobiy holat va sensor qamrovini yozish kerak.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

39-hafta / Hisobot va challenge

10-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Hunt hypothesis notebook

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Threat hunting” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Threat hunting. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: gipoteza, query, dalil, alternativ izoh.
Xavfsizlik chegarasi: Threat-hunt sintetik datasetda; jonli tenant loglarini nusxalama.

40-hafta / Safe automated response

10-OY • SOC, SIEM, XDR va detection engineering | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Approval gates, owner/operator role, quarantine safety, rollback, tamper-evident logs.

Asosiy tushuncha

Avtomatlashtirilgan javobda ruxsat, qurilma egasi, tasdiqlash, rollback va blast-radius chegaralari bo‘lishi kerak. Shubhali signalni darhol qurilmani uzishga aylantirish xizmat uzilishiga olib keladi.

Tayanch atamalarni ajratamiz

1. approval gate	Riskli javobdan oldin vakolatli tasdiqlash sharti.
2. dry-run	Haqiqiy o‘zgarishsiz kutiladigan qarorni sinash rejimi.
3. rollback	Bajarilgan nazoratli o‘zgarishni avvalgi holatga qaytarish.
4. fail-closed	Tekshiruv yoki telemetriya yo‘q bo‘lsa xavfsiz cheklov holatida qolish.

Keng tarqalgan chalkashlik

Aniqlik: Telemetry unavailable bo‘lsa 'healthy' qaytarmaslik kerak..

Chuqurroq konseptual tahlil

Detektor alert qilganda avtomatik host isolate har doim ham to‘g‘ri emas. Muhim server, tibbiy/OT tuguni yoki business critical xizmatga xavf yetishi mumkin. Buning uchun response gate, allowlist, role approval, stop condition va rollback talab etiladi.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

40-hafta / Texnik mexanizm

10-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Avtomatlashtirilgan javobda ruxsat, qurilma egasi, tasdiqlash, rollback va blast-radius chegaralari bo‘lishi kerak. Shubhali signalni darhol qurilmani uzishga aylantirish xizmat uzilishiga olib keladi.

approval gate	dry-run	rollback	fail-closed

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
git status	Lokal Git ishchi katalogi holatini o‘qiydi.
sha256sum	Faylning SHA-256 digestini hisoblaydi; o‘zi xavfsizlikni isbotlamaydi.
systemctl status	systemd service status; runtime operatsionligini isbotlamaydi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: IR “isolate” qarori OT/critical serverlarda biznes uzilishiga sabab bo‘lishi mumkin. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Telemetry unavailable bo‘lsa 'healthy' qaytarmaslik kerak. Natija: approval, plan, rollback va failed-gate testlar.

40-hafta / Xavf va himoya

10-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Haqiqiy agentni auto-remediate qilishdan avval rollback PASS.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik kompрometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: XDR response governance. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Queue to‘lganda silent drop xavfli: loss, duplicate, ordering, backpressure va protected reserve kabi holatlar biznes safety qaroriga ta’sir qiladi. Fail-closed prinsipida “unknown” yoki “degraded” alohida holat bo‘lib, UI uni “healthy”ga tenglashtirmaydi.

Manba yo‘nalishi: [S07][S09][S10][S20]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Avtomatik karantin/servis to‘xtatish ishlatilmaydi.

40-hafta / Amaliy mashg‘ulot A

10-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: approval, plan, rollback va failed-gate testlar.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 40 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
def respond(signal,approved=False,dry_run=True):
 if signal!='confirmed' or not approved: return 'DENY'
 return 'PLAN' if dry_run else 'NEEDS_MANUAL_EXECUTION'
assert respond('suspected')=='DENY'
assert respond('confirmed',True)=='PLAN'
print('safe response gates: PASS')
PYLAB
```

KUTILGAN NATIJA: Tasdiqsiz DENY; tasdiqli quruq sinov PLAN. Real host o‘chirilmaydi.
XAVFSIZLIK: Avtomatik karantin/servis to‘xtatish ishlatilmaydi.

TUSHUNTIRISH: Avtomatlashtirilgan javobda ruxsat, qurilma egasi, tasdiqlash, rollback va blast-radius chegaralari bo‘lishi kerak. Shubhali signalni darhol qurilmani uzishga aylantirish xizmat uzilishiga olib keladi.
EHTIYOT: Telemetry unavailable bo‘lsa 'healthy' qaytarmaslik kerak.

40-hafta / Amaliy mashg‘ulot B

10-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #40, Safe automated response.
Command / tool	Python3 (sintetik sinov)
Expected	Tasdiqsiz DENY; tasdiqli quruq sinov PLAN. Real host o‘chirilmaydi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Telemetry unavailable bo‘lsa 'healthy' qaytarmaslik kerak.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: approval, plan, rollback va failed-gate testlar. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Rule lifecycle: hypothesis → data contract → draft → test fixture → unit test → shadow rollout → monitor →

Texnik izoh: Telemetry unavailable bo‘lsa 'healthy' qaytarmaslik kerak. Avtomatlashtirilgan javobda ruxsat, qurilma egasi, tasdiqlash, rollback va blast-radius chegaralari bo‘lishi kerak. Shubhali signalni darhol qurilmani uzishga aylantirish xizmat uzilishiga olib keladi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

40-hafta / Hisobot va challenge

10-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

XDR response governance

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Safe automated response” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Safe automated response. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: approval, plan, rollback va failed-gate testlar.
Xavfsizlik chegarasi: Avtomatik karantin/servis to‘xtatish ishlatilmaydi.

41-hafta / Disk/log forensics

11-OY • Digital forensics, threat intelligence va history | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Preservation, chain of custody, hashing, filesystem timeline, volatile vs persistent evidence.

Asosiy tushuncha

Digital forensics faylni asrab olish, dalil yaxlitligini tekshirish, vaqt zonasini qayd etish va takrorlanadigan tahlilni talab qiladi. Hash dalil kontentini kuzatadi, lekin o‘zi kelib chiqishni isbotlamaydi.

Tayanch atamalarni ajratamiz

1. preservation	Dalil kontentini o‘zgartirmasdan saqlash tamoyili.
2. chain of custody	Kim qachon qabul qilganini qayd qiluvchi jurnal.
3. filesystem timeline	Fayl yaratish, o‘zgartirish va ko‘rish vaqtlari xaritasi.
4. hash manifest	Fayl nomlari va SHA-256 qiymatlarining tekshiruv ro‘yxati.

Keng tarqalgan chalkashlik

Aniqlik: mtime/ctime tushunchalari OSga bog‘liq.

Chuqurroq konseptual tahlil

Threat intelligence IOC (hash, domain, IP) dan tashqari TTP, victimology, campaign context va adversary capability’ni o‘z ichiga oladi. IP blacklist tez eskirishi mumkin; authentication misuse yoki supply-chain compromise kabi behavior pattern’lar ko‘proq umumlashadi.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

41-hafta / Texnik mexanizm

11-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Digital forensics faylni asrab olish, dalil yaxlitligini tekshirish, vaqt zonasini qayd etish va takrorlanadigan tahlilni talab qiladi. Hash dalil kontentini kuzatadi, lekin o‘zi kelib chiqishni isbotlamaydi.

preservation	chain of custody	filesystem timeline	hash manifest

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
sha256sum	Faylning SHA-256 digestini hisoblaydi; o‘zi xavfsizlikni isbotlamaydi.
stat -c	Fayl metadata maydonlarini maxsus formatda chiqaradi.
date -u +%FT%TZ	UTC vaqti ISO ko‘rinishda; dalil timestamp uchun.
journalctl	systemd jurnalini o‘qiydi; ayrim yozuvlar uchun guruh/ruxsat kerak.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sabablardan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: STRIDE xatar turini beradi; controls va asset mapping bo‘lmasa ro‘yxat yetarli emas. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: mtime/ctime tushunchalari OSga bog‘liq; bitta timestamp yetarli emas. Natija: chain of custody jadvali va hash OK.

41-hafta / Xavf va himoya

11-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Evidence ochilganda originalni o‘zgartirmaslik.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Chain-of-custody sheet. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

APT va RaaS guruhlari nomi vendorlarga qarab almashishi mumkin. Hukumat advisory “we assess” kabi iboralar ehtimoliy atribusiya darajasini ko‘rsatadi. Bir guruhning taxallusi bilan dunyodagi ma’lum shaxsni bog‘lash uchun mustaqil huquqiy va texnik dalillar zarur.

Manba yo‘nalishi: [S07][S09][S22][S23][S24][S26][S28]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Fayl tizimidagi real dalillar ustida test o‘tkazmaymiz; o‘zing yaratgan fayl.

41-hafta / Amaliy mashg‘ulot A

11-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: chain of custody jadvali va hash OK.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 41 | Mavzuga mos amaliyot

```
mkdir -p ~/ehs/week41
printf 'forensic-lab\n' > ~/ehs/week41/sample.txt
stat ~/ehs/week41/sample.txt
sha256sum ~/ehs/week41/sample.txt > ~/ehs/week41/checksums.txt
sha256sum -c ~/ehs/week41/checksums.txt
```

KUTILGAN NATIJA: Yangi synthetic dalil uchun timestamp va hash manifest; tekshiruv OK.
XAVFSIZLIK: Fayl tizimidagi real dalillar ustida test o‘tkazmaymiz; o‘zing yaratgan fayl.

TUSHUNTIRISH: Digital forensics faylni asrab olish, dalil yaxlitligini tekshirish, vaqt zonasini qayd etish va takrorlanadigan tahlilni talab qiladi. Hash dalil kontentini kuzatadi, lekin o‘zi kelib chiqishni isbotlamaydi.
EHTIYOT: mtime/ctime tushunchalari OSga bog‘liq; bitta timestamp yetarli emas.

41-hafta / Amaliy mashg‘ulot B

11-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #41, Disk/log forensics.
Command / tool	Linux terminal / ruxsatli lokal sinov
Expected	Yangi synthetic dalil uchun timestamp va hash manifest; tekshiruv OK.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	mtime/ctime tushunchalari OSga bog‘liq; bitta timestamp yetarli emas.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: chain of custody jadvali va hash OK. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Recoveryda original root cause, revoked compromised credentials, clean rebuild, vulnerability fixed,

Texnik izoh: mtime/ctime tushunchalari OSga bog‘liq; bitta timestamp yetarli emas. Digital forensics faylni asrab olish, dalil yaxlitligini tekshirish, vaqt zonasini qayd etish va takrorlanadigan tahlilni talab qiladi. Hash dalil kontentini kuzatadi, lekin o‘zi kelib chiqishni isbotlamaydi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

41-hafta / Hisobot va challenge

11-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Chain-of-custody sheet

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Disk/log forensics” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Disk/log forensics. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: chain of custody jadvali va hash OK.
Xavfsizlik chegarasi: Fayl tizimidagi real dalillar ustida test o‘tkazmaymiz; o‘zing yaratgan fayl.

© 2026 • Xavfsiz, ruxsatli tadqiqot • Nazariya + amaliyot

42-hafta / Network forensics

11-OY • Digital forensics, threat intelligence va history | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

PCAP, 5-tuple, TLS metadata, DNS correlation, benign vs malicious anomalies.

Asosiy tushuncha

Network forensics paketlar orasidagi oqimni 5-tuple, vaqt, DNS va TLS metama’lumot bilan bog‘laydi. HTTPS mazmuni TLS ishlayotganida oddiy PCAPdan o‘qilmaydi.

Tayanch atamalarni ajratamiz

1. PCAP	Tarmoq paketlari yozilgan fayl formati.
2. 5-tuple	src IP/port, dst IP/port va transport protokoli.
3. TLS metadata	SNI, sertifikat va vaqt kabi mumkin bo‘lgan qo‘shimcha ma’lumotlar.
4. flow correlation	Bir aloqa oqimidagi hodisalarni vaqt/manzilga qarab bog‘lash.

Keng tarqalgan chalkashlik

Aniqlik: Bir IP manzilga ikkita ulanish bitta session degani emas..

Chuqurroq konseptual tahlil

Dalillar bilan ishlashda time-zone, wall-clock drift, NTP holati, host identity, acquisition agent version va hash manifest qayd etiladi. Bir vaqtning o‘zida uch manbadan yig‘ilgan loglarda timestamp turli granularity bo‘lishi mumkin; timeline’ni qayta qurishda shuni ochiq yozish kerak.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

42-hafta / Texnik mexanizm

11-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Network forensics paketlar orasidagi oqimni 5-tuple, vaqt, DNS va TLS metama’lumot bilan bog‘laydi. HTTPS mazmuni TLS ishlayotganida oddiy PCAPdan o‘qilmaydi.

PCAP	5-tuple	TLS metadata	flow correlation

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
tshark -r sample.pcap	Mavjud PCAPni offline o‘qiydi; sample.pcap bo‘lishi kerak.
tcpdump -r sample.pcap	Saqlangan paket faylini o‘qiydi; jonli trafik yo‘q.
capinfos	PCAP fayl metadata, vaqt va paket sonini ko‘rsatadi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Adversary emulation — kelishilgan harmless test bo‘lib, unauthorized exploitation emas. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Bir IP manzilga ikkita ulanish bitta session degani emas. Natija: flow jadvali, timestamp cheklovlari.

42-hafta / Xavf va himoya

11-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Encrypted trafficda payloadsiz ham metadata foydali.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Network forensic timeline. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Recoveryda original root cause, revoked compromised credentials, clean rebuild, vulnerability fixed, monitoring restored, backup validated va user reentry approval ketma-ketligi kerak. “Server ishga tushdi” degani “biznes tiklandi” emas.

Manba yo‘nalishi: [S07][S09][S22][S23][S24][S26][S28]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Begona LAN/Wi-Fi trafikini ushlama; ushbu misol offline.

42-hafta / Amaliy mashg‘ulot A

11-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: flow jadvali, timestamp cheklovlari.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 42 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
flows=[('127.0.0.1',55000,'127.0.0.1',8000,'TCP'),
       ('127.0.0.1',55001,'127.0.0.1',8000,'TCP')]
for flow in flows: print('5-tuple:',flow)
print('flow count:',len(flows))
PYLAB
```

KUTILGAN NATIJA: Ikki sintetik TCP flow va ularning 5-tuple maydonlari ajratiladi.
XAVFSIZLIK: Begona LAN/Wi-Fi trafikini ushlama; ushbu misol offline.

TUSHUNTIRISH: Network forensics paketlar orasidagi oqimni 5-tuple, vaqt, DNS va TLS metama’lumot bilan bog‘laydi. HTTPS mazmuni TLS ishlayotganida oddiy PCAPdan o‘qilmaydi.
EHTIYOT: Bir IP manzilga ikkita ulanish bitta session degani emas.

42-hafta / Amaliy mashg‘ulot B

11-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #42, Network forensics.
Command / tool	t Python3 (sintetik sinov)
Expected	Ikki sintetik TCP flow va ularning 5-tuple maydonlari ajratiladi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Bir IP manzilga ikkita ulanish bitta session degani emas.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: flow jadvali, timestamp cheklovlari. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Threat intelligence IOC (hash, domain, IP) dan tashqari TTP, victimology, campaign context va adversary

Texnik izoh: Bir IP manzilga ikkita ulanish bitta session degani emas. Network forensics paketlar orasidagi oqimni 5-tuple, vaqt, DNS va TLS metama’lumot bilan bog‘laydi. HTTPS mazmuni TLS ishlayotganida oddiy PCAPdan o‘qilmaydi.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

42-hafta / Hisobot va challenge

11-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Network forensic timeline

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Network forensics” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Network forensics. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: flow jadvali, timestamp cheklovlari.
Xavfsizlik chegarasi: Begona LAN/Wi-Fi trafikini ushlama; ushbu misol offline.

43-hafta / Threat intelligence & attribution

11-OY • Digital forensics, threat intelligence va history | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

IOC/TTP, confidence, STIX/TAXII, source reliability, false attribution.

Asosiy tushuncha

Threat intelligence manbani, indikatorni, kuzatuv vaqtini va ishonch darajasini ajratadi. Bir xil domen ko‘plab xizmatlarda ishlatilishi mumkin; shaxs yoki guruhni isbotsiz ayblash noto‘g‘ri.

Tayanch atamalarni ajratamiz

1. IOC/TTP	IOC kuzatuv belgisi; TTP xatti-harakat usuli va jarayonlari.
2. confidence	Xulosa dalillarining mustaqilligi va ishonchliligini baholash.
3. STIX/TAXII	Threat intel ma’lumotini tuzish va almashish standartlari.
4. attribution	Hodisaning ehtimoliy ijrochisini ehtiyotkor dalillar bilan bog‘lash.

Keng tarqalgan chalkashlik

Aniqlik: Bitta IOC bilan aniq tahdid guruhini tasdiqlash mumkin emas..

Chuqurroq konseptual tahlil

APT va RaaS guruhlari nomi vendorlarga qarab almashishi mumkin. Hukumat advisory “we assess” kabi iboralar ehtimoliy atribusiya darajasini ko‘rsatadi. Bir guruhning taxallusi bilan dunyodagi ma’lum shaxsni bog‘lash uchun mustaqil huquqiy va texnik dalillar zarur.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

43-hafta / Texnik mexanizm

11-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Threat intelligence manbani, indikatorni, kuzatuv vaqtini va ishonch darajasini ajratadi. Bir xil domen ko‘plab xizmatlarda ishlatilishi mumkin; shaxs yoki guruhni isbotsiz ayblash noto‘g‘ri.

IOC/TTP	confidence	STIX/TAXII	attribution

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
jq .	JSONni formatlaydi yoki jq ifodasi bilan filtrlaydi.
sha256sum	Faylning SHA-256 digestini hisoblaydi; o‘zi xavfsizlikni isbotlamaydi.
git diff	Commit qilinmagan o‘zgarishlarni ko‘rsatadi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Finding risk — reproducibility, preconditions, impact va mitigation kombinatsiyasi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Bitta IOC bilan aniq tahdid guruhini tasdiqlash mumkin emas. Natija: source/indicator/time/confidence matritsasi.

43-hafta / Xavf va himoya

11-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

“Ushlanmagan” ≠ “topib bo‘lmaydi”; davlatlararo yurisdiksiya muhim.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Threat intel brief. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Threat intelligence IOC (hash, domain, IP) dan tashqari TTP, victimology, campaign context va adversary capability’ni o‘z ichiga oladi. IP blacklist tez eskirishi mumkin; authentication misuse yoki supply-chain compromise kabi behavior pattern’lar ko‘proq umumlashadi.

Manba yo‘nalishi: [S07][S09][S22][S23][S24][S26][S28]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Real shaxslar haqida taxminiy ayblov e’lon qilma.

43-hafta / Amaliy mashg‘ulot A

11-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: source/indicator/time/confidence matritsasi.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 43 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
intel=[{'indicator':'example.com','source':'synthetic','confidence':'low'}]
for x in intel:
 print(x['indicator'],'->',x['confidence'])
assert all(x['source']=='synthetic' for x in intel)
PYLAB
```

KUTILGAN NATIJA: Indicator sintetik va LOW confidence bo‘lib qoladi.
XAVFSIZLIK: Real shaxslar haqida taxminiy ayblov e’lon qilma.

TUSHUNTIRISH: Threat intelligence manbani, indikatorni, kuzatuv vaqtini va ishonch darajasini ajratadi. Bir xil domen ko‘plab xizmatlarda ishlatilishi mumkin; shaxs yoki guruhni isbotsiz ayblash noto‘g‘ri.
EHTIYOT: Bitta IOC bilan aniq tahdid guruhini tasdiqlash mumkin emas.

43-hafta / Amaliy mashg‘ulot B

11-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #43, Threat intelligence & attribution.
Command / tool	j Python3 (sintetik sinov)
Expected	Indicator sintetik va LOW confidence bo‘lib qoladi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Bitta IOC bilan aniq tahdid guruhini tasdiqlash mumkin emas.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: source/indicator/time/confidence matritsasi. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Dalillar bilan ishlashda time-zone, wall-clock drift, NTP holati, host identity, acquisition agent version va

Texnik izoh: Bitta IOC bilan aniq tahdid guruhini tasdiqlash mumkin emas. Threat intelligence manbani, indikatorni, kuzatuv vaqtini va ishonch darajasini ajratadi. Bir xil domen ko‘plab xizmatlarda ishlatilishi mumkin; shaxs yoki guruhni isbotsiz ayblash noto‘g‘ri.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

43-hafta / Hisobot va challenge

11-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Threat intel brief

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Threat intelligence & attribution” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Threat intelligence & attribution. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: source/indicator/time/confidence matritsasi.
Xavfsizlik chegarasi: Real shaxslar haqida taxminiy ayblov e’lon qilma.

© 2026 • Xavfsiz, ruxsatli tadqiqot • Nazariya + amaliyot

44-hafta / Malware tarixiy case studies

11-OY • Digital forensics, threat intelligence va history | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Morris, ILOVEYOU, WannaCry, NotPetya, SolarWinds, LockBit, Volt Typhoon.

Asosiy tushuncha

Tarixiy incidentlar bo‘yicha dalil manbasi, vaqt, ta’sir va himoya xulosasini ajrating. WannaCry va NotPetya bir yilda paydo bo‘lgan bo‘lsa-da, zararli maqsad va real oqibatlari turlicha.

Tayanch atamalarni ajratamiz

1. case study	Muayyan tarixiy hodisani dalillar va natijalar bilan o‘rganish.
2. initial vector	Dastlabki kirish yo‘li; ishonch darajasi qayd etiladi.
3. business impact	Tashkilotga ish, moliya yoki ma’lumot jihatidan ta’sir.
4. lessons learned	Ustuvor patch, segmentatsiya, zaxira va monitoring saboqlari.

Keng tarqalgan chalkashlik

Aniqlik: Bitta manbaning talqini atributsiyani to‘liq tasdiqlamaydi..

Chuqurroq konseptual tahlil

Recoveryda original root cause, revoked compromised credentials, clean rebuild, vulnerability fixed, monitoring restored, backup validated va user reentry approval ketma-ketligi kerak. “Server ishga tushdi” degani “biznes tiklandi” emas.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

44-hafta / Texnik mexanizm

11-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Tarixiy incidentlar bo‘yicha dalil manbasi, vaqt, ta’sir va himoya xulosasini ajrating. WannaCry va NotPetya bir yilda paydo bo‘lgan bo‘lsa-da, zararli maqsad va real oqibatlari turlicha.

case study	initial vector	business impact	lessons learned

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
cat	Fayl matnini stdoutga ko‘rsatadi; maxfiy faylni ko‘rsatishda ehtiyot.
grep	Bu buyruq uchun --help/man sahifasidan variant, kirish va chiqishni tekshiring; faqat ruxsatli muhitda.
python3 -m json.tool	JSON matnining sintaksisini tekshiradi/formatlaydi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Purple Teamda bitta detected eventdan o‘ta katta xulosa chiqarmang. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Bitta manbaning talqini atributsiyani to‘liq tasdiqlamaydi. Natija: sana, manba, mexanizm, zarar, himoya sabog‘i.

44-hafta / Xavf va himoya

11-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Published facts va tergov atribusiyasini alohida belgilash.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Historical incident review. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Dalillar bilan ishlashda time-zone, wall-clock drift, NTP holati, host identity, acquisition agent version va hash manifest qayd etiladi. Bir vaqtning o‘zida uch manbadan yig‘ilgan loglarda timestamp turli granularity bo‘lishi mumkin; timeline’ni qayta qurishda shuni ochiq yozish kerak.

Manba yo‘nalishi: [S07][S09][S22][S23][S24][S26][S28]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Bu ilmiy tahlil, real zararli kodni qayta yaratish emas.

44-hafta / Amaliy mashg‘ulot A

11-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: sana, manba, mexanizm, zarar, himoya sabog‘i.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 44 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
cases=[('WannaCry','2017','patching'),('NotPetya','2017','recovery'),('SolarWinds','2020','supply-cha
in')]
for name,year,lesson in cases: print(name,year,lesson)
PYLAB
```

KUTILGAN NATIJA: 3 ta tarixiy misol uchun yil va himoya sabog‘i jadvali tuziladi.
XAVFSIZLIK: Bu ilmiy tahlil, real zararli kodni qayta yaratish emas.

TUSHUNTIRISH: Tarixiy incidentlar bo‘yicha dalil manbasi, vaqt, ta’sir va himoya xulosasini ajrating. WannaCry va NotPetya bir yilda paydo bo‘lgan bo‘lsa-da, zararli maqsad va real oqibatlari turlicha.
EHTIYOT: Bitta manbaning talqini atributsiyani to‘liq tasdiqlamaydi.

44-hafta / Amaliy mashg‘ulot B

11-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #44, Malware tarixiy case studies.
Command / tool	Python3 (sintetik sinov)
Expected	3 ta tarixiy misol uchun yil va himoya sabog‘i jadvali tuziladi.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Bitta manbaning talqini atributsiyani to‘liq tasdiqlamaydi.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: sana, manba, mexanizm, zarar, himoya sabog‘i. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: APT va RaaS guruhlari nomi vendorlarga qarab almashishi mumkin. Hukumat advisory “we assess” kabi

Texnik izoh: Bitta manbaning talqini atributsiyani to‘liq tasdiqlamaydi. Tarixiy incidentlar bo‘yicha dalil manbasi, vaqt, ta’sir va himoya xulosasini ajrating. WannaCry va NotPetya bir yilda paydo bo‘lgan bo‘lsa-da, zararli maqsad va real oqibatlari turlicha.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

44-hafta / Hisobot va challenge

11-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Historical incident review

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Malware tarixiy case studies” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Malware tarixiy case studies. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: sana, manba, mexanizm, zarar, himoya sabog‘i.
Xavfsizlik chegarasi: Bu ilmiy tahlil, real zararli kodni qayta yaratish emas.

45-hafta / Pentest reporting

12-OY • Professional faoliyat va yakuniy portfel | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Scope, methodology, executive summary, finding, reproduction evidence, impact, mitigation, retest.

Asosiy tushuncha

Professional pentest hisobot biznes egasi o‘qiy oladigan xavf tavsifi va texnik mutaxassis takrorlay oladigan minimal dalilni birlashtiradi. Findingda 'expected vs actual' bo‘lishi zarur.

Tayanch atamalarni ajratamiz

1. scope	Tekshiruvdan o‘tgan aniq aktivlar va cheklovlar.
2. finding	Zaiflik, uning dalili, ta’siri va remediatsiyasi to‘plami.
3. severity	Ehtimol va ta’sirga tayangan ustuvorlik.
4. retest	Tuzatish haqiqatan ishlashini qayta tekshirish.

Keng tarqalgan chalkashlik

Aniqlik: 'Scan PASS' degani real remediation sinovidan o‘tgan degani emas..

Chuqurroq konseptual tahlil

Pentesterlar aniq ruxsatli scope ichida zaiflikni topib riskini isbotlaydi; Red Team muayyan tashkilotning defense samaradorligini realistik ssenariy bilan baholaydi; Blue Team esa monitoring, incident response, recovery va threat huntingni yuritadi. Purple Team ularni umumiy test/detection feedback loopiga bog‘laydi.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

45-hafta / Texnik mexanizm

12-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Professional pentest hisobot biznes egasi o‘qiy oladigan xavf tavsifi va texnik mutaxassis takrorlay oladigan minimal dalilni birlashtiradi. Findingda 'expected vs actual' bo‘lishi zarur.

scope	finding	severity	retest

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
git diff	Commit qilinmagan o‘zgarishlarni ko‘rsatadi.
sha256sum	Faylning SHA-256 digestini hisoblaydi; o‘zi xavfsizlikni isbotlamaydi.
date -Is	Joriy vaqtni ISO-8601 va zona bilan chiqaradi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Written authorization va stop condition professional ishning huquqiy chegara nuqtasi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: 'Scan PASS' degani real remediation sinovidan o‘tgan degani emas. Natija: executive summary + texnik finding + retest shabloni.

45-hafta / Xavf va himoya

12-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Findingni “isbotlandi/aniqlanmadi/noaniq” deb ajrat.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Pentest report v1. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Sertifikatlar ma’lum yo‘lni tartiblaydi, lekin ish tajribasini to‘liq almashtirmaydi. Network+/Security+ kabi nazariy poydevor, eJPT kabi entry-level amaliyot, keyin OSCP, web security, cloud/DFIR yoki detection engineering ixtisoslashuvi. Har birini moliyaviy qiymat va bo‘sh vaqtga mos o‘rganing.

Manba yo‘nalishi: [S12][S05][S09][S10]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Real zaiflik topilgan deb yozma; finding sintetikligi belgilansin.

45-hafta / Amaliy mashg‘ulot A

12-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: executive summary + texnik finding + retest shabloni.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 45 | Mavzuga mos amaliyot

```
mkdir -p ~/ehs/week45
cat > ~/ehs/week45/finding.txt <<'EOF'
Asset: localhost test server
Finding: synthetic configuration note
Expected: bound to 127.0.0.1
Actual: verify with ss -ltn
Fix: keep loopback binding
Retest: listener address is 127.0.0.1
EOF
cat ~/ehs/week45/finding.txt
```

KUTILGAN NATIJA: Hisobotda asset, expected, actual, fix va retest alohida satrda.
XAVFSIZLIK: Real zaiflik topilgan deb yozma; finding sintetikligi belgilansin.

TUSHUNTIRISH: Professional pentest hisobot biznes egasi o‘qiy oladigan xavf tavsifi va texnik mutaxassis takrorlay oladigan minimal dalilni birlashtiradi. Findingda 'expected vs actual' bo‘lishi zarur.
EHTIYOT: 'Scan PASS' degani real remediation sinovidan o‘tgan degani emas.

45-hafta / Amaliy mashg‘ulot B

12-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #45, Pentest reporting.
Command / tool	Linux terminal / ruxsatli lokal sinov
Expected	Hisobotda asset, expected, actual, fix va retest alohida satrda.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	'Scan PASS' degani real remediation sinovidan o‘tgan degani emas.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: executive summary + texnik finding + retest shabloni. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Autonomous response tamper-evident audit, operator approval, test vector, rollback, deployment hold va

Texnik izoh: 'Scan PASS' degani real remediation sinovidan o‘tgan degani emas. Professional pentest hisobot biznes egasi o‘qiy oladigan xavf tavsifi va texnik mutaxassis takrorlay oladigan minimal dalilni birlashtiradi. Findingda 'expected vs actual' bo‘lishi zarur.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

45-hafta / Hisobot va challenge

12-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Pentest report v1

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Pentest reporting” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Pentest reporting. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: executive summary + texnik finding + retest shabloni.
Xavfsizlik chegarasi: Real zaiflik topilgan deb yozma; finding sintetikligi belgilansin.

© 2026 • Xavfsiz, ruxsatli tadqiqot • Nazariya + amaliyot

46-hafta / Purple team exercise

12-OY • Professional faoliyat va yakuniy portfel | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Red side hypotheses, Blue side detections, purple feedback, outcome measures.

Asosiy tushuncha

Purple Team Red tarafdagi gipoteza va Blue tarafdagi aniqlash signalini bog‘laydi. Nazorat qilinadigan test telemetriyani tekshirishi, zarar yetkazmasligi va rollback rejasiga ega bo‘lishi kerak.

Tayanch atamalarni ajratamiz

1. Red hypothesis	Tekshiriladigan hujumchi xatti-harakati modeli.
2. Blue detection	Aniq telemetriya manbaida ishlaydigan qoida/signal.
3. feedback loop	Test natijasiga ko‘ra qoidani aniqlashtirish va qayta sinash.
4. rollback	Sinov tugagach normal holatga qaytish sharti.

Keng tarqalgan chalkashlik

Aniqlik: Purple Team muvaffaqiyati faqat hujum muvaffaqiyati emas, detection sifati ham.

Chuqurroq konseptual tahlil

Queue to‘lganda silent drop xavfli: loss, duplicate, ordering, backpressure va protected reserve kabi holatlar biznes safety qaroriga ta’sir qiladi. Fail-closed prinsipida “unknown” yoki “degraded” alohida holat bo‘lib, UI uni “healthy”ga tenglashtirmaydi.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

46-hafta / Texnik mexanizm

12-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Purple Team Red tarafdagi gipoteza va Blue tarafdagi aniqlash signalini bog‘laydi. Nazorat qilinadigan test telemetriyani tekshirishi, zarar yetkazmasligi va rollback rejasiga ega bo‘lishi kerak.

Red hypothesis	Blue detection	feedback loop	rollback

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
pytest -q	Lokal testlarni ishga tushiradi; test kodini avval tekshir.
jq .	JSONni formatlaydi yoki jq ifodasi bilan filtrlaydi.
journalctl	systemd jurnalini o‘qiydi; ayrim yozuvlar uchun guruh/ruxsat kerak.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Agent `running` bo‘lishi pipeline ACK, tenant va fresh heartbeat sog‘lomligini kafolatlamaydi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Purple Team muvaffaqiyati faqat hujum muvaffaqiyati emas, detection sifati hamdir. Natija: scenario, signal, FP, corrective action va retest.

46-hafta / Xavf va himoya

12-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

False-positive cost va false-negative risk ham hisoblanadi.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik kompрometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Purple team exercise book. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Autonomous response tamper-evident audit, operator approval, test vector, rollback, deployment hold va emergency disable bilan nazorat qilinadi. Birgina “adversary-like” eventga javoban yirik korporativ tarmoqni o‘chirib qo‘yish xavfsizlik emas.

Manba yo‘nalishi: [S12][S05][S09][S10]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Real tarmoqda brute-force yoki xizmatni izdan chiqarish simulyatsiyasi yo‘q.

46-hafta / Amaliy mashg‘ulot A

12-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: scenario, signal, FP, corrective action va retest.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 46 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
logs=[{'kind':'failed_login','count':4},{'kind':'failed_login','count':6}]
for l in logs:
 print('alert:',l['count']>=5)
print('no real login attempt performed')
PYLAB
```

KUTILGAN NATIJA: 4 urinish false, 6 urinish true; hammasi sintetik event.
XAVFSIZLIK: Real tarmoqda brute-force yoki xizmatni izdan chiqarish simulyatsiyasi yo‘q.

TUSHUNTIRISH: Purple Team Red tarafdagi gipoteza va Blue tarafdagi aniqlash signalini bog‘laydi. Nazorat qilinadigan test telemetriyani tekshirishi, zarar yetkazmasligi va rollback rejasiga ega bo‘lishi kerak.
EHTIYOT: Purple Team muvaffaqiyati faqat hujum muvaffaqiyati emas, detection sifati hamdir.

46-hafta / Amaliy mashg‘ulot B

12-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #46, Purple team exercise.
Command / tool	Python3 (sintetik sinov)
Expected	4 urinish false, 6 urinish true; hammasi sintetik event.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Purple Team muvaffaqiyati faqat hujum muvaffaqiyati emas, detection sifati hamdir.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: scenario, signal, FP, corrective action va retest. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Pentesterlar aniq ruxsatli scope ichida zaiflikni topib riskini isbotlaydi; Red Team muayyan tashkilotning

Texnik izoh: Purple Team muvaffaqiyati faqat hujum muvaffaqiyati emas, detection sifati hamdir. Purple Team Red tarafdagi gipoteza va Blue tarafdagi aniqlash signalini bog‘laydi. Nazorat qilinadigan test telemetriyani tekshirishi, zarar yetkazmasligi va rollback rejasiga ega bo‘lishi kerak.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

46-hafta / Hisobot va challenge

12-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Purple team exercise book

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Purple team exercise” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Purple team exercise. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: scenario, signal, FP, corrective action va retest.
Xavfsizlik chegarasi: Real tarmoqda brute-force yoki xizmatni izdan chiqarish simulyatsiyasi yo‘q.

47-hafta / Enterprise architecture

12-OY • Professional faoliyat va yakuniy portfel | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Tenant isolation, RBAC, telemetry queue, signing, health, fail-closed, backup/recovery.

Asosiy tushuncha

Enterprise XDR arxitekturasi tenant isolation, agent sog‘lig‘i, spool, ACK, imzo va boshqariladigan javobni ko‘zda tutadi. 'Agent running' holati 'runtime operational' holatiga teng emas.

Tayanch atamalarni ajratamiz

1. tenant isolation	Bitta mijozning telemetriya va vakolatlari boshqasidan ajratilishi.
2. bounded queue	Xotira/spool chegarasi oshganda aniq xatolik yoki backpressure.
3. ACK/replay	Voqea qabul qilinganini tasdiqlash va qayta yetkazish tartibi.
4. fail-closed health	Tekshiruv amalga oshmasa HEALTHY deb noto‘g‘ri ko‘rsatmaslik.

Keng tarqalgan chalkashlik

Aniqlik: Service RUNNING bo‘lgani yakuniy telemetriya ACK borligini isbotlamaydi..

Chuqurroq konseptual tahlil

Sertifikatlar ma’lum yo‘lni tartiblaydi, lekin ish tajribasini to‘liq almashtirmaydi. Network+/Security+ kabi nazariy poydevor, eJPT kabi entry-level amaliyot, keyin OSCP, web security, cloud/DFIR yoki detection engineering ixtisoslashuvi. Har birini moliyaviy qiymat va bo‘sh vaqtga mos o‘rganing.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

47-hafta / Texnik mexanizm

12-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Enterprise XDR arxitekturasi tenant isolation, agent sog‘lig‘i, spool, ACK, imzo va boshqariladigan javobni ko‘zda tutadi. 'Agent running' holati 'runtime operational' holatiga teng emas.

tenant isolation	bounded queue	ACK/replay	fail-closed health

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
sha256sum	Faylning SHA-256 digestini hisoblaydi; o‘zi xavfsizlikni isbotlamaydi.
git log --oneline	Git commit tarixini qisqa formatda ko‘rsatadi.
systemctl status	systemd service status; runtime operatsionligini isbotlamaydi.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sababdan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Retest dalili bo‘lmasa remediatsiya faqat taklif maqomida qoladi. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Service RUNNING bo‘lgani yakuniy telemetriya ACK borligini isbotlamaydi. Natija: 10 arxitektura invariant + 2 salbiy test + rollback.

47-hafta / Xavf va himoya

12-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

“Agent running” ≠ “runtime operational”.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: Security architecture review. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Pentesterlar aniq ruxsatli scope ichida zaiflikni topib riskini isbotlaydi; Red Team muayyan tashkilotning defense samaradorligini realistik ssenariy bilan baholaydi; Blue Team esa monitoring, incident response, recovery va threat huntingni yuritadi. Purple Team ularni umumiy test/detection feedback loopiga bog‘laydi.

Manba yo‘nalishi: [S12][S05][S09][S10]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Faqat model: ishlab turgan agentni to‘xtatma yoki konfiguratsiyani o‘zgartirma.

47-hafta / Amaliy mashg‘ulot A

12-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: 10 arxitektura invariant + 2 salbiy test + rollback.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 47 | Mavzuga mos amaliyot

```
python3 - <<'PYLAB'
def healthy(service, runtime, ack, queue):
 return all([service,runtime,ack]) and queue<8192
assert not healthy(True,False,False,8192)
assert healthy(True,True,True,100)
print('fail-closed health invariant: PASS')
PYLAB
```

KUTILGAN NATIJA: Running, ammo runtime ishlamasa sog‘lom emas; to‘liq tekshiruvlarda true.
XAVFSIZLIK: Faqat model: ishlab turgan agentni to‘xtatma yoki konfiguratsiyani o‘zgartirma.

TUSHUNTIRISH: Enterprise XDR arxitekturasi tenant isolation, agent sog‘lig‘i, spool, ACK, imzo va boshqariladigan javobni ko‘zda tutadi. 'Agent running' holati 'runtime operational' holatiga teng emas.
EHTIYOT: Service RUNNING bo‘lgani yakuniy telemetriya ACK borligini isbotlamaydi.

47-hafta / Amaliy mashg‘ulot B

12-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #47, Enterprise architecture.
Command / tool	Python3 (sintetik sinov)
Expected	Running, ammo runtime ishlamasa sog‘lom emas; to‘liq tekshiruvlarda true.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Service RUNNING bo‘lgani yakuniy telemetriya ACK borligini isbotlamaydi.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: 10 arxitektura invariant + 2 salbiy test + rollback. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Queue to‘lganda silent drop xavfli: loss, duplicate, ordering, backpressure va protected reserve kabi

Texnik izoh: Service RUNNING bo‘lgani yakuniy telemetriya ACK borligini isbotlamaydi. Enterprise XDR arxitekturasi tenant isolation, agent sog‘lig‘i, spool, ACK, imzo va boshqariladigan javobni ko‘zda tutadi. 'Agent running' holati 'runtime operational' holatiga teng emas.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

47-hafta / Hisobot va challenge

12-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

Security architecture review

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Enterprise architecture” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Enterprise architecture. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: 10 arxitektura invariant + 2 salbiy test + rollback.
Xavfsizlik chegarasi: Faqat model: ishlab turgan agentni to‘xtatma yoki konfiguratsiyani o‘zgartirma.

© 2026 • Xavfsiz, ruxsatli tadqiqot • Nazariya + amaliyot

48-hafta / Career, ethics va capstone

12-OY • Professional faoliyat va yakuniy portfel | 1/6 TUSHUNCHA VA MOHIYAT

Bir haftalik maqsad

Report writing, vulnerability disclosure, CVE, bug bounty scope, skills portfolio va sertifikat reja.

Asosiy tushuncha

Capstone professional portfelga ruxsat, dalil, reproduksiya, remediation, retest va cheklovlarni qo‘yadi. Sertifikat emas, mustaqil amaliy ko‘nikma hujjati muhim.

Tayanch atamalarni ajratamiz

1. responsible disclosure	Topilmani egasiga ruxsatli va muvofiqlashtirilgan usulda xabar qilish.
2. CVE/bug bounty	CVE zaiflik IDsi; bounty esa alohida ruxsatli dastur qoidalari.
3. portfolio	Ish ko‘rsatadigan dalilli va qayta tekshirilgan artefaktlar to‘plami.
4. capstone	Bir necha ko‘nikmani umumiy yakuniy loyiha bilan namoyish etish.

Keng tarqalgan chalkashlik

Aniqlik: Faoliyatsiz sertifikat barcha amaliy kompetensiyalarni isbotlamaydi..

Chuqurroq konseptual tahlil

Autonomous response tamper-evident audit, operator approval, test vector, rollback, deployment hold va emergency disable bilan nazorat qilinadi. Birgina “adversary-like” eventga javoban yirik korporativ tarmoqni o‘chirib qo‘yish xavfsizlik emas.

Bilim mezoni: yuqoridagi to‘rt elementning bir-biriga bog‘liqligini internetdan buyruq ko‘chirib ishlatmasdan, o‘z so‘zlaring bilan tushuntir.

48-hafta / Texnik mexanizm

12-OY • 2/6 PROTOKOL / TIZIM QATLAMI

Nima sodir bo‘ladi?

Capstone professional portfelga ruxsat, dalil, reproduksiya, remediation, retest va cheklovlarni qo‘yadi. Sertifikat emas, mustaqil amaliy ko‘nikma hujjati muhim.

responsible disclosure	CVE/bug bounty	portfolio	capstone

Asboblarni tushunish: komandalar ma’nosi

Buyruq yoki vosita	O‘qilishi / natijasi
git status	Lokal Git ishchi katalogi holatini o‘qiydi.
python3 --version	Python interpreter versiyasini ko‘rsatadi.
nmap --version	FAQAT o‘rnatilgan Nmap dasturining versiyasini chiqaradi; tarmoq skani EMAS.

Texnik natijani qanday o‘qiymiz?

Bir xil ko‘rinadigan signal turli sabablardan kelishi mumkin. Avval kuzatuvning manbasini yoz: kernel holatimi, HTTP responsemi, log/eventmi, DNS javobimi yoki offline hisoblashmi? Keyin aynan qaysi talabga mos kelishini tekshir.

Mavzu doirasida: Portfelda haqiqiy credential, private key va uchinchi tomon ma’lumotlari bo‘lmasligi shart. Shuning uchun “tasdiqlandi” va “taxmin” maqomlarini aralashtirmang.

Professional qoida

Asbob chiqargan yagona javob bilan “zaiflik aniq bor” deyish mumkin emas. Mustaqil dalil, ruxsatli minimal reproduksiya va ta’sirni aniqlash kerak.

Mezonga bog‘langan izoh

Mavzuga mos xulosa: Faoliyatsiz sertifikat barcha amaliy kompetensiyalarni isbotlamaydi. Natija: 6 loyiha uchun source/evidence/limitation checklist.

48-hafta / Xavf va himoya

12-OY • 3/6 THREAT MODEL / DETECTION / FIX

Tizim himoyachisi qanday qaraydi?

Ruxsat, minimal ta’sir, data handling va disclosure.

Uch bosqichli tahlil

Savol	Tekshiruv mezoni
1. Zaif joy qayerda?	Asset, external interface, trust boundary, ruxsat doirasi va versiyalar xaritasi.
2. Nimani dalil deb olamiz?	Raw output, aniq timestamp, alternativ sabab, false-positive darajasi.
3. Himoya qanday ishlaydi?	Least privilege, kerakli logging, segmentatsiya, secure defaults, rollback.

Riskni noto‘g‘ri baholashdan saqlaning

• Ochiq port, ko‘rinadigan SSID yoki bitta login xatosini avtomatik komprometatsiya deb hisoblama.

• Himoya “bor/yo‘q” bilan tugamaydi: nazorat sifatini va telemetriya qamrovini bahola.

• Tekshiruv natijasini confidence: confirmed / likely / possible / unknown darajalariga ajrat.

• Mavzu materialini birgina vendor blogidan emas, rasmiy hujjat va mustaqil talqin bilan solishtir.

Oyga tegishli mustaqil natija

Professional baholash: 12 oy final portfolio. Shu dalilni oylik portfelga kiritish uchun “risk → observed evidence → mitigation → retest” ketma-ketligi talab qilinadi.

Qo‘shimcha tushuntirish

Queue to‘lganda silent drop xavfli: loss, duplicate, ordering, backpressure va protected reserve kabi holatlar biznes safety qaroriga ta’sir qiladi. Fail-closed prinsipida “unknown” yoki “degraded” alohida holat bo‘lib, UI uni “healthy”ga tenglashtirmaydi.

Manba yo‘nalishi: [S12][S05][S09][S10]. Barcha manbalar bibliografiyada berilgan.

Maxsus nazorat: Portfelga haqiqiy password, JWT, token, shaxsiy ma’lumot qo‘shma.

48-hafta / Amaliy mashg‘ulot A

12-OY • 4/6 PRE-FLIGHT / LAB / LIVE READ-ONLY

Mashq maqsadi

ANIQ MAQSAD: 6 loyiha uchun source/evidence/limitation checklist.

Bajarishdan oldin — nazorat ro‘yxati

• Buyruq tashqi qurilmaga emas, faqat o‘zingiz boshqaradigan tizimga qaratilganmi?

• Oldin va keyingi holatni qaysi read-only manba bilan solishtirasiz?

• Qaysi natija tajribani muvaffaqiyatli, qaysi natija noaniq qiladi?

Qadam-baqadam ko‘rsatmalar

• Kali Linux terminalini och, `pwd` va `whoami` natijasini qayd et.

• Test scope: faqat sintetik ma’lumot, localhost, o‘z VMing yoki bevosita read-only konfiguratsiya.

• Har qanday o‘zgarishdan oldin `~/ehs/weekXX` test papkasini alohida ajrat.

• Quyidagi komandalarni ketma-ket, izohlardagi “Yangi terminal” ajratishlariga amal qilib bajar.

TUZATILGAN LAB 48 | Mavzuga mos amaliyot

```
mkdir -p ~/ehs/week48
cat > ~/ehs/week48/README.md <<'EOF'
# Ethical Hacking Portfolio
Scope: local training systems
Evidence: sanitized only
Included: network, web, audit, detection
Unverified: label explicitly
EOF
cat ~/ehs/week48/README.md
```

KUTILGAN NATIJA: README sahifasi aniq scope va maxfiylik chekloviga ega.
XAVFSIZLIK: Portfelga haqiqiy password, JWT, token, shaxsiy ma’lumot qo‘shma.

TUSHUNTIRISH: Capstone professional portfelga ruxsat, dalil, reproduksiya, remediation, retest va cheklovlarni qo‘yadi. Sertifikat emas, mustaqil amaliy ko‘nikma hujjati muhim.
EHTIYOT: Faoliyatsiz sertifikat barcha amaliy kompetensiyalarni isbotlamaydi.

48-hafta / Amaliy mashg‘ulot B

12-OY • 5/6 NATIJANI O‘QISH / XATONI DIAGNOSTIKA

Birinchi natijani protokolga yoz

Field	To‘ldirish bo‘yicha yo‘riqnoma
Asset / scope	127.0.0.1 yoki own-VM; hafta #48, Career, ethics va capstone.
Command / tool	Linux terminal / ruxsatli lokal sinov
Expected	README sahifasi aniq scope va maxfiylik chekloviga ega.
Actual	O‘zing olgan stdout/stderr natijasini qisqacha yoz; xato bo‘lsa raw nusxani saqla.
Interpretation	Faoliyatsiz sertifikat barcha amaliy kompetensiyalarni isbotlamaydi.

Noto‘g‘ri ishlasa, qanday tekshirasiz?

• `command not found`: `command -v <tool>` yordamida asbob mavjudligini tekshir; o‘rnatish zarur bo‘lsa avval paket manbasini tekshir.

• `Permission denied`: fayl ruxsati yoki port/privilege talabini tekshir; oldin root huquqini berishga shoshilma.

• `Connection refused`: xizmat ishga tushganmi, 127.0.0.1 ga bind qilinganmi, `ss -ltnp` bilan ko‘r.

• Natija bo‘sh yoki noaniq: to‘g‘ri interface, manba fayli, port va kutilgan ssenariyni tekshir.

• Nima bo‘lganini taqqoslash uchun raw outputni alohida saqla; xulosani logdan farqlab yoz.

Tajribaning ikkinchi ko‘rinishi

QAYTA SINASH: 6 loyiha uchun source/evidence/limitation checklist. Boshqa izohni solishtiring; noaniq natijani PASS deb yozmang.

Texnik nuans: Sertifikatlar ma’lum yo‘lni tartiblaydi, lekin ish tajribasini to‘liq almashtirmaydi. Network+/Security+ kabi

Texnik izoh: Faoliyatsiz sertifikat barcha amaliy kompetensiyalarni isbotlamaydi. Capstone professional portfelga ruxsat, dalil, reproduksiya, remediation, retest va cheklovlarni qo‘yadi. Sertifikat emas, mustaqil amaliy ko‘nikma hujjati muhim.

Manbaga izoh: Kitob, CISA, OWASP, Kali/Nmap rasmiy docs va topshirilgan materiallardagi usullar texnik versiyaga mos kelmasligi mumkin. Buning uchun `--help`, man page va documentationdan tekshir.

48-hafta / Hisobot va challenge

12-OY • 6/6 DELIVERABLE / RETEST / SCORE

Bu hafta topshiriladigan haqiqiy natija

Portfolio artefakti

12 oy final portfolio

Qayta tekshirish protokoli

• Birlamchi observatsiya va taxminni ikki ustunga ajrating.

• Xuddi shu logni sog‘lom jarayon ham hosil qila oladimi?

• Yolg‘on musbat/inkor natijaga nima sabab bo‘lishi mumkin?

• O‘zgartirilgan fayl yoki servis qaytarildimi?

• Natija/vaqt/tool versiyasi dalil papkasiga yozildimi?

• Tuzatish taklifi va qayta tekshiruv bor-mi?

3 ta mustaqil savol

• “Career, ethics va capstone” mavzusida dastlabki input va final signal o‘rtasidagi ishonch chegarasini tushuntir.

• Bu tajriba nimani isbotlaydi, nimani isbotlamaydi? Muqobil sababni yoz.

• Shu kuzatuv uchun bitta himoya va undan keyingi retest mezonini tuz.

Baholash

Mezon	Ball
Texnik izoh va model	25
Xavfsiz amaliy bajarish	35
Dalil va takrorlash	20
Remediation va retest	20

Keyingi bosqichning amaliy savoli

Hafta mavzusi: Career, ethics va capstone. Mavjud xulosani qanday qilib mustaqil, xavfsiz ikkinchi dalil bilan tasdiqlaysan? Kerakli signal, eng kichik o‘zgarish, o‘zgartirilmagan baseline va rollback shartini yoz.

Ish daftari: qaysi xato senga eng ko‘p bilim berdi?

TUZATILGAN KOMPETENSIYA MEZONI

Mustaqil dalil: 6 loyiha uchun source/evidence/limitation checklist.
Xavfsizlik chegarasi: Portfelga haqiqiy password, JWT, token, shaxsiy ma’lumot qo‘shma.

Ilova N01 / Mashhur hackerlar va ularning tarixiy o‘rni

297–308-BETLAR • TARIX, MANBALAR, TAHLIL

Mavzuning mohiyati

Kevin Mitnick, Robert Tappan Morris, Gary McKinnon, Adrian Lamo va boshqa tarixiy shaxslarni tushunishda “xacker”ning o‘zi na maqtov, na ayblov hukmi. Manbada qaysi ish tasdiqlanganini, qaysi da’vo sudga yetganini va qaysi ishda qat’iy qaror mavjudligini ajrating.

To‘g‘ri fikrlash metodikasi

• Fakt qaysi tashkilotning rasmiy manbasidan yoki kitobning qaysi nashridan kelgan?

• E’lon sanasi va real hodisa sanasi bir xilmi? Davom etayotgan tergovda noaniqlik yozilganmi?

• Tahdidning mexanizmi, biznes oqibati va himoya o‘rtasidagi aloqa qanday?

• Haqiqiy ekspluatatsiya bilan ta’limdagi xavfsiz modelni aralashtirmang.

Qo‘shimcha chuqurlashtirish

Ushbu misolni oddiy “qaysi hacker kuchli” savoliga keltirish ilmiy nuqtayi nazardan yetarli emas. Mutaxassis zarar qanday ro‘y bergani, nazorat nima sabab ishlamagani, qaysi dalil mavjudligi va qanday tiklash chorasi talab qilinganini ko‘rib chiqadi.

Tahlil qatlami	Yoziladigan natija
Tarix / manba	Yil, muallif, institut, e’lonning turi va holat.
TTP / texnologiya	Initial access, privilege, collection, impact — faqat tasdiqlangan dalil.
Himoya / recovery	Patching, MFA, telemetry, backups, containment.

Mustaqil analitik topshiriq

Vazifa: bir tarixiy shaxs haqida manba, yil, fakt, nizo, ta’sir, huquqiy yakunni jadvalga yozing.

Ilova N02 / Davlat bilan bog‘langan tahdidlar va atribusiya

297–308-BETLAR • TARIX, MANBALAR, TAHLIL

Mavzuning mohiyati

APT28, Lazarus va Volt Typhoon kabi nomlar vendor va rasmiy advisorylarda uchraydi. Atribusiya ishonch darajasi, kampaniya va infratuzilma dalili bilan bog‘liq; “manba X shunday baholaydi” degani sud hukmi emas.

To‘g‘ri fikrlash metodikasi

• Fakt qaysi tashkilotning rasmiy manbasidan yoki kitobning qaysi nashridan kelgan?

• E’lon sanasi va real hodisa sanasi bir xilmi? Davom etayotgan tergovda noaniqlik yozilganmi?

• Tahdidning mexanizmi, biznes oqibati va himoya o‘rtasidagi aloqa qanday?

• Haqiqiy ekspluatatsiya bilan ta’limdagi xavfsiz modelni aralashtirmang.

Qo‘shimcha chuqurlashtirish

Ushbu misolni oddiy “qaysi hacker kuchli” savoliga keltirish ilmiy nuqtayi nazardan yetarli emas. Mutaxassis zarar qanday ro‘y bergani, nazorat nima sabab ishlamagani, qaysi dalil mavjudligi va qanday tiklash chorasi talab qilinganini ko‘rib chiqadi.

Tahlil qatlami	Yoziladigan natija
Tarix / manba	Yil, muallif, institut, e’lonning turi va holat.
TTP / texnologiya	Initial access, privilege, collection, impact — faqat tasdiqlangan dalil.
Himoya / recovery	Patching, MFA, telemetry, backups, containment.

Mustaqil analitik topshiriq

Vazifa: ATT&CK group sahifasini o‘qib TTP va atribusiya confidence’ni ajrating.

Ilova N03 / Ransomware-as-a-Service va jinoyat iqtisodi

297–308-BETLAR • TARIX, MANBALAR, TAHLIL

Mavzuning mohiyati

RaaS operator, affiliate, access broker, infrastruktura va tovlamachilik jarayonlarini ajratadi. Ularning munosabati doim barqaror emas. Himoyachi initial access va data movement dalillari bilan riskni tushunadi.

To‘g‘ri fikrlash metodikasi

• Fakt qaysi tashkilotning rasmiy manbasidan yoki kitobning qaysi nashridan kelgan?

• E’lon sanasi va real hodisa sanasi bir xilmi? Davom etayotgan tergovda noaniqlik yozilganmi?

• Tahdidning mexanizmi, biznes oqibati va himoya o‘rtasidagi aloqa qanday?

• Haqiqiy ekspluatatsiya bilan ta’limdagi xavfsiz modelni aralashtirmang.

Qo‘shimcha chuqurlashtirish

Ushbu misolni oddiy “qaysi hacker kuchli” savoliga keltirish ilmiy nuqtayi nazardan yetarli emas. Mutaxassis zarar qanday ro‘y bergani, nazorat nima sabab ishlamagani, qaysi dalil mavjudligi va qanday tiklash chorasi talab qilinganini ko‘rib chiqadi.

Tahlil qatlami	Yoziladigan natija
Tarix / manba	Yil, muallif, institut, e’lonning turi va holat.
TTP / texnologiya	Initial access, privilege, collection, impact — faqat tasdiqlangan dalil.
Himoya / recovery	Patching, MFA, telemetry, backups, containment.

Mustaqil analitik topshiriq

Vazifa: RaaS ekotizimini tahlikasiz actor/asset/control diagramga joylang.

Ilova N04 / WannaCry: 2017 worm-ransomware

297–308-BETLAR • TARIX, MANBALAR, TAHLIL

Mavzuning mohiyati

WannaCry SMB zaifligidan kelib chiqqan o‘z-o‘zidan tarqaluvchi xatti-harakat va fayl shifrlashni bog‘ladi. Keng qamrovda patch, segmentation va legacy exposure masalalarini kun tartibiga olib chiqdi.

To‘g‘ri fikrlash metodikasi

• Fakt qaysi tashkilotning rasmiy manbasidan yoki kitobning qaysi nashridan kelgan?

• E’lon sanasi va real hodisa sanasi bir xilmi? Davom etayotgan tergovda noaniqlik yozilganmi?

• Tahdidning mexanizmi, biznes oqibati va himoya o‘rtasidagi aloqa qanday?

• Haqiqiy ekspluatatsiya bilan ta’limdagi xavfsiz modelni aralashtirmang.

Qo‘shimcha chuqurlashtirish

Ushbu misolni oddiy “qaysi hacker kuchli” savoliga keltirish ilmiy nuqtayi nazardan yetarli emas. Mutaxassis zarar qanday ro‘y bergani, nazorat nima sabab ishlamagani, qaysi dalil mavjudligi va qanday tiklash chorasi talab qilinganini ko‘rib chiqadi.

Tahlil qatlami	Yoziladigan natija
Tarix / manba	Yil, muallif, institut, e’lonning turi va holat.
TTP / texnologiya	Initial access, privilege, collection, impact — faqat tasdiqlangan dalil.
Himoya / recovery	Patching, MFA, telemetry, backups, containment.

Mustaqil analitik topshiriq

Vazifa: infect-chain → patching → segmentation → recover mapping.

Ilova N05 / NotPetya: 2017 destruktiv hodisa

297–308-BETLAR • TARIX, MANBALAR, TAHLIL

Mavzuning mohiyati

NotPetya avval ransomwarega o‘xshab ko‘ringan, amalda keng destruktiv oqibat bilan yodda qolgan. Supply-chain yo‘li va korporativ tarmoq ishonch chegaralari jiddiy saboq bo‘ldi.

To‘g‘ri fikrlash metodikasi

• Fakt qaysi tashkilotning rasmiy manbasidan yoki kitobning qaysi nashridan kelgan?

• E’lon sanasi va real hodisa sanasi bir xilmi? Davom etayotgan tergovda noaniqlik yozilganmi?

• Tahdidning mexanizmi, biznes oqibati va himoya o‘rtasidagi aloqa qanday?

• Haqiqiy ekspluatatsiya bilan ta’limdagi xavfsiz modelni aralashtirmang.

Qo‘shimcha chuqurlashtirish

Ushbu misolni oddiy “qaysi hacker kuchli” savoliga keltirish ilmiy nuqtayi nazardan yetarli emas. Mutaxassis zarar qanday ro‘y bergani, nazorat nima sabab ishlamagani, qaysi dalil mavjudligi va qanday tiklash chorasi talab qilinganini ko‘rib chiqadi.

Tahlil qatlami	Yoziladigan natija
Tarix / manba	Yil, muallif, institut, e’lonning turi va holat.
TTP / texnologiya	Initial access, privilege, collection, impact — faqat tasdiqlangan dalil.
Himoya / recovery	Patching, MFA, telemetry, backups, containment.

Mustaqil analitik topshiriq

Vazifa: backup, business continuity, third-party software trustlarini baholang.

Ilova N06 / ILOVEYOU va Morris Worm

297–308-BETLAR • TARIX, MANBALAR, TAHLIL

Mavzuning mohiyati

ILOVEYOU ijtimoiy muhandislik va foydalanuvchi ishonchidan foydalanish tarixida muhim hodisa; Morris worm esa internet tarmoqlari bo‘ylab avtomatik tarqalishning dastlabki yirik namunasidir.

To‘g‘ri fikrlash metodikasi

• Fakt qaysi tashkilotning rasmiy manbasidan yoki kitobning qaysi nashridan kelgan?

• E’lon sanasi va real hodisa sanasi bir xilmi? Davom etayotgan tergovda noaniqlik yozilganmi?

• Tahdidning mexanizmi, biznes oqibati va himoya o‘rtasidagi aloqa qanday?

• Haqiqiy ekspluatatsiya bilan ta’limdagi xavfsiz modelni aralashtirmang.

Qo‘shimcha chuqurlashtirish

Ushbu misolni oddiy “qaysi hacker kuchli” savoliga keltirish ilmiy nuqtayi nazardan yetarli emas. Mutaxassis zarar qanday ro‘y bergani, nazorat nima sabab ishlamagani, qaysi dalil mavjudligi va qanday tiklash chorasi talab qilinganini ko‘rib chiqadi.

Tahlil qatlami	Yoziladigan natija
Tarix / manba	Yil, muallif, institut, e’lonning turi va holat.
TTP / texnologiya	Initial access, privilege, collection, impact — faqat tasdiqlangan dalil.
Himoya / recovery	Patching, MFA, telemetry, backups, containment.

Mustaqil analitik topshiriq

Vazifa: file attachment trust va network propagation o‘rtasidagi nazorat farqini yozing.

Ilova N07 / SolarWinds va supply-chain zarari

297–308-BETLAR • TARIX, MANBALAR, TAHLIL

Mavzuning mohiyati

2020-yil SolarWinds holatida dasturiy ta’minot ta’minot zanjirining ishonch modeli va tashkilotlararo kirish huquqlari muhim bo‘lgan. SBOM, build provenance va signing vazifasini mustaqil baholang.

To‘g‘ri fikrlash metodikasi

• Fakt qaysi tashkilotning rasmiy manbasidan yoki kitobning qaysi nashridan kelgan?

• E’lon sanasi va real hodisa sanasi bir xilmi? Davom etayotgan tergovda noaniqlik yozilganmi?

• Tahdidning mexanizmi, biznes oqibati va himoya o‘rtasidagi aloqa qanday?

• Haqiqiy ekspluatatsiya bilan ta’limdagi xavfsiz modelni aralashtirmang.

Qo‘shimcha chuqurlashtirish

Ushbu misolni oddiy “qaysi hacker kuchli” savoliga keltirish ilmiy nuqtayi nazardan yetarli emas. Mutaxassis zarar qanday ro‘y bergani, nazorat nima sabab ishlamagani, qaysi dalil mavjudligi va qanday tiklash chorasi talab qilinganini ko‘rib chiqadi.

Tahlil qatlami	Yoziladigan natija
Tarix / manba	Yil, muallif, institut, e’lonning turi va holat.
TTP / texnologiya	Initial access, privilege, collection, impact — faqat tasdiqlangan dalil.
Himoya / recovery	Patching, MFA, telemetry, backups, containment.

Mustaqil analitik topshiriq

Vazifa: CI/CD artifact integrity threat model yarating.

Ilova N08 / LockBit va Operation Cronos

297–308-BETLAR • TARIX, MANBALAR, TAHLIL

Mavzuning mohiyati

2024-yil huquqni muhofaza qiluvchi organlar LockBit infratuzilmasiga qarshi tadbirlarni e’lon qildi. Jinoiy gumon, ayblov va hukm — turli huquqiy holatlar.

To‘g‘ri fikrlash metodikasi

• Fakt qaysi tashkilotning rasmiy manbasidan yoki kitobning qaysi nashridan kelgan?

• E’lon sanasi va real hodisa sanasi bir xilmi? Davom etayotgan tergovda noaniqlik yozilganmi?

• Tahdidning mexanizmi, biznes oqibati va himoya o‘rtasidagi aloqa qanday?

• Haqiqiy ekspluatatsiya bilan ta’limdagi xavfsiz modelni aralashtirmang.

Qo‘shimcha chuqurlashtirish

Ushbu misolni oddiy “qaysi hacker kuchli” savoliga keltirish ilmiy nuqtayi nazardan yetarli emas. Mutaxassis zarar qanday ro‘y bergani, nazorat nima sabab ishlamagani, qaysi dalil mavjudligi va qanday tiklash chorasi talab qilinganini ko‘rib chiqadi.

Tahlil qatlami	Yoziladigan natija
Tarix / manba	Yil, muallif, institut, e’lonning turi va holat.
TTP / texnologiya	Initial access, privilege, collection, impact — faqat tasdiqlangan dalil.
Himoya / recovery	Patching, MFA, telemetry, backups, containment.

Mustaqil analitik topshiriq

Vazifa: rasmiy press-relizni vaqt, mamlakat, ayblov turi va natija bo‘yicha faktlarga ajrating.

Ilova N09 / Nega ba’zi tahdidchilar qo‘lga olinmagan?

297–308-BETLAR • TARIX, MANBALAR, TAHLIL

Mavzuning mohiyati

Yurisdiksiya, ekstraditsiya, dalil standartlari, chet hududda yashirin infratuzilma va davlatlararo hamkorlik murakkab. Bu omillar haqidagi faraz aniq shaxsning aybi yoki holatini tasdiqlamaydi.

To‘g‘ri fikrlash metodikasi

• Fakt qaysi tashkilotning rasmiy manbasidan yoki kitobning qaysi nashridan kelgan?

• E’lon sanasi va real hodisa sanasi bir xilmi? Davom etayotgan tergovda noaniqlik yozilganmi?

• Tahdidning mexanizmi, biznes oqibati va himoya o‘rtasidagi aloqa qanday?

• Haqiqiy ekspluatatsiya bilan ta’limdagi xavfsiz modelni aralashtirmang.

Qo‘shimcha chuqurlashtirish

Ushbu misolni oddiy “qaysi hacker kuchli” savoliga keltirish ilmiy nuqtayi nazardan yetarli emas. Mutaxassis zarar qanday ro‘y bergani, nazorat nima sabab ishlamagani, qaysi dalil mavjudligi va qanday tiklash chorasi talab qilinganini ko‘rib chiqadi.

Tahlil qatlami	Yoziladigan natija
Tarix / manba	Yil, muallif, institut, e’lonning turi va holat.
TTP / texnologiya	Initial access, privilege, collection, impact — faqat tasdiqlangan dalil.
Himoya / recovery	Patching, MFA, telemetry, backups, containment.

Mustaqil analitik topshiriq

Vazifa: attribution dalili va huquqiy statusni alohida ustunlarda beruvchi template tuzing.

Ilova N10 / Malware taksonomiyasi

297–308-BETLAR • TARIX, MANBALAR, TAHLIL

Mavzuning mohiyati

Virus, worm, trojan, rootkit, spyware, downloader, infostealer, ransomware, wiper turli tarqalish, bajarilish va impact mexanizmlariga ega; bitta namuna bir nechta toifaga kirishi mumkin.

To‘g‘ri fikrlash metodikasi

• Fakt qaysi tashkilotning rasmiy manbasidan yoki kitobning qaysi nashridan kelgan?

• E’lon sanasi va real hodisa sanasi bir xilmi? Davom etayotgan tergovda noaniqlik yozilganmi?

• Tahdidning mexanizmi, biznes oqibati va himoya o‘rtasidagi aloqa qanday?

• Haqiqiy ekspluatatsiya bilan ta’limdagi xavfsiz modelni aralashtirmang.

Qo‘shimcha chuqurlashtirish

Ushbu misolni oddiy “qaysi hacker kuchli” savoliga keltirish ilmiy nuqtayi nazardan yetarli emas. Mutaxassis zarar qanday ro‘y bergani, nazorat nima sabab ishlamagani, qaysi dalil mavjudligi va qanday tiklash chorasi talab qilinganini ko‘rib chiqadi.

Tahlil qatlami	Yoziladigan natija
Tarix / manba	Yil, muallif, institut, e’lonning turi va holat.
TTP / texnologiya	Initial access, privilege, collection, impact — faqat tasdiqlangan dalil.
Himoya / recovery	Patching, MFA, telemetry, backups, containment.

Mustaqil analitik topshiriq

Vazifa: har toifaga execution trigger, telemetry, mitigation va recovery nazoratini biriktiring.

Ilova N11 / Joriy standartlar va manbalar 1

297–308-BETLAR • TARIX, MANBALAR, TAHLIL

Manbalar bo‘limi: 2019-yil Packt nashri tarixiy; 2025–2026-yil NIST/OWASP/MITRE hujjatlari alohida yangilanadi. URLlar PDFda bosib ochiladi.

S01 Foydalanuvchi fayli: Mastering Kali Linux for Advanced Penetration T…
PDF:Mastering_Kali_Linux_for_Advanced.pdf

S02 Foydalanuvchi fayli: behruzO.pdf
PDF:behruzO.pdf

S03 Foydalanuvchi fayli: Pasted text.txt (Claude dars suhbatlari)
PDF:Pasted text.txt

S04 OWASP Top 10:2025
top10.owasp.org/2025/

S05 OWASP WSTG
owasp.org/projects/web-security-testing-guide/

S06 OWASP WSTG GitHub
github.com/OWASP/wstg

S07 MITRE ATT&CK Enterprise
attack.mitre.org/tactics/enterprise/

S08 MITRE ATT&CK T1486
attack.mitre.org/techniques/T1486/

S09 NIST SP 800-61 Revision 3
csrc.nist.gov/pubs/sp/800/61/r3/final

S10 NIST CSF 2.0
www.nist.gov/cyberframework

S11 NIST SP 800-63-4
csrc.nist.gov/pubs/sp/800/63/4/final

S12 NIST SP 800-115
csrc.nist.gov/pubs/sp/800/115/final

S13 CISA StopRansomware Guide
www.cisa.gov/resources-tools/resources/stopransomware-gui

S14 CISA Known Exploited Vulnerabilities
www.cisa.gov/known-exploited-vulnerabilities-catalog

S15 Kali Linux Documentation
www.kali.org/docs/

S16 Nmap Reference Guide
nmap.org/docs.html

S17 Wireshark User Guide
www.wireshark.org/docs/wsug_html_chunked/

S18 PortSwigger Web Security Academy
portswigger.net/web-security

Ilova N12 / Bibliografiya va GitHub manbalari 2

297–308-BETLAR • TARIX, MANBALAR, TAHLIL

Manbalar bo‘limi: 2019-yil Packt nashri tarixiy; 2025–2026-yil NIST/OWASP/MITRE hujjatlari alohida yangilanadi. URLlar PDFda bosib ochiladi.

S19 OverTheWire: Bandit
overthewire.org/wargames/bandit/

S20 SigmaHQ GitHub
github.com/SigmaHQ/sigma

S21 YARA-X Documentation
virustotal.github.io/yara-x/docs/

S22 CISA 2020 SolarWinds Advisory
www.cisa.gov/news-events/alerts/2020/12/17/advanced-persi

S23 NCSC/UK NotPetya case study
www.ncsc.gov.uk/files/ncsc_nca_report.pdf

S24 DOJ Operation Cronos/LockBit
www.justice.gov/usao-nj/pr/us-and-uk-disrupt-lockbit-rans

S25 DOJ LockBit identifikatsiya ayblovi
www.justice.gov/usao-nj/pr/us-charges-russian-national-de

S26 FBI Cyber Most Wanted
www.fbi.gov/investigate/cyber/most-wanted

S27 DOJ Kevin Mitnick arrest (1995)
www.justice.gov/archive/opa/pr/Pre_96/February95/89.txt.h

S28 CISA Volt Typhoon 2024
content.govdelivery.com/accounts/USDHSCISA/bulletins/3894

S29 CISA/FBI Gunra ransomware 2026
content.govdelivery.com/accounts/USDHSCISA/bulletins/4244

S30 YARA-X GitHub
github.com/VirusTotal/yara-x

S31 CISA/Sigma/MITRE methodology crosswalk
attack.mitre.org/

S32 NIST NVD
nvd.nist.gov/

S33 GitHub: rapid7/metasploitable3
github.com/rapid7/metasploitable3

S34 OWASP Juice Shop GitHub
github.com/juice-shop/juice-shop

S35 OWASP Cheat Sheet Series
cheatsheetseries.owasp.org/

Ilova A01 / Pentest report: 5 bo‘limli sifatli hisobot

309–320-BETLAR • VAZIFA / REPORT / BAHOLASH

O‘quv ssenariysi

Executive summary → scope/method → findings → mitigations → retest. Katta riskni biznes tilida tushuntiring; skaner screenshoti o‘rniga dalil kontekstini ko‘rsating.

Ishni topshirish shartlari

• Faoliyat oldidan scope va ma’lumotlar sun’iy yoki o‘zingizniki ekanini belgilang.

• Maqsad — nazoratning ishlashini ko‘rsatish, real tizimni ishdan chiqarish emas.

• Har bir outputga versiya, timestamp va source fieldlarini qo‘shing.

• Alternativ izoh va false-positive bahosini qo‘shing.

• Shart bajarilmaganda STOP deb belgilang, soxta PASS yozmang.

Yakuniy portfel artefakti

Topshiruv

Artefakt: 3 sahifalik anonymized lab report; 1 finding + remediation + confidence.

Sifat nazorati

Ko‘rsatkich	Pass mezoni
Nazariya	Tushuncha, trust boundary va risk aniq.
Amaliy dalil	Reproducible, scope ichida, sezgir ma’lumotsiz.
Tahlil	Observatsiya, taxmin va risk alohida.
Retest	Fix va acceptance mezoni bor.

Mustaqil kuzatuv va keyingi o‘quv savollari

Ilova A02 / Ransomware: SOC tabletop

309–320-BETLAR • VAZIFA / REPORT / BAHOLASH

O‘quv ssenariysi

Sintetik company: 100 endpoint, 5 server, daily backups. Hodisa vaqtida EDR signallari, identity rotation, offline backup va owner approval qarorlarini rangli jadvalga ajrating.

Ishni topshirish shartlari

• Faoliyat oldidan scope va ma’lumotlar sun’iy yoki o‘zingizniki ekanini belgilang.

• Maqsad — nazoratning ishlashini ko‘rsatish, real tizimni ishdan chiqarish emas.

• Har bir outputga versiya, timestamp va source fieldlarini qo‘shing.

• Alternativ izoh va false-positive bahosini qo‘shing.

• Shart bajarilmaganda STOP deb belgilang, soxta PASS yozmang.

Yakuniy portfel artefakti

Topshiruv

Artefakt: 15-min triage, 60-min contain, 24h recovery variantlari.

Sifat nazorati

Ko‘rsatkich	Pass mezoni
Nazariya	Tushuncha, trust boundary va risk aniq.
Amaliy dalil	Reproducible, scope ichida, sezgir ma’lumotsiz.
Tahlil	Observatsiya, taxmin va risk alohida.
Retest	Fix va acceptance mezoni bor.

Mustaqil kuzatuv va keyingi o‘quv savollari

Ilova A03 / Worm: grafik segmentatsiya eksperimenti

309–320-BETLAR • VAZIFA / REPORT / BAHOLASH

O‘quv ssenariysi

8 node grafda infektsiya tarqalish imkoniyatini dasturiy hisoblang; segmentatsiya qirralarini cheklash orqali tarqalish ko‘rsatkichini qiyoslang. Real tarmoqqa paket yubormang.

Ishni topshirish shartlari

• Faoliyat oldidan scope va ma’lumotlar sun’iy yoki o‘zingizniki ekanini belgilang.

• Maqsad — nazoratning ishlashini ko‘rsatish, real tizimni ishdan chiqarish emas.

• Har bir outputga versiya, timestamp va source fieldlarini qo‘shing.

• Alternativ izoh va false-positive bahosini qo‘shing.

• Shart bajarilmaganda STOP deb belgilang, soxta PASS yozmang.

Yakuniy portfel artefakti

Topshiruv

Artefakt: ikkita graf, boshlang‘ich node va reachability hisoblari.

Sifat nazorati

Ko‘rsatkich	Pass mezoni
Nazariya	Tushuncha, trust boundary va risk aniq.
Amaliy dalil	Reproducible, scope ichida, sezgir ma’lumotsiz.
Tahlil	Observatsiya, taxmin va risk alohida.
Retest	Fix va acceptance mezoni bor.

Mustaqil kuzatuv va keyingi o‘quv savollari

Ilova A04 / YARA marker va false positive

309–320-BETLAR • VAZIFA / REPORT / BAHOLASH

O‘quv ssenariysi

Faqat o‘quv faylga TRAINING_ONLY satrini joylashtiring. YARA-X o‘rnatilmagan bo‘lsa offline Python string matchdan foydalaning.

Ishni topshirish shartlari

• Faoliyat oldidan scope va ma’lumotlar sun’iy yoki o‘zingizniki ekanini belgilang.

• Maqsad — nazoratning ishlashini ko‘rsatish, real tizimni ishdan chiqarish emas.

• Har bir outputga versiya, timestamp va source fieldlarini qo‘shing.

• Alternativ izoh va false-positive bahosini qo‘shing.

• Shart bajarilmaganda STOP deb belgilang, soxta PASS yozmang.

Yakuniy portfel artefakti

Topshiruv

Artefakt: marker bor/yo‘qligi uchun 2 test, false positive tushuntirishi.

Sifat nazorati

Ko‘rsatkich	Pass mezoni
Nazariya	Tushuncha, trust boundary va risk aniq.
Amaliy dalil	Reproducible, scope ichida, sezgir ma’lumotsiz.
Tahlil	Observatsiya, taxmin va risk alohida.
Retest	Fix va acceptance mezoni bor.

Mustaqil kuzatuv va keyingi o‘quv savollari

Ilova A05 / Sigma rule scorecard

309–320-BETLAR • VAZIFA / REPORT / BAHOLASH

O‘quv ssenariysi

Sintetik login hodisalarini ikki qoida bilan tahlil qiling: bitta IP ko‘p user, bitta user ko‘p fail. FP va FNni oldindan rejalashtiring.

Ishni topshirish shartlari

• Faoliyat oldidan scope va ma’lumotlar sun’iy yoki o‘zingizniki ekanini belgilang.

• Maqsad — nazoratning ishlashini ko‘rsatish, real tizimni ishdan chiqarish emas.

• Har bir outputga versiya, timestamp va source fieldlarini qo‘shing.

• Alternativ izoh va false-positive bahosini qo‘shing.

• Shart bajarilmaganda STOP deb belgilang, soxta PASS yozmang.

Yakuniy portfel artefakti

Topshiruv

Artefakt: precision, recall, F1 va analyst workload jadvali.

Sifat nazorati

Ko‘rsatkich	Pass mezoni
Nazariya	Tushuncha, trust boundary va risk aniq.
Amaliy dalil	Reproducible, scope ichida, sezgir ma’lumotsiz.
Tahlil	Observatsiya, taxmin va risk alohida.
Retest	Fix va acceptance mezoni bor.

Mustaqil kuzatuv va keyingi o‘quv savollari

Ilova A06 / Windows log lab: EventID 4624/4625

309–320-BETLAR • VAZIFA / REPORT / BAHOLASH

O‘quv ssenariysi

Synthetic Windows security log jadvalidagi timestamp, LogonType va source workstationni birlashtirib shubhali login ssenariysi tuzing.

Ishni topshirish shartlari

• Faoliyat oldidan scope va ma’lumotlar sun’iy yoki o‘zingizniki ekanini belgilang.

• Maqsad — nazoratning ishlashini ko‘rsatish, real tizimni ishdan chiqarish emas.

• Har bir outputga versiya, timestamp va source fieldlarini qo‘shing.

• Alternativ izoh va false-positive bahosini qo‘shing.

• Shart bajarilmaganda STOP deb belgilang, soxta PASS yozmang.

Yakuniy portfel artefakti

Topshiruv

Artefakt: timeline, false positive ehtimoli, MFA qarori.

Sifat nazorati

Ko‘rsatkich	Pass mezoni
Nazariya	Tushuncha, trust boundary va risk aniq.
Amaliy dalil	Reproducible, scope ichida, sezgir ma’lumotsiz.
Tahlil	Observatsiya, taxmin va risk alohida.
Retest	Fix va acceptance mezoni bor.

Mustaqil kuzatuv va keyingi o‘quv savollari

Ilova A07 / Cloud IAM policy review

309–320-BETLAR • VAZIFA / REPORT / BAHOLASH

O‘quv ssenariysi

Wildcards va noto‘g‘ri resource scope bilan policy e’lon qiling, keyin least privilegega kamaytiring. Bu misol faqat JSON matni bo‘lsin.

Ishni topshirish shartlari

• Faoliyat oldidan scope va ma’lumotlar sun’iy yoki o‘zingizniki ekanini belgilang.

• Maqsad — nazoratning ishlashini ko‘rsatish, real tizimni ishdan chiqarish emas.

• Har bir outputga versiya, timestamp va source fieldlarini qo‘shing.

• Alternativ izoh va false-positive bahosini qo‘shing.

• Shart bajarilmaganda STOP deb belgilang, soxta PASS yozmang.

Yakuniy portfel artefakti

Topshiruv

Artefakt: Before/After policy diff va 5 test.

Sifat nazorati

Ko‘rsatkich	Pass mezoni
Nazariya	Tushuncha, trust boundary va risk aniq.
Amaliy dalil	Reproducible, scope ichida, sezgir ma’lumotsiz.
Tahlil	Observatsiya, taxmin va risk alohida.
Retest	Fix va acceptance mezoni bor.

Mustaqil kuzatuv va keyingi o‘quv savollari

Ilova A08 / Web AuthZ test suite

309–320-BETLAR • VAZIFA / REPORT / BAHOLASH

O‘quv ssenariysi

Sun’iy tenant-A va tenant-B obyekti uchun access-control unittest yozing. Har bir requestda tenant check qilinishi kerak.

Ishni topshirish shartlari

• Faoliyat oldidan scope va ma’lumotlar sun’iy yoki o‘zingizniki ekanini belgilang.

• Maqsad — nazoratning ishlashini ko‘rsatish, real tizimni ishdan chiqarish emas.

• Har bir outputga versiya, timestamp va source fieldlarini qo‘shing.

• Alternativ izoh va false-positive bahosini qo‘shing.

• Shart bajarilmaganda STOP deb belgilang, soxta PASS yozmang.

Yakuniy portfel artefakti

Topshiruv

Artefakt: 4 unit test, 1 intentionally failing fixture, patch.

Sifat nazorati

Ko‘rsatkich	Pass mezoni
Nazariya	Tushuncha, trust boundary va risk aniq.
Amaliy dalil	Reproducible, scope ichida, sezgir ma’lumotsiz.
Tahlil	Observatsiya, taxmin va risk alohida.
Retest	Fix va acceptance mezoni bor.

Mustaqil kuzatuv va keyingi o‘quv savollari

Ilova A09 / Packet capture evidence pack

309–320-BETLAR • VAZIFA / REPORT / BAHOLASH

O‘quv ssenariysi

Faqat 127.0.0.1 serveri va lo interfeysi. TCP ulanishini 5-tuple, SYN/ACK, HTTP va close bo‘yicha tasniflang.

Ishni topshirish shartlari

• Faoliyat oldidan scope va ma’lumotlar sun’iy yoki o‘zingizniki ekanini belgilang.

• Maqsad — nazoratning ishlashini ko‘rsatish, real tizimni ishdan chiqarish emas.

• Har bir outputga versiya, timestamp va source fieldlarini qo‘shing.

• Alternativ izoh va false-positive bahosini qo‘shing.

• Shart bajarilmaganda STOP deb belgilang, soxta PASS yozmang.

Yakuniy portfel artefakti

Topshiruv

Artefakt: annotated pcap sample, UTC va hash.

Sifat nazorati

Ko‘rsatkich	Pass mezoni
Nazariya	Tushuncha, trust boundary va risk aniq.
Amaliy dalil	Reproducible, scope ichida, sezgir ma’lumotsiz.
Tahlil	Observatsiya, taxmin va risk alohida.
Retest	Fix va acceptance mezoni bor.

Mustaqil kuzatuv va keyingi o‘quv savollari

Ilova A10 / Recovery drill: immutable backup savollari

309–320-BETLAR • VAZIFA / REPORT / BAHOLASH

O‘quv ssenariysi

O‘z test papkangdan nusxa olib qayta tikla; original/restore SHA-256 taqqosla. Keyin offsite va immutability nazoratini nazariy qo‘sh.

Ishni topshirish shartlari

• Faoliyat oldidan scope va ma’lumotlar sun’iy yoki o‘zingizniki ekanini belgilang.

• Maqsad — nazoratning ishlashini ko‘rsatish, real tizimni ishdan chiqarish emas.

• Har bir outputga versiya, timestamp va source fieldlarini qo‘shing.

• Alternativ izoh va false-positive bahosini qo‘shing.

• Shart bajarilmaganda STOP deb belgilang, soxta PASS yozmang.

Yakuniy portfel artefakti

Topshiruv

Artefakt: RPO/RTO, restore duration, sha256 PASS.

Sifat nazorati

Ko‘rsatkich	Pass mezoni
Nazariya	Tushuncha, trust boundary va risk aniq.
Amaliy dalil	Reproducible, scope ichida, sezgir ma’lumotsiz.
Tahlil	Observatsiya, taxmin va risk alohida.
Retest	Fix va acceptance mezoni bor.

Mustaqil kuzatuv va keyingi o‘quv savollari

Ilova A11 / Rules of Engagement: tayyor cheklist

309–320-BETLAR • VAZIFA / REPORT / BAHOLASH

O‘quv ssenariysi

Asset owner, written authorization, domain/IP, excluded systems, time, rate caps, data handling, emergency contact, report delivery, cleanup.

Ishni topshirish shartlari

• Faoliyat oldidan scope va ma’lumotlar sun’iy yoki o‘zingizniki ekanini belgilang.

• Maqsad — nazoratning ishlashini ko‘rsatish, real tizimni ishdan chiqarish emas.

• Har bir outputga versiya, timestamp va source fieldlarini qo‘shing.

• Alternativ izoh va false-positive bahosini qo‘shing.

• Shart bajarilmaganda STOP deb belgilang, soxta PASS yozmang.

Yakuniy portfel artefakti

Topshiruv

Artefakt: imzolashga tayyor scope formasi (namunaviy, haqiqiy yuridik maslahat emas).

Sifat nazorati

Ko‘rsatkich	Pass mezoni
Nazariya	Tushuncha, trust boundary va risk aniq.
Amaliy dalil	Reproducible, scope ichida, sezgir ma’lumotsiz.
Tahlil	Observatsiya, taxmin va risk alohida.
Retest	Fix va acceptance mezoni bor.

Mustaqil kuzatuv va keyingi o‘quv savollari

Ilova A12 / Yakuniy portfolio & ishga tayyorlik

309–320-BETLAR • VAZIFA / REPORT / BAHOLASH

O‘quv ssenariysi

6 ish: network map; web threat model; auth unit tests; malware triage; IR timeline; detection + XDR diagram. Har biriga source, result, feedback va retest qo‘shing.

Ishni topshirish shartlari

• Faoliyat oldidan scope va ma’lumotlar sun’iy yoki o‘zingizniki ekanini belgilang.

• Maqsad — nazoratning ishlashini ko‘rsatish, real tizimni ishdan chiqarish emas.

• Har bir outputga versiya, timestamp va source fieldlarini qo‘shing.

• Alternativ izoh va false-positive bahosini qo‘shing.

• Shart bajarilmaganda STOP deb belgilang, soxta PASS yozmang.

Yakuniy portfel artefakti

Topshiruv

Artefakt: README, screenshot, checksums, signed-off scope, 90-day next plan.

Sifat nazorati

Ko‘rsatkich	Pass mezoni
Nazariya	Tushuncha, trust boundary va risk aniq.
Amaliy dalil	Reproducible, scope ichida, sezgir ma’lumotsiz.
Tahlil	Observatsiya, taxmin va risk alohida.
Retest	Fix va acceptance mezoni bor.

Mustaqil kuzatuv va keyingi o‘quv savollari